# AI Governance Platform – Aegis.AI




**Submitted By**

Ahmad Abdullah Khan – F2022376096
Muhammad Haris – F2022376040
Farhana Minhas – F2022376126

**Session: 2022-2026**

**Project Supervisor:** Usama Ahmed

**Department of Artificial Intelligence and Data Science**
**School of Systems and Technology**
**University of Management and Technology**
**C-II Johar Town Lahore Pakistan**

# Dedication

Dedicated to everyone working to make Artificial Intelligence safe, accountable, and transparent and to the open standards community that makes such efforts possible.

# Final Approval
# AI Governance Platfrom – Aegis.AI

## Panel of Examiners

- **Head of Department** _____
  Department of AI & DS
  University of Management and Technology
  Lahore

- Program Director ( Final Year Projects) _____
  Department of AI & DS
  University of Management and Technology
  Lahore

- **Supervisor** _____
  Department of AI & DS
  University of Management and Technology
  Lahore

- **Co-Supervisor** _____
  (If any)

- Documentation Evaluator _____

## Acknowledgment

This component is planned for implementation in the next phase of the project (FYP II).

**Project Title:** AI Governance Platform – Aegis.AI

**Objective:** To build a self-hostable AI governance platform that helps organizations comply with AI regulations such as the EU AI Act, ISO 42001, ISO 27001, and NIST AI RMF.

**Undertaken by:** Muhammad Haris, Ahmad Abdullah Khan, Farhana Minhas

Supervised by: Usama Ahmad

Starting Date: November 2025

Completion Date: June 2026

**Tools Used:** React, Node.js, TypeScript, PostgreSQL, Redis, Python, FastAPI, Docker, Kubernetes

**Operating System:** Cross-platform (Linux production, Windows/macOS development)

**Documentation:** Microsoft Word / Markdown

# Plagairism Report

# Declaration Form

I have carefully examined the documentation of the Final Year Project titled *"AI Governance Platform – Aegis.AI"*; and I endorse that this documentation complies with the standards of an undergraduate level Final Year Project report.

The document has been checked for plagiarism through Turnitin software available in UMT Library. The similarities of the document are within acceptable range.

Moreover, the accompanying CDs contain PDF of the documentation, as well as the source code and binaries with user manual and installation guide.

FYP Supervisor Name: _____

Signature: _____ Date:_____

# Abstract

Aegis.AI is a self-hostable AI governance platform designed to help business's adopt Artificial Intelligence safely and responsibly. As organizations increasingly integrate AI into critical workflows, there is a growing need for structured oversight, regulatory compliance, and transparent risk management. Existing tools are often expensive, cloud-only, and lack the customizability required by enterprises with strict data residency requirements.

This project presents a full-stack AI governance solution built using the PERN stack (PostgreSQL, Express.js, React, Node.js) with TypeScript, augmented by a Python-based LLM Evaluation Server (FastAPI). The platform supports four major compliance frameworks, the EU AI Act, ISO 42001, ISO 27001, and NIST AI RMF, and provides features including an AI Model Inventory, Risk Management, Vendor Management, Policy Manager, LLM Evaluations and Arena, AI Advisor chatbot, AI Detection Module, Evidence Hub, CE Marking Registry, AI Trust Center, and comprehensive reporting.

The system follows Clean Architecture principles, implements multi-tenant data isolation using PostgreSQL schema-per-tenant, employs JWT-based authentication with RBAC, and supports Docker and Kubernetes deployment. It integrates with Slack, MLflow, and GitHub, and enables automated governance workflows and AI literacy tracking.

## REVISION CHART

| Version | Date | Author(s) | Reviewed By | Description of Changes |
|---|---|---|---|---|
| Draft | November 2025 | Muhammad Haris, Ahmed Abdullah Khan, Farhana Minhas | Usama Ahmad | Initial Requirements – Submitted for Approval |
| Preliminary | January 2026 | Muhammad Haris, Ahmd Abdullah Khan, Farhana Minhas | Usama Ahmad | Finalized Requirements Documented |
| Revision 1 | February 2026 | Muhammad Haris, Ahmed Abdullah Khan, Farhana Minhas | Usama Ahmad | Scope Updated |
| Revision 2 | March 2026 | Muhammad Haris, Ahmed Abdullah Khan, Farhana Minhas | Usama Ahmad | Scope Updated |
| Final | March 2026 | Muhammad Haris, Ahmed Abdullah Khan, Farhana Minhas | Usama Ahmad | Final Version – For FYP 1 Evaluation |

# TABLE OF CONTENTS

## Contents


Table of Contents ..... 1
Definitions and Acronyms ..... 6
1. Introduction ..... 7
1.1 Problem Statement ..... 7
1.2 Objectives ..... 8
1.3 Scope of the Project ..... 8
1.4 Significance of the Project ..... 9
1.5 Artificial Intelligence features ..... 10
1.6 Project Deliverables ..... 11
2. Domain Analysis ..... 12
2.1 Customer ..... 12
2.2 Stakeholders ..... 12
2.3 Affected Groups with social or economic impact ..... 13
2.4 Dependencies/ External Systems ..... 14
2.5 Related Projects with feature comparision ..... 15
2.5.1 Related Projects ..... 15
2.5.2 Feature Comparison ..... 15
2.6 Context Diagram ..... 18
2.7 Data Flow Diagram Level 0 ..... 19
3. Requirements analysis ..... 20
3.1 List of Actors ..... 20
3.2 Product Backlog ..... 21
3.3 Figma UI/UX Designs ..... 38
4. Project Planning and Execution using Sprints ..... 47
4.1 Jira ..... 47
4.2 Slack ..... 47
4.3 Github Repository ..... 47
4.4 Sprint 1: Foundation & Authentication ..... 47
4.5 Sprint 2: Multi-Tenancy, Approvals & Use Case Management ..... 57
4.6 Sprint 3: EU AI Act Compliance Framework ..... 66
4.7 Sprint 4: ISO 42001 & ISO 27001 Frameworks: ..... 74

4.8 Sprint 5: Risk Management ..... 79
4.9 Sprint 6: Vendor Management, Policy Manager & Tasks ..... 88
4.10 Sprint 7: AI Model Inventory & NIST AI RMF ..... 96
4.11 Sprint 8: LLM Evaluations UI & AI Advisor UI ..... 103
4.12 Sprint 9: Reporting, Evidence Hub, Notes, Search & AI Trust Center ..... 109
5. System Architecture ..... 117
5.1 System context Diagram ..... 117
5.2 System Container Diagram ..... 118
5.3 Component Diagram ..... 119
5.4 Code Diagrams ..... 120
5.5 ERD ..... 121
5.6 Data Dictionary ..... 121
6. Implementation details ..... 125
6.1 Development Setup ..... 125
6.2 Deployment setup ..... 126
6.3 Algorithms ..... 127
6.4 Constraints ..... 128
7. Project Monitoring, control and traceability ..... 130
7.1 Traceability Matrix ..... 130
7.1.1 Requirements vs Prototype (PB-ID vs PID) ..... 130
7.1.2 Requirements vs Test Cases (PB-ID vs TID) ..... 132
8. Results/Output/Statistics ..... 136
9. Conclusion ..... 143
10. Future work ..... 144
11. Bibliography ..... 145
12. Appendix ..... 146

## List of Figures:

**Figure 1: Aegis.AI System Context Diagram** ..... 18
**Figure 2: Aegis.AI DFD Level 0** ..... 19
**Figure 3: Product Backlog Hierarchy** ..... 21
**Figure 4: Prototype -Login** ..... 38
**Figure 5: Prototype - Register** ..... 38
**Figure 6: Prototype-Dashboard** ..... 39
**Figure 7: Prototype-AI detection** ..... 39
**Figure 8: Prototype-AI Trust Center** ..... 40
**Figure 9: Prototype- Approval Workflows** ..... 40
**Figure 10: Prototype-Automations** ..... 41
**Figure 11: Prototype-LLM Evaluations** ..... 41
**Figure 12: Prototype-Model Inventory** ..... 42
**Figure 13: Prototype-Overview** ..... 42
**Figure 14:Prototype-Policies** ..... 43
**Figure 15: Prototype-Reporting** ..... 43
**Figure 16: Prototype-Risk Management** ..... 44
**Figure 17: Prototype-Settings** ..... 44
**Figure 18: Prototype-Tasks** ..... 45
**Figure 19: Prototype-Vendors** ..... 45
**Figure 20: Prototype -Watch Tower** ..... 46
**Figure 21: Sprint 1 Class Diagram** ..... 51
**Figure 22: Sprint 1 Sequence Diagram** ..... 52
**Figure 23: Sprint 1 Decision Table** ..... 53
**Figure 24: Class Diagram** ..... 60
**Figure 25: Sprint 2 Class Diagram** ..... 61
**Figure 26: Sprint 2 Sequence Diagram** ..... 62
**Figure 27: Sprint 3 Class Diagram** ..... 69
**Figure 28: Sprint 3 Sequence Diagram** ..... 70
**Figure 29: Sprint 5 Class Diagram** ..... 83
**Figure 30: Sprint 5 Sequence Diagram** ..... 84
**Figure 31: Sprint 6 Class Diagram** ..... 91
**Figure 33: Sprint 7 Class Diagram** ..... 98
**Figure 34: Sprint 7 Sequence Diagram** ..... 99
**Figure 35: Sprint 8 Class Diagram** ..... 105
**Figure 36: Sprint 8 Sequence Diagram** ..... 106
**Figure 37: Sprint 9 Class Diagram** ..... 112
**Figure 38: Sprint 9 Sequence Diagram** ..... 113
**Figure 39: System Context Diagram** ..... 117
**Figure 40: System Container Diagram** ..... 118
**Figure 41: Component Diagram** ..... 119
**Figure 42: Code Diagram Backend File Structure** ..... 120
**Figure 43: ERD Diagram** ..... 121

## List of Tables:


**Table 1: List Of Acronyms And Defintions Used In the System ..... 6**
**Table 2: List Of Stakeholders ..... 12**
**Table 3: List Of Dependencies and External Systems ..... 14**
**Table 4: Sprint 1 Selected User stories from Product Backlog ..... 47**
**Table 5: Sprint 1 Team Capacity ..... 48**
**Table 6: Sprint 1 Sprint backlog ..... 49**
**Table 7: Sprint 1 Decision Table: Role-Based Access Control ..... 52**
**Table 8: Sprint 1 Extended Test Cases ..... 53**
**Table 9: Sprint 1 Review Status of Sprint Backlog ..... 55**
**Table 10: Sprint 2 Selected User stories From Product backlog ..... 57**
**Table 11: Sprint 2 Team Capacity ..... 57**
**Table 12: Sprint 2 Sprint Backlog ..... 58**
**Table 13: Sprint 2 Decision Table: Approval Request State Transitions ..... 62**
**Table 14: sprint 2 Extended Test Cases ..... 63**
**Table 15: Sprint 2 Review Status of Sprint backlog ..... 65**
**Table 16: Sprint 3 Selected User Stories From Product Backlog ..... 66**
**Table 17: Sprint 3 Team Capacity ..... 67**
**Table 18: Sprint 3 Sprint Backlog ..... 67**
**Table 19: Sprint 3 Decision Table: EU AI Act Control Status Transitions ..... 70**
**Table 20: Sprint 3 Extended Test cases ..... 71**
**Table 21: Sprint 3 Review Status of Sprint Backlog ..... 73**
**Table 22: Sprint 4 Selected User Stories from Product Backlog ..... 74**
**Table 23: Sprint 4 Team Capacity ..... 74**
**Table 24: Sprint 4 Sprint Backlog ..... 75**
**Table 25: Sprint 4 Decision Table: ISO Clause 7-Stage Status Workflow ..... 76**
**Table 26: Sprint 4 Extended Test Cases ..... 77**
**Table 27: Sprint 4 Review Status of Sprint Backlog ..... 78**
**Table 28: Sprint 5 Selected User Stories from Product Backlog ..... 80**
**Table 29: Sprint 5 Team Capacity ..... 80**
**Table 30: Sprint 5 Sprint Backlog ..... 81**
**Table 31: Sprint 5 Decision Table Risk Level Auto-Calculation ..... 84**
**Table 32: Sprint 5 Extended Test Cases ..... 85**
**Table 33: Sprint 5 Review Status of Sprint Backlog ..... 87**
**Table 34: Sprint 6 Selected User Stories from Product Backlog ..... 88**
**Table 35: Sprint 6 Team Capacity ..... 89**
**Table 36: Sprint 6 Sprint Backlog ..... 89**
**Table 37: Sprint 6 Decision Table Policy Lifecycle Transitions ..... 92**
**Table 38: Sprint 6 Extended Test Cases ..... 93**
**Table 39: Sprint 6 Sprint Review Status of Sprint Backlog ..... 94**
**Table 40: Sprint 7 Selected User Stories from Product Backlog ..... 96**
**Table 41: Sprint 7 Team Capacity ..... 96**
**Table 42: Sprint 7 Sprint Backlog ..... 97**
**Table 43: Sprint 7 Decision Table NIST AI RMF Function Applicability ..... 99**
**Table 44: Sprint 7 Extended Test Cases ..... 100**
**Table 45: Sprint 7 Sprint Review Status of Sprint Backlog ..... 102**

**Table 46: Sprint 8 Selected User Stories from Product Backlog ..... 103**
**Table 47: Sprint 8 Team Capacity ..... 103**
**Table 48: Sprint 8 Sprint Backlog ..... 104**
**Table 49: Sprint 8 Decision Table LLM Feature Activation Requirements ..... 106**
**Table 50: Sprint 8 Extended Test Cases ..... 107**
**Table 51: Sprint 8 Review Status of Sprint Backlog ..... 108**
**Table 52: Sprint 9 Selected User Stories from Product Backlog ..... 109**
**Table 53: Sprint 9 Team Capacity ..... 110**
**Table 54: Sprint 9 Sprint Backlog ..... 111**
**Decision Table Table 55: Sprint 9 Decision Table Report Types and Output ..... 113**
**Table 56: Sprint 9 Extended Test Cases ..... 114**
**Table 57: Sprint 9 Review Status of Sprint Backlog ..... 115**
**Table 58: projects (Use Cases) ..... 121**
**Table 59: project_risks ..... 122**
**Table 60: approval_workflows ..... 123**
**Table 61: post_market_monitoring_configs ..... 123**
**Table 62: Requirements vs Prototype Traceability Matrix ..... 130**
**Table 63: Requirements vs Test Cases Traceability Matrix ..... 132**
**Table 64: Platform Completion Metrics ..... 136**
**Table 65: Compliance Framework Coverage Statistics ..... 136**
**Table 66: Feature Completeness ..... 136**
**Table 67: Performance Benchmarks ..... 139**
**Table 68: System Correctness Measurements ..... 140**

# Definitions and Acronyms

**Table 1: List Of Acronyms And Defintions Used In the System**

| Acronym | Definition |
|---|---|
| AI | Artificial Intelligence |
| LLM | Large Language Model |
| EU AI Act | European Union Artificial Intelligence Act |
| ISO | International Organization for Standardization |
| NIST | National Institute of Standards and Technology |
| RMF | Risk Management Framework |
| RBAC | Role-Based Access Control |
| PERN | PostgreSQL, Express.js, React, Node.js |
| JWT | JSON Web Token |
| ORM | Object-Relational Mapping |
| SPA | Single-Page Application |
| REST | Representational State Transfer |
| API | Application Programming Interface |
| CRUD | Create, Read, Update, Delete |
| CI/CD | Continuous Integration / Continuous Delivery |
| BSL | Business Source License |
| CE | Conformité Européenne |
| MUI | Material UI |

# 1. INTRODUCTION

The rate of introducing AI systems into businesses has been higher than designing appropriate frameworks and control mechanisms. The issue of AI is becoming more and more regulated, particularly in the European Union. The EU AI Act mandates high-risk systems be assessed in terms of risk, documented, promoted openness and human supervision. Other world standards such as ISO 42001, ISO 27001 and the NIST AI Risk Management Framework are also a guide. All these must be done simultaneously thus consuming a lot of time, money, and effort on the side of organizations.

The current AI governance solutions are mostly proprietary, run on cloud and do not allow small to medium size businesses. All the organizations that have relatively stringent data sovereignty needs cannot use SaaS solutions, and there is a limited number of self-hostable solutions available which have the broad range of functionality needed to take regulation compliance as a whole.

This gap was to be filled by Aegis.AI. It is an artificial intelligence governance platform, which can be fully hosted either in a private cloud or on-prem, hence, enabling organizations an appropriate degree of control over their governance processes and data.

## 1.1 Problem Statement

The implementation of AI systems in companies is a multi-dimensional governance problem:

**Regulatory Complexity:** Compliance with the EU AI Act, ISO 42001, ISO 27001, and the NIST AI Risk Management Framework stipulates that hundreds of controls, assessments, and evidence have to be monitored in a variety of projects.

**Missing Overriding Controls:** Models, risks, vendors, and policies are handled in discrete spreadsheets, tools, and systems that have no central perspective.

**None is an On-Premises, Self-Hostable Alternative:** Current AI governance solutions are expensive SaaS products or too restricted, compelling companies to integrate multiple disjointed instruments.

**Manual, Error-Prone Audit:** Audit processes are manual, slow, and can hardly be repeated with consistency, thus creating inconsistencies and causing delays in reporting.

**None Built-In AI Safety:** Organizations do not have tools in place to evaluate the behavior of LLMs, identify problematic AI-written code, and monitor the future quality of the model.

The centralized compliance management, risk tracking, vendor management, model testing, and policy planning through an integrated, self-governed AI platform should be in one system.

## 1.2 Objectives

- The primary objectives of this project are:
- To develop a full-stack AI governance platform that supports the EU AI Act, ISO 42001, ISO 27001, and NIST AI RMF frameworks from a single interface.
- To provide an AI Model Inventory with risk assessment and change tracking for all AI models deployed within an organization.
- To implement a Vendor Management module for monitoring third-party AI vendors and their associated risks.
- To create a Policy Manager that enables organizations to draft, manage, and link internal AI policies to framework controls.
- To build an AI Advisor — an LLM-powered chatbot that provides governance recommendations based on project context.
- To integrate an LLM Evaluation module (LLM Evals & Arena) for benchmarking and comparing language model performance.
- To develop an AI Detection Module that scans code repositories for AI-generated content.
- To support multi-tenancy so that a single deployment can serve multiple organizations with complete data isolation.
- To enable Docker and Kubernetes deployment for enterprise-grade scalability and on-premises hosting.
- To generate PDF and DOCX compliance reports for internal and external audit purposes.

## 1.3 Scope of the Project

- Full-stack web application (React frontend + Node.js backend + Python evaluation server)
- Compliance framework support: EU AI Act, ISO 42001, ISO 27001, NIST AI RMF
- AI Model Inventory and Model Risk tracking
- Project-level risk management (Project Risks, Vendor Risks, Model Risks)
- Vendor and vendor risk management

- AI Policy Manager with policy-to-control mapping
- Task management and assignment workflows
- AI Incident Management
- Evidence Hub for compliance evidence storage
- CE Marking Registry
- AI Trust Center (public-facing transparency page)
- AI Literacy Training Registry
- LLM Evaluations and LLM Arena (benchmarking)
- AI Advisor (LLM-powered governance chatbot)
- AI Detection Module (repository scanning for AI-generated code)
- WatchTower / Event Tracker (live event audit log and system log viewer)
- Automations (event-driven workflows, webhooks, periodic reports)
- Integrations: Slack, MLflow, GitHub
- Approval Workflows for policies and risks
- Reporting module (PDF, DOCX export)
- User management with RBAC (Admin, Editor, Reviewer, Auditor)
- Multi-tenancy with PostgreSQL schema-per-tenant isolation
- Docker Compose and Kubernetes deployment support
- Email notifications (AWS SES, Exchange Online, SMTP, Resend)
- Google OAuth2 authentication
- Out of Scope
- Native mobile applications (iOS/Android)
- Real-time video/audio monitoring of AI systems
- Direct integration with model training pipelines
- Vendor billing or contract management
- Legal advice or formal compliance certification

## 1.4 Significance of the Project

Aegis.AI provides significant value across multiple dimensions:

**Regulatory Compliance:** Helps organizations systematically meet EU AI Act and ISO/NIST requirements, reducing the risk of regulatory penalties in markets where AI regulation is becoming mandatory.

**Cost Reduction:** By centralizing governance in a single self-hosted platform, organizations eliminate the need for multiple SaaS subscriptions and reduce manual audit labor.

**Transparency and Trust:** The AI Trust Center provides a public-facing view of an organization's AI posture, building confidence with customers, partners, and regulators.

**Technical Depth:** The combination of a compliance management platform with functional LLM evaluation capabilities (Evals & Arena) and an AI Detection Module represents a holistic approach to AI governance that no comparable self-hostable project provides.

**Community & democratization:** By releasing under BSL 1.1 with full source access, Aegis.AI democratizes AI governance best practices for organizations that cannot afford enterprise SaaS tools.

## 1.5 Artificial Intelligence features

Aegis.AI directly integrates several AI capabilities:

**1. AI Advisor (Governance Chatbot)** An LLM-powered chatbot built on OpenAI and Anthropic APIs that provides context-aware governance recommendations. The Advisor is aware of the organization's projects, risks, vendors, and compliance status, and can answer questions, generate draft policies, and suggest risk mitigations. It maintains conversation history per user session and is accessible via a persistent sidebar in the UI.

**2. LLM Evaluations and LLM Arena** A dedicated evaluation server (FastAPI/Python) using the DeepEval framework allows organizations to:

- Run structured benchmark experiments on LLMs (correctness, faithfulness, hallucination, bias detection),
- Compare LLM models head-to-head in an "arena" format
- Track evaluation logs and performance trends over time
- Store and manage evaluation-specific API keys

**3. AI Detection Module Scans** connected GitHub repositories to identify AI-generated content in code. Uses configurable rules and scanning algorithms to flag files or functions likely produced by AI code generation tools, supporting intellectual property and compliance oversight.

**4. AI-Generated Compliance** Answers The assessment modules can leverage LLM capabilities to auto-generate suggested answers for compliance assessment questions mapped to EU AI Act controls, reducing the manual effort required during audits.

**5. Post-Market Monitoring (PMM)** An automated background job that continuously monitors deployed AI models for performance degradation, bias drift, and compliance violations, generating alerts when thresholds are breached.

## 1.6 Project Deliverables

- A fully functional web-based AI governance platform (Aegis.AI)
- Source code repository with clean architecture and documentation
- API documentation (Swagger/OpenAPI at /api/docs)
- Docker Compose configuration for one-command local deployment
- Kubernetes manifests for production-scale deployment
- User guide and feature walkthrough documentation
- PDF and DOCX report export templates
- This FYP documentation report
- Recorded demo walkthrough for FYP presentation

# 2. DOMAIN ANALYSIS

## 2.1 Customer

Aegis.AI's primary customers are organizations that develop, procure, or deploy AI systems and are subject to regulatory or internal governance requirements. This includes:

Technology companies building AI-powered products who need to demonstrate compliance with the EU AI Act before market entry.

Enterprises (finance, healthcare, manufacturing, public sector) integrating third-party or in-house AI tools and needing an audit trail of risk assessments, policies, and incidents.

Regulated industries (banking, insurance, healthcare) where AI use is subject to sectoral oversight in addition to horizontal AI regulation.

Government and public sector bodies deploying AI in citizen-facing services who must adhere to transparency and human oversight requirements.

The platform is designed to be self-hosted, making it suitable for organizations with data sovereignty requirements who cannot use cloud-based SaaS governance tools.

## 2.2 Stakeholders

**Table 2: List Of Stakeholders**

| Stakeholder | Role in System |
|---|---|
| **Admin** | Full platform control. Creates organizations, manages users, configures email/integrations, manages billing/tiers. Has access to all data across the organization. |
| **AI Governance Officer / Editor** | Day-to-day governance work. Creates and manages projects, assigns frameworks, fills in compliance controls, manages risks, vendors, and policies. |
| **Reviewer** | Reviews implementation details and assessment answers submitted by editors. Can approve or request rework. |
| **Auditor** | Read-only access to all governance data. Generates reports, views evidence, and performs audit inspections. |

| Stakeholder | Role in System |
|---|---|
| **End Users / Employees** | Assigned tasks within the platform. May be required to complete AI literacy training registered in the system. |
| **Vendors / Third-Party Providers** | Not direct system users, but their information, risks, and compliance status are tracked in the Vendor Management module. |
| **Regulatory Bodies (External)** | Not direct users. Receive compliance reports, CE marking certificates, and AI Trust Center public information generated by the system. |
| **LLM Providers (OpenAI, Anthropic)** | External AI services consumed by the AI Advisor and LLM Evaluation features. |
| **IT / DevOps Team** | Responsible for deploying and maintaining the platform (Docker, Kubernetes, environment configuration). |
| **System (Automated Jobs)** | Background workers perform scheduled tasks: post-market monitoring checks, automation rule execution, email sending, Slack notifications. |

## 2.3 Affected Groups with social or economic impact

**Organizations (Compliance & Risk Management)**

- Economic: Reduced audit costs, faster compliance cycles, fewer regulatory penalties.
- Social: Improved organizational trust in AI adoption, more accountable deployment of AI systems.

**AI Developers & Engineers**

- Economic: Streamlined documentation and compliance tracking reduces time-to-market for AI products.
- Social: Greater awareness of ethical and regulatory dimensions of AI systems.

**End Users of AI Systems (Citizens, Customers)**

- Social: Better-governed AI systems reduce the risk of biased, harmful, or opaque AI decisions affecting individuals.

- Economic: Safer AI translates to fewer financial or reputational harms to end users.

**Regulatory Bodies**

- Social: Systematic compliance reporting makes regulatory oversight more effective and data-driven.
- Economic: Reduced enforcement burden when organizations self-regulate effectively.

**open standards community**

- Social: A freely available governance platform democratizes access to AI governance tools for organizations that cannot afford enterprise alternatives.

## 2.4 Dependencies/ External System

**Table 3: List Of Dependencies and External Systems**

| External System | Purpose | Interaction |
|---|---|---|
| **PostgreSQL** | Primary relational database | Stores all platform data; schema-per-tenant isolation |
| **Redis** | In-memory store | Job queues (BullMQ), pub/sub notifications, caching |
| **OpenAI API** | LLM provider | Powers the AI Advisor chatbot; used for compliance question auto-fill |
| **Anthropic API** | LLM provider (alternative) | Alternative backend for AI Advisor |
| **Slack API** | Notifications | Sends governance alerts, automation results, and incident notifications to Slack channels |
| **MLflow** | ML experiment tracking | Syncs model metadata and run information from MLflow into the Model Inventory |
| **GitHub API** | Repository access | AI Detection Module scans GitHub repositories for AI-generated code |

| External System | Purpose | Interaction |
|---|---|---|
| **AWS SES / Azure Email / Resend / SMTP** | Email delivery | Transactional emails: registration, password reset, task assignments, automation notifications |
| **Google OAuth2** | Authentication | Optional OAuth-based user login |
| **DeepEval (Python library)** | LLM evaluation | Powers the LLM Evals module via the EvalServer (FastAPI) |

## 2.5 Related Projects with feature comparision

### 2.5.1 Related Projects

**1. IBM OpenScale / Watson OpenScale** An enterprise AI monitoring platform by IBM. Provides fairness, explainability, and drift monitoring for AI models deployed on IBM or other cloud platforms. Primarily cloud-hosted and part of IBM's larger cloud ecosystem.

**2. Credo AI** A commercial AI governance platform offering risk assessments, policy management, and compliance reporting. Closed-source and SaaS-only with enterprise pricing.

**3. Holistic AI** A UK-based commercial AI governance platform covering risk auditing, vendor assessment, and regulatory compliance mapping. SaaS-based.

**4. ModelRisk (Vose Software)** A quantitative risk analysis tool that includes some AI risk modeling capabilities. Primarily financial risk-focused, not an AI governance platform.

**5. OSCAL (NIST)** An open standard (not a platform) for representing security/compliance controls in machine-readable formats. Used as a data format, not a governance application.

**6. OneTrust AI Governance** A commercial data privacy and AI governance platform extending OneTrust's existing privacy management product. Enterprise SaaS, highly integrated but expensive.

### 2.5.2 Feature Comparison

**Table 4: Feature Comparison Of Our Product With Other Competitors**

| Feature | Credo AI | IBM OpenScale | Holistic AI | OneTrust AI |
|---|---|---|---|---|
| **EU AI Act Support** | | | | |
| **ISO 42001 Support** | Partial | | Partial | |
| **ISO 27001 Support** | | | | |
| **NIST AI RMF Support** | | Partial | Partial | Partial |
| **AI Model Inventory** | | | | |
| **Risk Management** | | Partial | | |
| **Vendor Management** | Partial | | | |
| **Policy Manager** | | | Partial | |
| **LLM Evaluations / Arena** | | Partial | | |
| **AI Advisor (Chatbot)** | | | | |
| **AI Detection Module** | | | | |
| **Incident Management** | Partial | | | |
| **Evidence Hub** | | | Partial | |
| **AI Trust Center (Public)** | | | | Partial |
| **Multi-Tenancy** | | | | |
| **PDF/DOCX Reports** | | Partial | | |
| **Automations / Webhooks** | | | | Partial |
| **Slack Integration** | | | | Partial |
| **MLflow Integration** | | | | |

| Feature | Credo AI | IBM OpenScale | Holistic AI | OneTrust AI |
|---|---|---|---|---|
| **On-Premises Deployment** | | | | |

## 2.6 Context Diagram

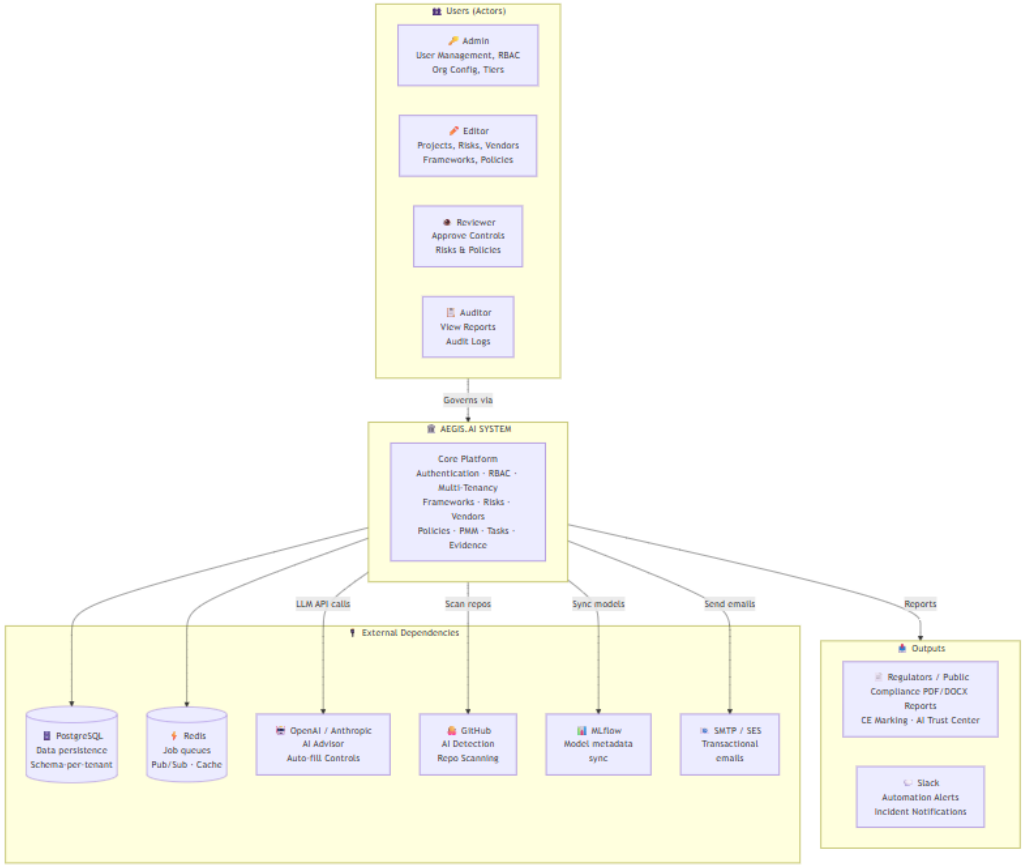



**Figure 1: Aegis.AI System Context Diagram**

## 2.7 Data Flow Diagram Level 0




**Figure 2: Aegis.AI DFD Level 0**

# 3. REQUIREMENTS ANALYSIS

## 3.1 List of Actors

**System Boundary**

The system boundary is the Aegis.AI Platform. Inside this boundary is the core functionality: User Management Multi-Tenancy Isolation Compliance Framework Tracking ( EU AI Act, ISO 42001 etc.), Risk & vendor management, LLM Evaluations, A.I. Advisor and Reporting. Outside this this interaction of external entities boundary include Regulatory Bodies, Third-Party APIs (Openai/ Anthropic, Github, Slack, MLflow), and Email Providers.

**List of Actors (Stakeholders & Users)**

The following actors interact with or are affected by the Aegis.AI platform and its associated user stories:

- **End User / Employee:** this person is a member of the organization that registers for account, logs into portal, personal preference (Dark/Light mode, notifications), changed passwords and completed assigned compliance training. (Associated User Stories: US-101, US-103, US-104)

- **Admin:** This is someone who has control over the entire platform of an organization. Multiple Licensed employees are those that can be managed under an organization's license. The admin assigns user roles, provides API token configurations, access organization-wide data dashboards, creates subscription tiers, and creates custom multi-step approval workflow templates. (Associated User Stories: US-102, US-105, US-202, US-203, US-303)

- **AI Governance Officer / Editor:** This is the person behind day-to-day governance. They create and take care of use cases (projects), fill in questionnaires for compliance frameworks (EU AI Act, ISO 42001, NIST AI RMF), manage AI policies, assess vendor risks, and submit projects for formal approval, (Associated User Stories: US-301, US-401, US-402, US-403)

- **Reviewer:**This person creates an internal compliance checkpoint. They review the implementation details and answers to assessment submitted by the Editor, and can either approve or reject the requests being pending. (Associated User Stories:US-302)

- **Risk Owner:** this person is accountable for creation, tracking and maintenance of a history of project-specific or model-specific risks within the organization. (Associated User Stories: US-501,US-502)

- **Auditor:** this person is internal or external to an entity who has read-only access to governance records for viewing evidence, inspecting audit logs and extracting compliance reports for regulatory purposes.

- **System (Automated Jobs):**This is a non-human actor that runs in the background to automatically compute levels of risk according to severity and likelihood, ensure schema-per-tenant data isolation, provide AI-driven auto-completion for compliance controls, and undertake scheduled monitoring tasks, (Associated User Stories: US-201, US-404, US-503)
- **LLM Provider (External System):** This external AI service (e.g. OpenAI, Anthropic) processes prompts from sent by the system to generate chat responses for the AI Advisor and performs LLM Evaluations.
- **Regulatory Body (External Stakeholder)**; These are external entities or government regulators, who receive the finalized PDF/DOCX complaints of compliance reports, CE Marking certificates and view public-facing AI Trust Center.

## 3.2 Product Backlog

The product backlog for Aegis.AI spans the end to end AI governance lifecycle, including of GRC (Governance, Risk, and Compliance) capabilities technical LLM evaluations, and automated scanning of the repositories.



**Figure 3: Product Backlog Hierarchy**

**EPIC 1: User Management & RBAC**

Purpose: Authenticate access and access control privileges to organization members.

| ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| US-101 | As a user, I can register and login to my organization's portal. | High | User can register with email/password; login returns a JWT; invalid credentials return 401. | 5 | Done |
| US-102 | As an admin, I can assign roles (Admin, Editor, | High | Admin can update any user's role; role change is reflected | 3 | Done |

| ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| | Reviewer, Auditor). | | immediately on next API request. | | |
| US-103 | As a user, I can reset my password via email. | High | User receives reset email within 60 s; clicking the link allows setting a new password; old password no longer works. | 3 | *(Planned)* |
| US-104 | As a user, I can set my theme and notification preferences. | Medium | User can toggle dark/light mode and notification settings; preferences persist across sessions. | 2 | Done |
| US-105 | As an admin, I can generate and manage API tokens for platform access. | Medium | Admin can create, view, and revoke API tokens; token can authenticate API calls. | 3 | Done |

**EPIC 2: Multi-Tenancy & Org Management**

Purpose: Data environments in isolation of various organizations.

| ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| US-201 | As a system, I must isolate data using schema-per-tenant architecture. | High | Two tenants sharing the same DB instance cannot read each other's data; verified via API calls with different JWT tokens. s. | 8 | Done |
| US-202 | As an admin, I can view organization- | High | Dashboard shows total use cases, risks, | 5 | Done |

| ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| | wide statistics on a dashboard. | | vendors, and compliance progress; data is tenant-scoped. | | |
| US-203 | As an admin, I can manage tiers and subscriptions. | Medium | Admin can view and update the organization's subscription tier; tier limits are enforced. | 3 | Done |

**EPIC 3: Approval Workflows**

**Goal:** Configurable sign-off processes for governance changes.

| ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| US-301 | As an editor, I can submit a use case or risk for approval. | High | An approval request is created and linked to the entity; approver receives real-time SSE notification. | 5 | Done |
| US-302 | As an approver, I can review, approve, or reject pending requests. | High | Approver can accept or reject; on approval entity status changes; submitter receives notification. | 5 | Done |
| US-303 | As an admin, I can create custom multi-step approval workflow templates. | High | Admin can create a workflow with 1–5 steps, each assigned to a role; template is available for use on use cases. | 8 | Done |

**EPIC 4: Framework Management**

**Goal:** Tracking compliance across major AI regulations and standards.

| ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| US-401 | As an editor, I can assess a use case against the EU AI Act. | High | Editor can fill in all 13 control category questionnaires; progress percentage updates in real-time. | 13 | Done |
| US-402 | As an editor, I can manage ISO 42001 (AIMS) and ISO 27001 (ISMS) clauses. | High | Editor can update each subclause through a 7-stage workflow; annex items can be marked N/A with justification. | 13 | Done |
| US-403 | As an editor, I can track NIST AI RMF functions and categories. | High | All 4 NIST functions (Govern/Map/Measure/Manage) with subcategories are trackable; progress charts display per function. | 8 | Done |
| US-404 | As a user, I can use "Auto Drivers" to auto-fill controls using AI. | Medium | User triggers AI auto-fill on a control; LLM generates a suggested response; user can accept or edit. | 5 | *(Planned)* |

**EPIC 5: Risk Management**

**Goal:** Comprehensive tracking of project, vendor, and model risks.

| ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| US-501 | As a risk owner, I can create and track project-specific risks. | High | Risk is created with name, owner, likelihood, severity; risk level is auto-calculated on save. | 5 | Done |
| US-502 | As a user, I can see the change history of a risk over time. | High | Every update to a risk is recorded; user can view full history with timestamps and changed fields. | 3 | Done |
| US-503 | As a system, I auto-calculate risk levels using (Likelihood × 1) + (Severity × 3). | High | Given Likelihood=4, Severity=4 → Score=16 → Risk Level="High"; formula verified in unit tests. | 3 | Done |

**EPIC 6: Vendor Management**

**Goal:** Managing third-party AI service providers and their associated risks.

| ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| US-601 | As a user, I can maintain a registry of AI vendors. | High | Vendor can be created, updated, and deleted; vendor list is displayed with search and filter. | 5 | Done |
| US-602 | As a risk officer, I can perform risk assessments on specific vendors. | High | Vendor risk can be created, linked to a vendor, and tracked with history; risk level is auto-calculated. | 5 | Done |

**EPIC 7: Policy Management**

**Goal:** Lifecycle management of internal AI policies and guidelines.

| ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| US-701 | As a policy owner, I can draft, review, and publish AI policies. | Medium | Policy goes through Draft → Under Review → Published states; each transition is logged in change history. | 8 | Done |
| US-702 | As a user, I can link policies to specific framework controls or risks. | Medium | Policy can be linked to one or more controls/risks; linked objects visible on policy detail page. objects visible on policy detail page. | 3 | Done |

**EPIC 8: AI Model Inventory**

Goal: All AI models utilized in the organization will be registered centrally.

| ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| US-801 | As a developer, I can register model metadata and version history. | Medium | Model entry created with name, version, type, owner; version history tracked; change history recorded. | 5 | Done |
| US-802 | As a user, I can sync model metadata directly from MLflow. | Medium | Given a configured MLflow URL, clicking "Sync" populates/updates model entries from MLflow registry. | 8 | *(Planned)* |

**EPIC 9: LLM Evaluations & Arena**

Aim: The technical assessment of performance and comparison of the LLDs.
This command needs: OpenAI / Anthropic / OpenRouter API key + EvalServer up and running.

| ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| US-901 | As a user, I can run DeepEval experiments to test LLM outputs. | Medium | User sets up an experiment, uploads. a dataset, selects metrics (Correctness/Faithfulness/Hallucination/Bias); results stored and viewable. | 13 | *(Planned)* |
| US-902 | As a user, I can perform head-to-head model comparisons in an "Arena". | Medium | User selects two LLMs and a both response returned, prompt; displayed side-by-side for comparison. | 8 | *(Planned)* |
| US-903 | As an admin, I can manage separate API keys for | Medium | Evaluation can be added/ deleted by Admin.<br>LLM API keys are independent of the. main advisor LLM keys. | 3 | Done |

| ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| | evaluation LLMs. | | | | |

**EPIC 10: AI Advisor (Assistant)**

Purpose: Artificial intelligence-based instructions on governance and compliance assignments.

requires: OpenAI / Anthropic API key is set in Settings / OpenRouter API key / OpenRouter in the OpenAI dropdown.

| ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| US-1001 | As a user, I can chat with an AI Advisor for governance help. | Medium | User sends a message; AI responds with governance-relevant advice; conversation history persists across sessions. | 8 | *(Planned)* |
| US-1002 | As a system, the Advisor can use "Tools" to query live platform data. | Medium | Advisor invokes a named tool (e.g., getRisksByProject) to fetch live data; tool result is incorporated into the response. | 13 | *(Planned)* |

**EPIC 11: Search & Navigation**

Purpose: Quick access to information throughout the platform.

| ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| US-1101 | As a user, I can use a global search to find any of the 14 entity types. | Medium | Searching a keyword returns results across use cases, risks, vendors, policies, etc.; results scoped to tenant. | 8 | Done |
| US-1102 | As a power user, I can use the Command Palette (Ctrl+K) for navigation. | Medium | Pressing Ctrl+K opens the command palette; typing a query shows matching pages and entities; selecting navigates to them. | 5 | Done |

**EPIC 12: Reporting & Dashboard**

**Goal:** Visualising and exporting governance posture.

| ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| US-1201 | As a user, I can generate PDF and DOCX compliance reports. | High | Clicking "Generate Report" on a use case produces a downloadable PDF and DOCX; report contains framework progress, risks, and controls. | 8 | Done |
| US-1202 | As a user, I can view an Entity Graph of relationships between objects. | Medium | Graph visualises connections between use cases, risks, vendors, models, and controls; nodes are clickable for detail. | 8 | Done |

**EPIC 13: Shared Collaboration Tools**

Aim: Inter-functional governance documentation tools.

| ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| US-1301 | As a user, I can upload and manage files in a central Evidence Hub. | High | Files can be uploaded, searched, filtered by entity, and downloaded; max 10 MB per file enforced. | 5 | Done |
| US-1302 | As a user, I can add notes and annotations to any platform entity. | Medium | Note can be created on any entity type; notes list is visible on the entity detail page. | 3 | Done |
| US-1303 | As a user, I can create shareable links for external reviewers. | Medium | Admin creates a share link with expiry; external user can access the linked view without logging in. | 5 | Done |
| US-1304 | As a user, I can view and manage CE Marking conformities. | Medium | CE Marking entries can be developed, monitored, and associated to use cases; registry view available. | 3 | Done |
| US-1305 | As a user, I can configure and view the AI Trust Center for transparency. | Medium | Admin can add resources and subprocessors; public Trust Center page isaccessible without login. | 5 | Done |
| US-1306 | As a user, I can create and manage governance tasks. | Medium | Task can be created with title, assignee, due date; overdue tasks | 3 | Done |

| ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| | | | display a warning indicator.. | | |
| US-1307 | As an auditor, I can view full audit trails and change history for all entities. | High | Change history is available for use cases, risks, vendors, policies, model inventory, and incidents; each record shows who changed what and when. | 5 | Done |

**EPIC 14: Automations & Notifications**

Goal: Event-based and real-time notifications.

| ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| US-1401 | As a user, I receive real-time notifications via SSE for approvals. | High | When an approval event fires, the notification appears in the header within < 100 ms without page refresh. | 8 | Done |
| US-1402 | As an admin, I can configure automation rules (e.g., Slack on High Risk). | High | Admin creates a rule with trigger (e.g., RISK_CREATED), condition (risk_level = Very High), action (SEND_SLACK); rule fires automatically when condition is met. | 13 | *(Planned)* |

EPIC 15: Registry of Incident Management and Training.

Purpose: AI failure and organisational literacy tracking.

| ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| US-1501 | As a user, I can log and track AI incidents and their resolutions. | Medium | Incident can be created with title, severity, description, and status; change history recorded on every update. | 5 | Done |
| US-1502 | As an admin, I can maintain a registry of AI literacy training sessions. | Medium | Training record can be created with title, date, attendees, and status; lifecycle transitions (Planned → Completed) tracked. | 3 | Done |

**EPIC 16: AI Detection Module**

Objective: Searching repositories through the AI content and bill of material. (access to GitHub repository / GitHub token required.)

| ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| US-1601 | As a developer, I can scan a GitHub repo for AI components. | Medium | User enters a GitHub repo URL; scan runs and returns a list of detected AI components with file paths and confidence scores. | 13 | *(Planned)* |
| US-1602 | As a user, I can export an AI BOM (Bill of | Medium | User clicks "Export AI-BOM" on a completed scan; a | 5 | *(Planned)* |

| ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| | Materials) from a scan. | | structured JSON/CSV file is downloaded listing all detected components | | |

**EPIC 17: Bias & Fairness Evaluation**

Purpose: Methodic analysis of AI model results in the aspects of demographic bias and fairness.
**Requires:** EvalServer running + LLM API key

| ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| US-1701 | As an ML engineer, I can run a bias & fairness evaluation on an LLM using structured test datasets. | Medium | User uploads a dataset with demographic labels; EvalServer runs fairness metrics; results show per-group score breakdown. | 13 | *(Planned)* |
| US-1702 | As a user, I can view per-group fairness scores and bias metrics in the LLM Evaluations dashboard. | Medium | Bias & Fairness tab in EvalsDashboard shows bar/radar charts of group-level scores for each metric. | 5 | *(Planned)* |
| US-1703 | As a user, I can store and retrieve historical bias evaluation | Medium | Past bias evaluation runs are stored in EvalServer DB; user can retrieve and re-view any historical result. | 3 | *(Planned)* |

| ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| | results for audit purposes. | | | | |

**EPIC 18: Post-Market Monitoring (PMM)**

Purpose: AI use cases deployed by EU countries should be reviewed automatically and periodically (EU AI Act Articles 9).

72).

| ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| US-1801 | As an admin, I can configure a PMM schedule (frequency, reminder days, escalation contact) per use case. | High | PMM config can be created/updated with frequency (e.g., 30 days), reminder threshold, and escalation user; config persists per use case. | 5 | Done |
| US-1802 | As an admin, I can define custom monitoring questions (in addition to system defaults). | High | Admin can add/edit/delete custom questions; they appear alongside system defaults in the questionnaire form. | 3 | Done |
| US-1803 | As a stakeholder, I receive an email when a new monitoring cycle is due and can fill in the questionnaire. | High | BullMQ cron fires hourly; stakeholder receives email with questionnaire link; MonitoringForm allows answers with autosave. | 8 | *(Planned)* |
| US-1804 | As an admin, I receive escalation | High | If cycle not submitted within escalation_days, | 5 | *(Planned)* |

| ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| | notifications if a cycle is overdue beyond the configured threshold. | | escalation email sent to escalation_contact; logged in system. | | |
| US-1805 | As an auditor, I can download PDF reports for all completed PMM cycles. | High | Completed cycle triggers PDF generation; PDF listed in Reports Archive with date and download link. | 8 | Done |

**EPIC 19: Policy Templates**

Goal: Ready-to-use library of governance policy templates to speed up the policy making process.

| ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| US-1901 | As a policy owner, I can browse and use pre-built AI governance policy templates. | Low | Policy Templates page has all the available templates with title and description; user can preview content. | 3 | Done |
| US-1902 | As a user, I can create a new policy pre-populated from a selected template. | Low | Clicking "Use Template" opens the Policy Manager with fields pre-filled from template content; user can edit before saving. | 3 | Done |

| ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| | | | . | | |

**EPIC 20: WatchTower / Event Tracker**

Purpose: Platform visibility of everything users do, and everything that occurs in a system, in real time.

administrators..

| ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| US-2001 | As an admin, I can view a live feed of all platform events (logins, changes, approvals). | Medium | WatchTower Events tab shows a paginated, filterable list of all governance events with timestamp, user, and action. | 5 | Done |
| US-2002 | As an admin, I can view and filter raw system logs for troubleshooting. | Medium | WatchTower Logs tab displays raw server log entries; filterable by severity level and date range. | 3 | Done |

**Backlog Summary**

| Metric | FYP 1 | FYP 2 | Total |
|---|---|---|---|
| Total EPICs | 17 | 5 | 20 |
| Total User Stories | 43 | 15 | 58 |
| Story Points | 230 | 114 | 344 |
| Done (Tested & Verified) | 43 | — | 43 |
| *(FYP 2 — pending external setup)* | — | 15 | 15 |

## 3.3 Figma UI/UX Designs

*https://www.figma.com/design/35gFjjYXV4dOuEBV08LCg6/Aegis.AI?node-id=0-1&t=MyaAyIlV7AQf0e6A-1*

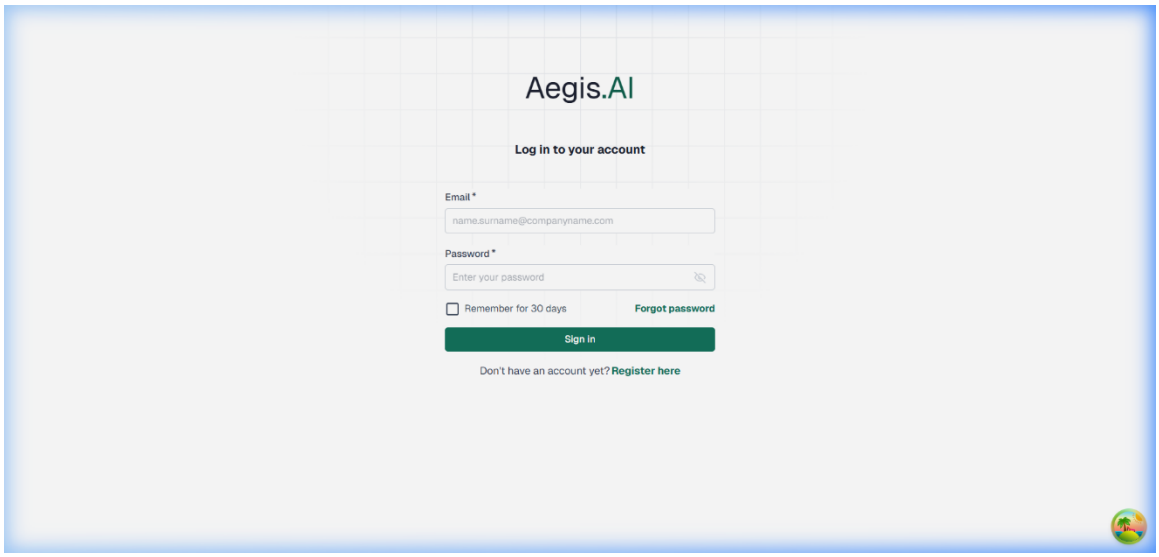



**Figure 4: Prototype -Login**

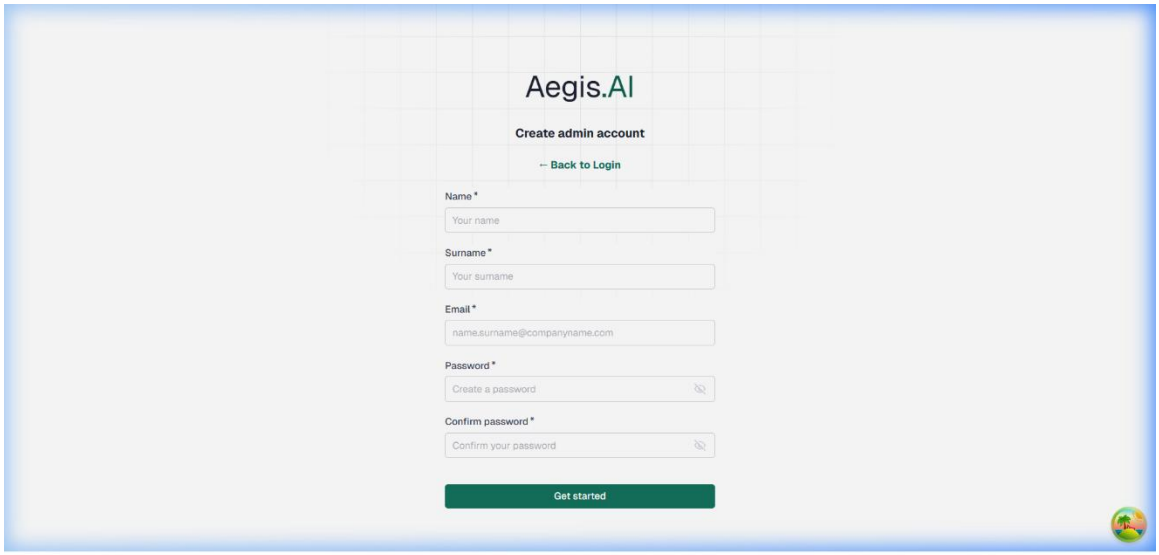



**Figure 5: Prototype - Register**

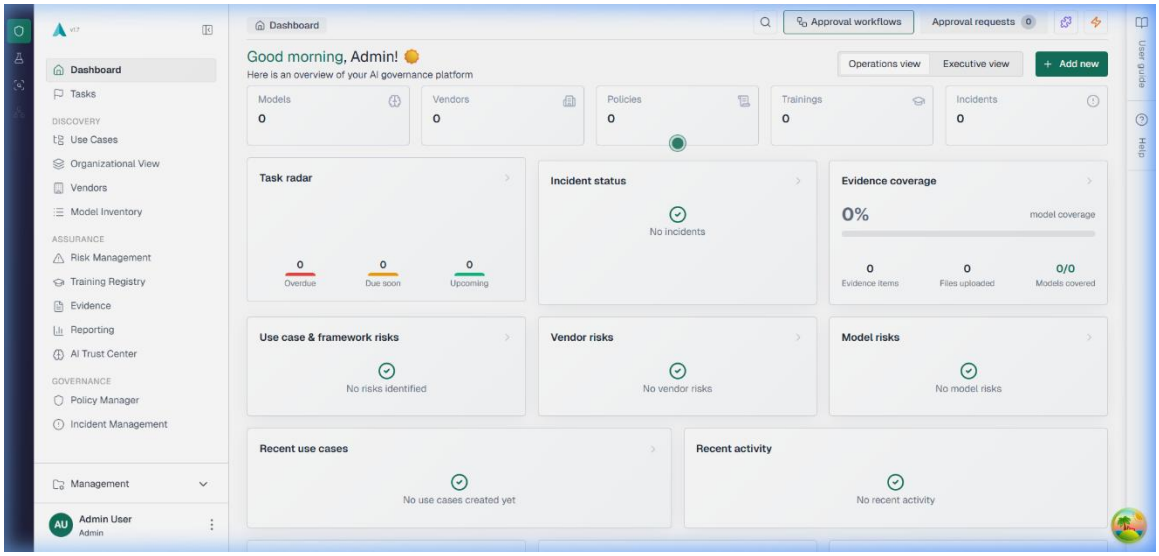



**Figure 6: Prototype-Dashboard**

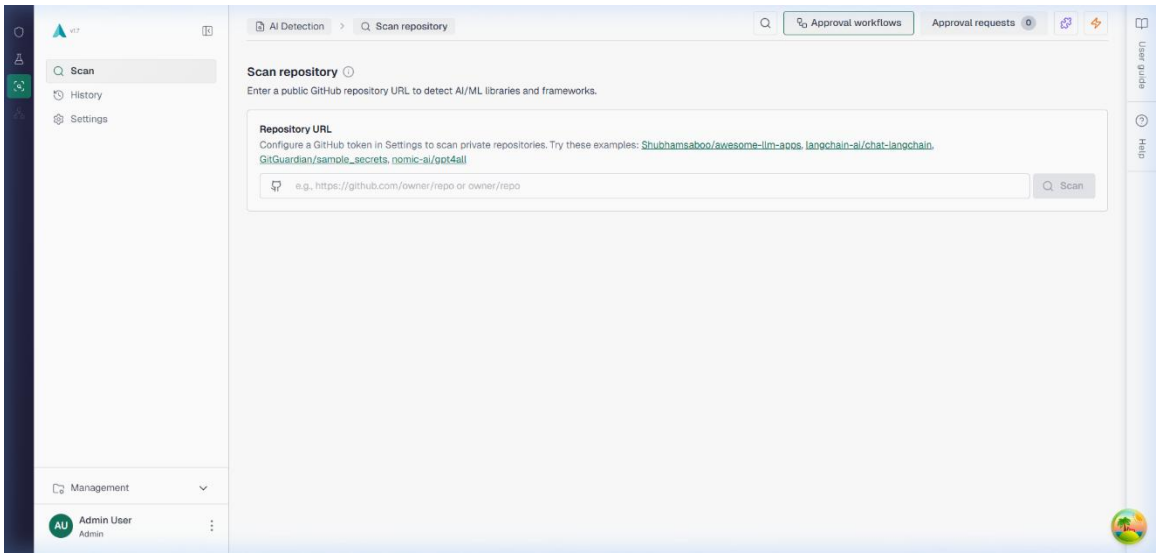



**Figure 7: Prototype-AI detection**

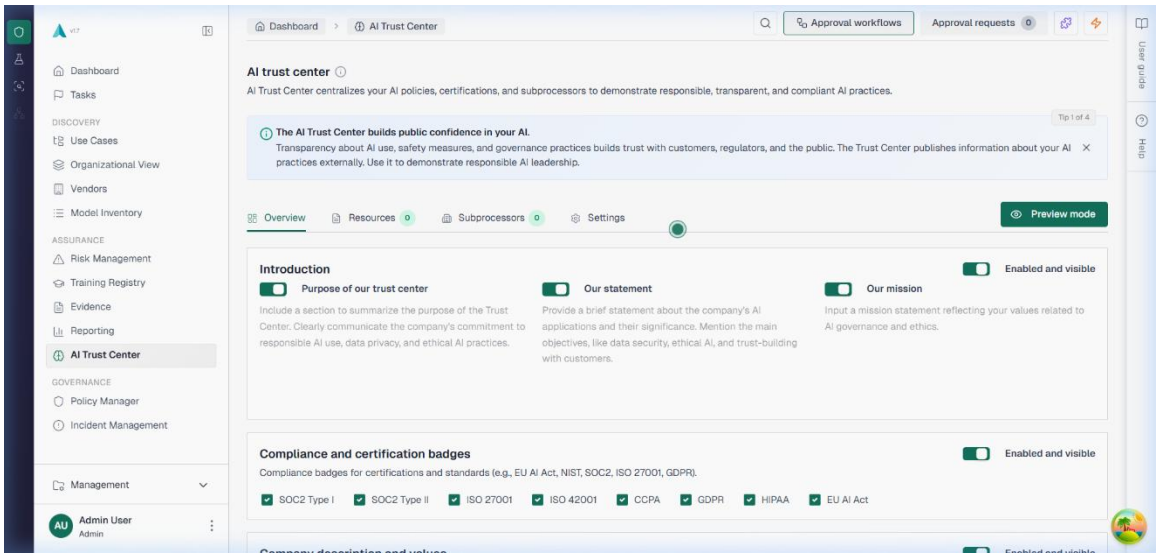



**Figure 8: Prototype-AI Trust Center**

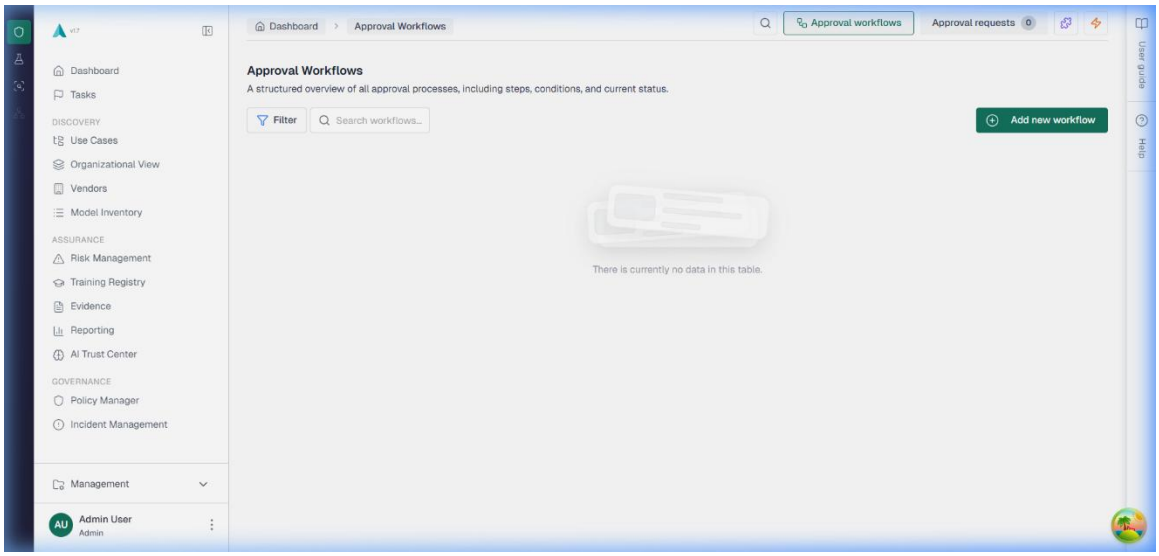



**Figure 9: Prototype- Approval Workflows**

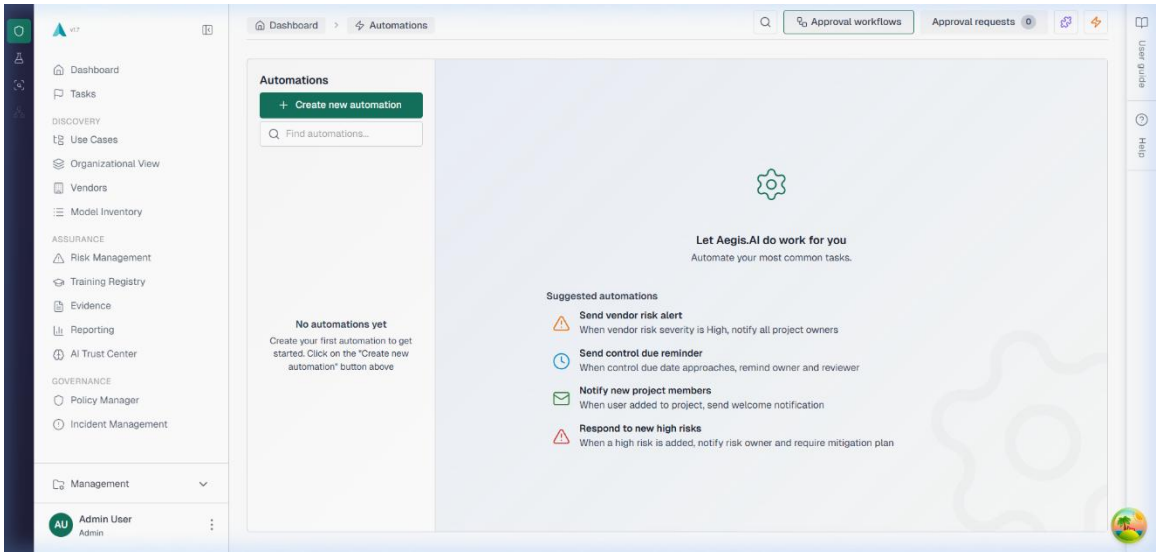



**Figure 10: Prototype-Automations**

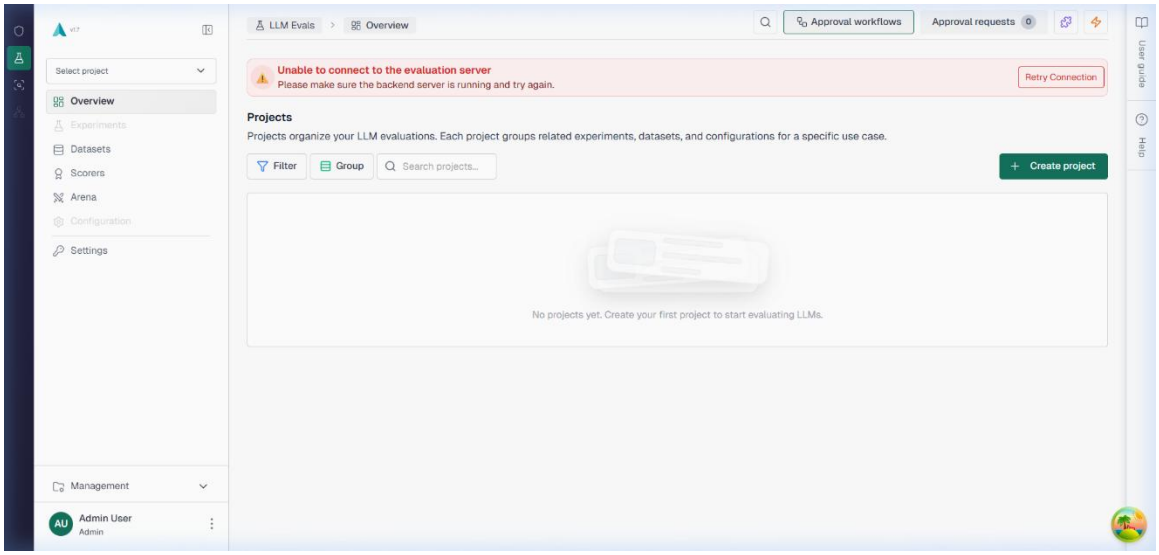



**Figure 11: Prototype-LLM Evaluations**

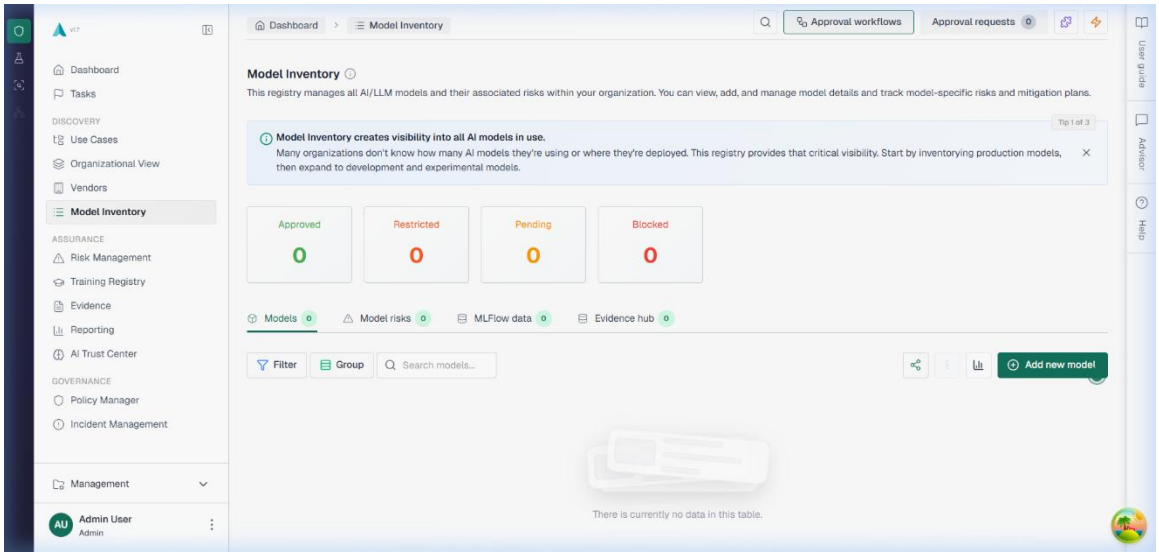



**Figure 12: Prototype-Model Inventory**

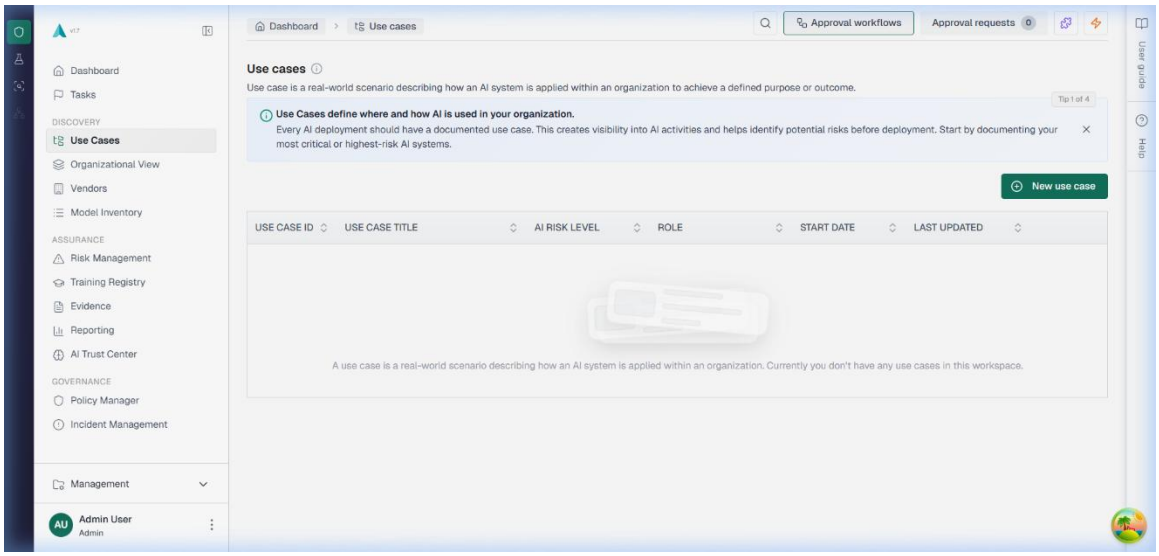



**Figure 13: Prototype-Overview**

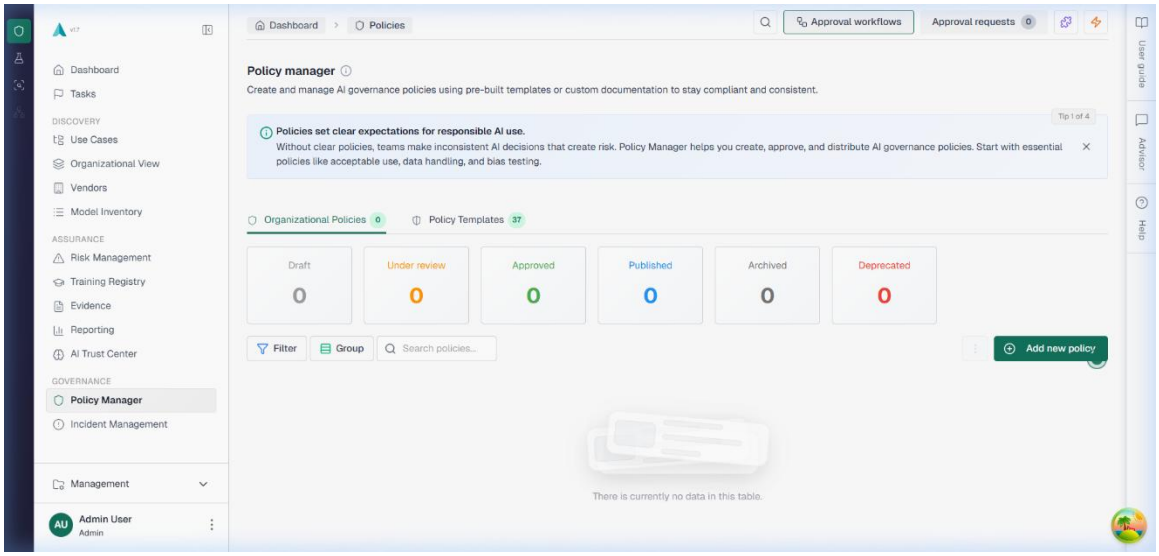



**Figure 14:Prototype-Policies**

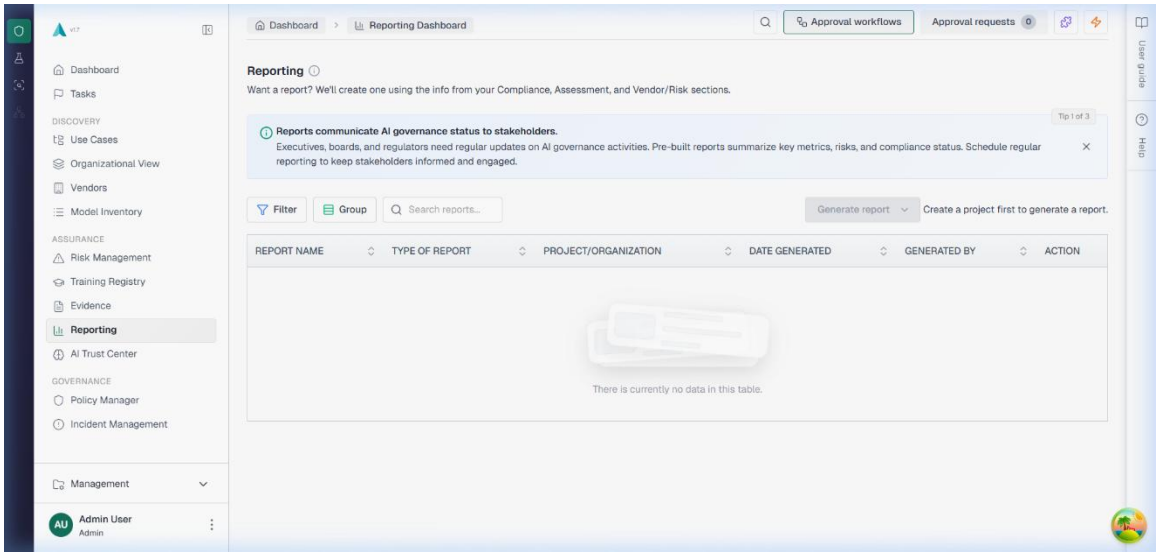



**Figure 15: Prototype-Reporting**

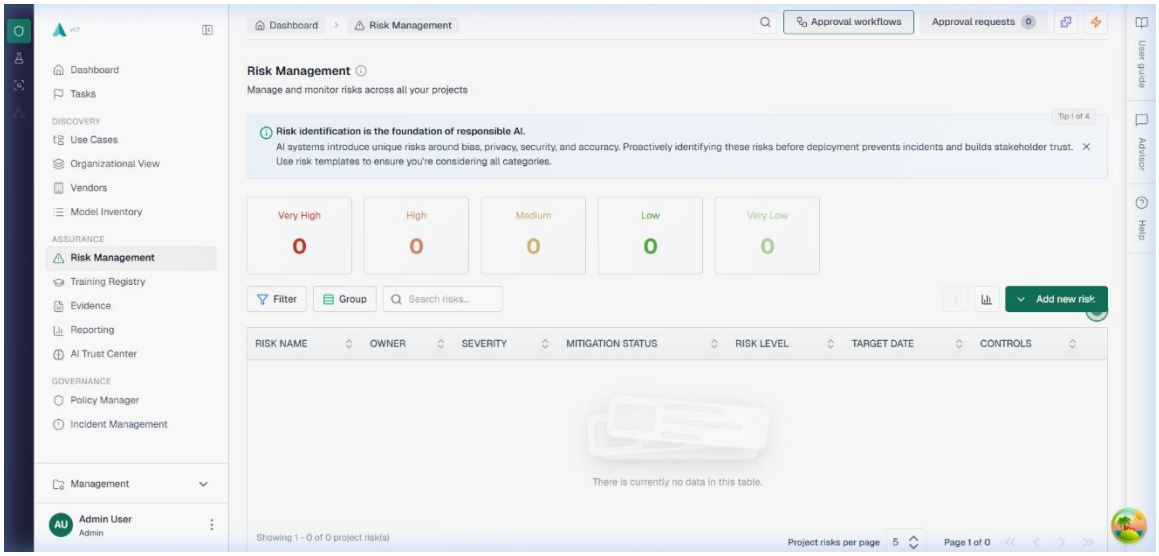



**Figure 16: Prototype-Risk Management**

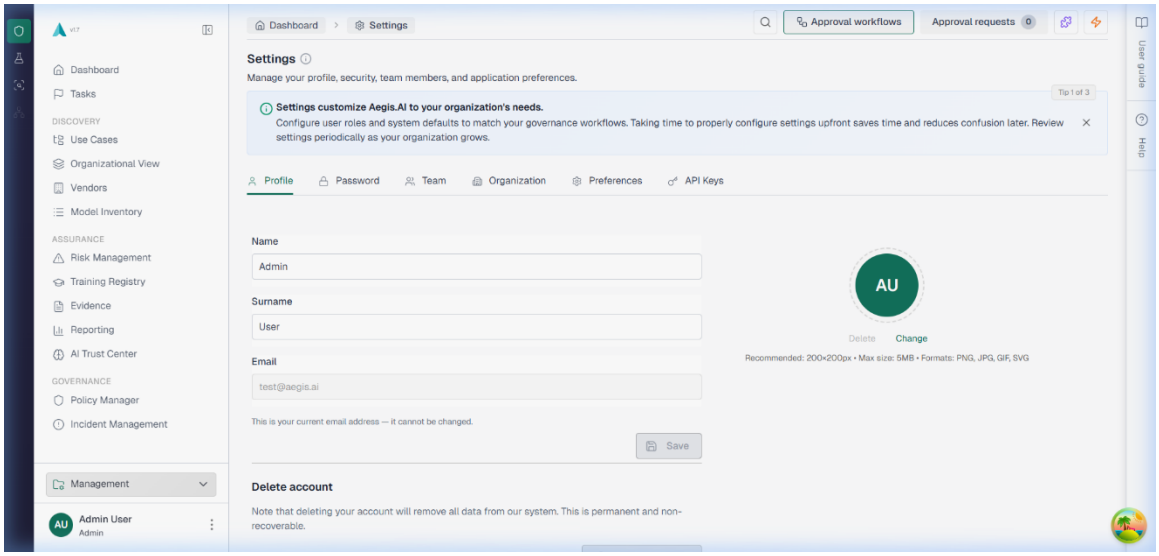



**Figure 17: Prototype-Settings**

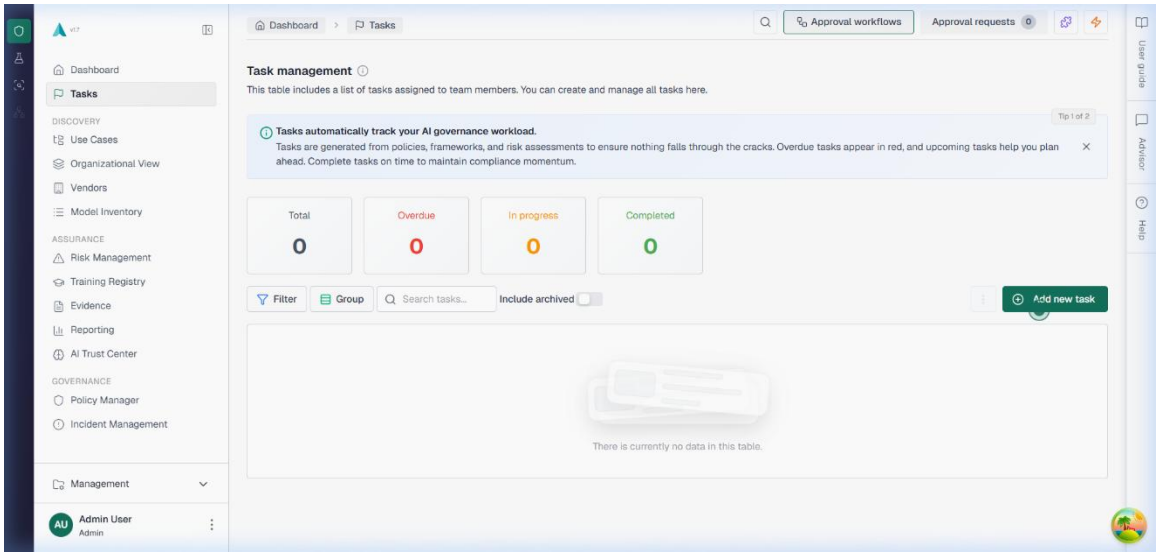



**Figure 18: Prototype-Tasks**

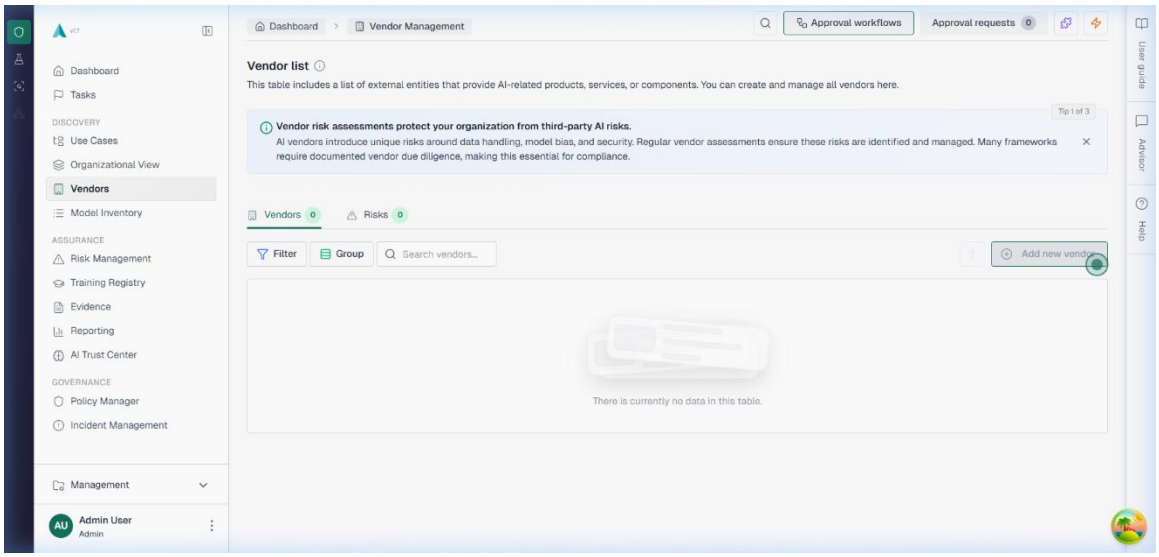



**Figure 19: Prototype-Vendors**

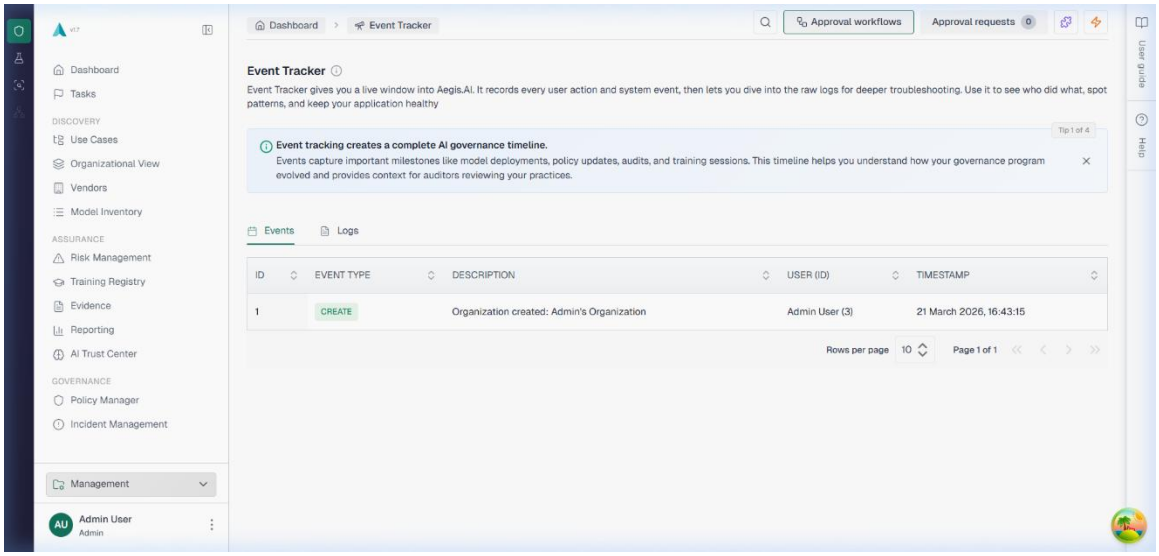



**Figure 20: Prototype -Watch Tower**

# 4. PROJECT PLANNING AND EXECUTION USING SPRINTS

## 4.1 Jira

Jira was used for task management, sprint planning, and tracking project progress throughout the development lifecycle.

*https://whoabdullahk.atlassian.net/jira/software/projects/AFS/boards/37/backlog?selectedIssue=AFS-21&atlOrigin=eyJpIjoiODk5NTA1YTFkYjdmNDViOWI2YjRlZjdiNmU4MTlmZWQiLCJwIjoiaiJ9*

## 4.2 Slack

Slack was used as the primary communication platform for team coordination, discussion, and sharing project updates throughout the development process.

*https://fyp-oqp5685.slack.com/archives/C0A77BLLVC0*

## 4.3 Github Repository

GitHub was used for version control and code management, enabling the team to collaboratively develop, track changes, and maintain the project codebase.

*https://github.com/muhammadharis356/aegis-develop*

## 4.4 Sprint 1: Foundation & Authentication

**Duration:** Weeks 1–2 (November 15 – November 28, 2025)
**Scrum Master:** Muhammad Haris
**Goal:** Bootstrap the project with core infrastructure, authentication, and user management.

**Sprint 1 Planning Meeting**

**Date:** November 15, 2025
**Attendees:** Muhammad Haris (Scrum Master), Ahmed Abdullah Khan, Farhana Minhas, Usama Ahmad (Product Owner)
**Location:** UMT Lab

**Table 4: Sprint 1 Selected User stories from Product Backlog**

| PB-ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| US-101 | As a user, I can register and login to my organization's portal. | High | Valid email/password accepted; JWT issued on login; | 8 | Done |

| PB-ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| | | | duplicate email rejected | | |
| US-102 | As an admin, I can assign roles (Admin, Editor, Reviewer, Auditor). | High | Role assignment works; route access enforces role permissions | 5 | Done |
| US-103 | As a user, I can reset my password via email. | Medium | Reset link sent via email; new password accepted | 5 | Deferred ” requires external services |
| US-203 | As an admin, I can manage tiers and subscriptions. | Medium | Tier CRUD API operational; subscriptions linked to org | 3 | Done |

**Table 5: Sprint 1 Team Capacity**

| Member | Days Available | Hours/Day | Total Hours |
|---|---|---|---|
| Muhammad Haris | 10 | 6 | 60 |
| Ahmed Abdullah Khan | 10 | 6 | 60 |
| Farhana Minhas | 10 | 5 | 50 |
| **Total** | | | **170 hrs** |

**Action Items Before Sprint Starts:**

- Confirm GitHub repository created and access granted to all members — *Muhammad Haris*
- Set up Docker Desktop on all development machines — *Ahmed Abdullah Khan*
- Create .env.example files for Clients, Servers, EvalServer — *Farhana Minhas*
- Review JWT authentication best practices — *All*

**Table 6: Sprint 1 Sprint backlog**

| SP-ID | Task Name | Related PB-ID | Assigned To | Status | Est. Hours | Actual Hours | Comments |
|---|---|---|---|---|---|---|---|
| SP1-01 | Initialize monorepo structure (Clients, Servers, EvalServer) | US-101 | Muhammad Haris | Done | 4 | 5 | Extra time configuring TypeScript paths |
| SP1-02 | Configure Docker Compose (PostgreSQL, Redis, Node.js, React) | US-101 | Ahmed Abdullah Khan | Done | 6 | 8 | Redis healthcheck required additional config |
| SP1-03 | Implement JWT-based authentication (register, login, logout) | US-101 | Muhammad Haris | Done | 10 | 12 | Added token refresh logic |
| SP1-04 | Implement RBAC middleware (Admin, Editor, Reviewer, Auditor) | US-102 | Ahmed Abdullah Khan | Done | 8 | 8 | Clean implementation |
| SP1-05 | Build login and registration | US-101 | Farhana Minhas | Done | 8 | 9 | Form validation added |

| SP-ID | Task Name | Related PB-ID | Assigned To | Status | Est. Hours | Actual Hours | Comments |
|---|---|---|---|---|---|---|---|
| | pages in React | | | | | | |
| SP1-06 | Set up password reset via email (scaffolding) | US-103 | Farhana Minhas | Done | 4 | 3 | Full email deferred ” requires external services |
| SP1-07 | Configure Sequelize ORM with PostgreSQL | US-101 | Muhammad Haris | Done | 5 | 5 | Migrations working cleanly |
| SP1-08 | Set up database migration system | US-101 | Muhammad Haris | Done | 4 | 4 | |
| SP1-09 | Tiers and subscriptions API | US-203 | Ahmed Abdullah Khan | Done | 5 | 5 | |

## Class Diagram:

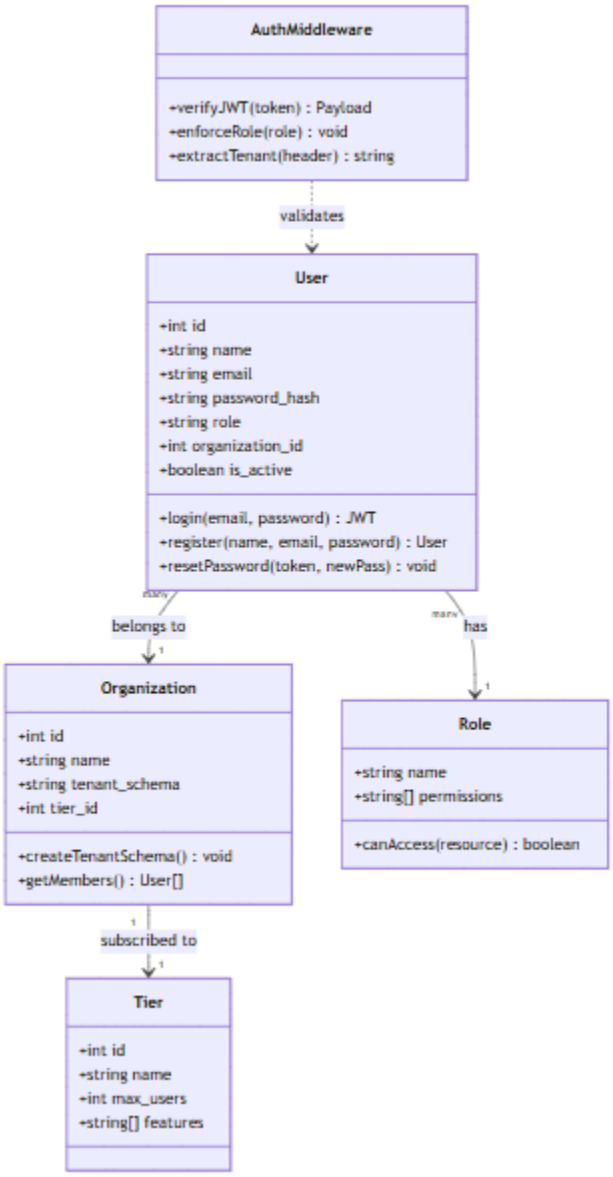



**Figure 21: Sprint 1 Class Diagram**

**Sequence Diagram:**

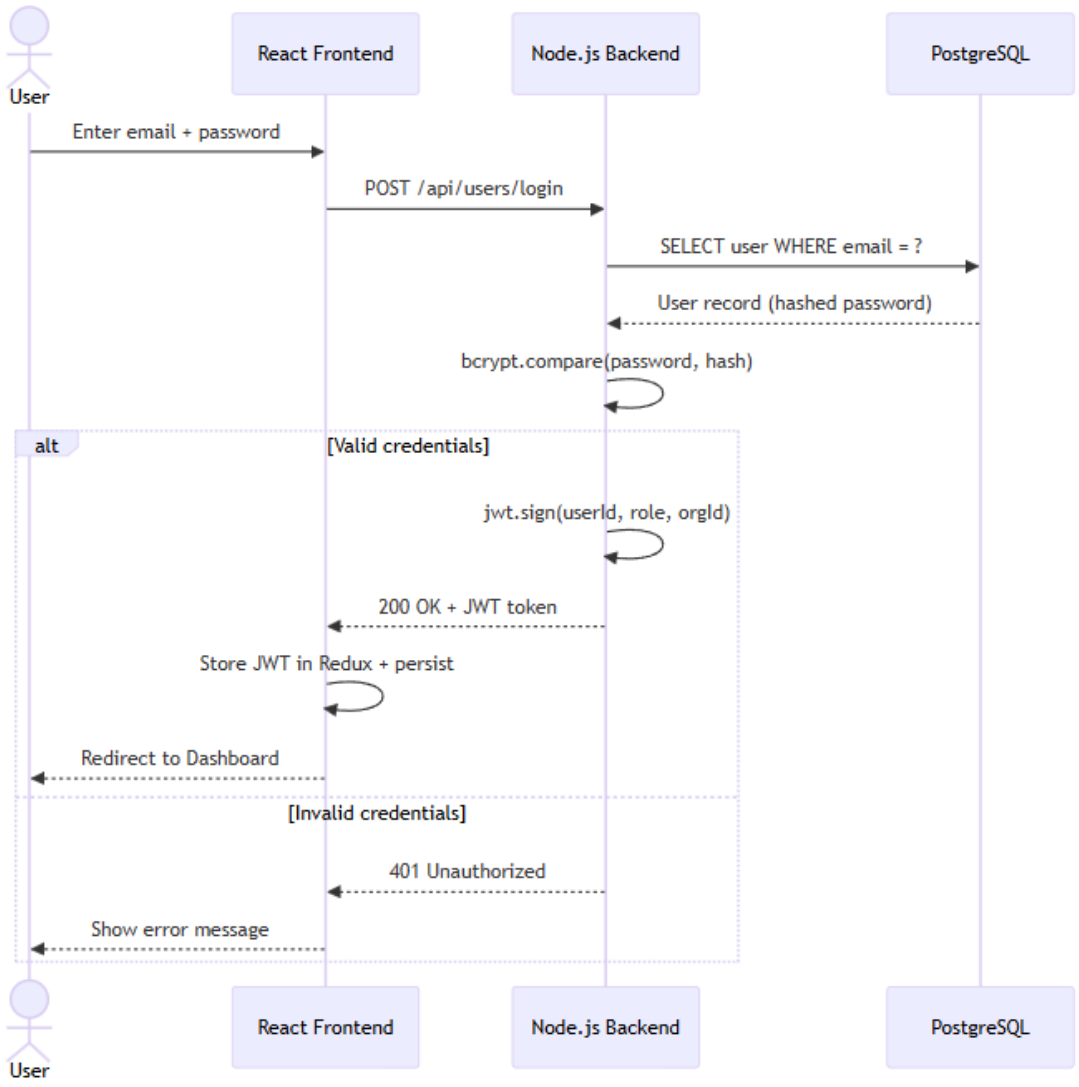



**Figure 22: Sprint 1 Sequence Diagram**

## Decision Table:

**Table 7: Sprint 1 Decision Table: Role-Based Access Control**

| User Role | View Projects | Create Projects | Approve Requests | Manage Users | Access Admin Panel |
|---|---|---|---|---|---|
| Admin | Yes | Yes | Yes | Yes | Yes |

| User Role | View Projects | Create Projects | Approve Requests | Manage Users | Access Admin Panel |
|---|---|---|---|---|---|
| Editor | Yes | Yes | No | No | No |
| Reviewer | Yes | No | Yes | No | No |
| Auditor | Yes | No | No | No | No |
| No Role / Unauthenticated | No | No | No | No | No |

**Figure 23: Sprint 1 Decision Table**

**Sprint 1 Extended Test Cases:**

**Test Designer:** Muhammad Haris
**Executor:** Ahmed Abdullah Khan
**Date:** November 28, 2025

**Table 8: Sprint 1 Extended Test Cases**

| TID | Test Case Description | Test Data | Expected Result | Actual Result | Status |
|---|---|---|---|---|---|
| TC1-01 | User registers with valid email and password | email: test@example.com, password: Test@1234 | Account created; welcome email queued; 201 response | Account created successfully | Pass |
| TC1-02 | User registers with duplicate email | email: existing@example.com | 400 error: Email already in use | Correct error returned | Pass |
| TC1-03 | User registers | password: 123 | 400 error: Password too weak | Validation error shown | Pass |

| TID | Test Case Description | Test Data | Expected Result | Actual Result | Status |
|---|---|---|---|---|---|
| | with weak password | | | | |
| TC1-04 | Valid user login | email: test@example.com, password: Test@1234 | 200 OK + JWT token returned | JWT issued correctly | Pass |
| TC1-05 | Login with wrong password | email: test@example.com, password: wrongpass | 401 Unauthorized | Correct 401 returned | Pass |
| TC1-06 | Access protected route without JWT | GET /api/projects (no Authorization header) | 401 Unauthorized | 401 returned | Pass |
| TC1-07 | Admin accesses admin-only route | Role: Admin, GET /api/roles | 200 OK | Access granted | Pass |
| TC1-08 | Editor accesses admin-only route | Role: Editor, GET /api/roles | 403 Forbidden | 403 returned | Pass |
| TC1-09 | JWT expiry enforcement | Expired JWT token used | 401 Unauthorized: Token expired | Correct rejection | Pass |
| TC1-10 | Tier management CRUD | POST /api/tiers with valid data | Tier created; linked to org | Tier API working | Pass |

**Sprint 1 Review Meeting:**

**Date:** November 28, 2025
**Attendees:** Full Scrum team + Product Owner

**Sprint 1 Metrics Overview:**

| Metric | Value |
|---|---|
| Committed Story Points | 21 |
| Completed Story Points | 18 |
| Carryover Items | US-103 (full email deferred ” requires external services) |
| Bugs Reported | 0 |
| Bugs Resolved | 0 |

**Demo Highlights:**

- Demonstrated registration flow, login with JWT, RBAC enforcement
- Showed Docker Compose one-command startup

**Table 9: Sprint 1 Review Status of Sprint Backlog**

| SP-ID | Task | Status | Notes |
|---|---|---|---|
| SP1-01 | Initialize monorepo | Done | All three services initialized |
| SP1-02 | Docker Compose | Done | Full environment working |
| SP1-03 | JWT Authentication | Done | Register, login, logout |
| SP1-04 | RBAC Middleware | Done | All four roles working |
| SP1-05 | Login/Register UI | Done | Forms with validation |
| SP1-06 | Password Reset scaffolding | Done | Full email deferred |
| SP1-07 | Sequelize ORM | Done | Migrations clean |

| SP-ID | Task | Status | Notes |
|---|---|---|---|
| SP1-08 | Migration system | Done | |
| SP1-09 | Tiers API | Done | |

**Feedback from Stakeholders:**

| Feedback Source | Comments |
|---|---|
| Product Owner (Usama Ahmad) | Authentication solid; requested RBAC be demonstrated with actual routes in Sprint 2 |
| Team | Requested standardized error response format — adopted going forward |

**Sprint 1 Retrospective Meeting:**

**Date:** November 28, 2025

**What went well:**

- Environment setup completed within sprint timeframe
- RBAC implementation clean and extensible

**What could be improved:**

- Docker setup took longer than expected — pre-configure base images
- Password reset email deferred — need external SMTP in FYP 2

**Action items for Sprint 2:**

- Pre-configure Docker base images — *Ahmed Abdullah Khan*
- Standardize API error response format — *Muhammad Haris*

**Team Health Check:**

| Area | Rating (1-5) | Comments |
|---|---|---|
| Team Morale | 5 | Excited about project start |
| Communication | 4 | Daily standups well attended |
| Tools & Resources | 3 | Docker setup issues slowed start; resolved by end |

## 4.5 Sprint 2: Multi-Tenancy, Approvals & Use Case Management

**Duration:** Weeks 3–4 (November 29 – December 12, 2025)
**Scrum Master:** Ahmed Abdullah Khan
**Goal:** Implement schema-per-tenant isolation, approval workflows, and Use Case CRUD.

**Sprint 2 Planning Meeting:**

**Date:** November 29, 2025
**Attendees:** Ahmed Abdullah Khan (Scrum Master), Muhammad Haris, Farhana Minhas, Usama Ahmad (Product Owner)

**Table 10: Sprint 2 Selected User stories From Product backlog**

| PB-ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| US-201 | As a system, I must isolate data using schema-per-tenant. | Critical | Two orgs cannot access each other's data | 13 | Done |
| US-301 | As an editor, I can submit a use case or risk for approval. | High | Approval request created; entity status changes | 5 | Done |
| US-302 | As an approver, I can review, approve, or reject requests. | High | Step transitions work; entity status updates | 5 | Done |
| US-303 | As an admin, I can create custom multi-step approval workflows. | High | Workflow template with multiple steps; assignable | 8 | Done |
| US-1401 | As a user, I receive real-time notifications via SSE for approvals. | High | SSE stream connected; notification shows in UI | 8 | Done |

**Table 11: Sprint 2 Team Capacity**

| Member | Days Available | Hours/Day | Total Hours |
|---|---|---|---|
| Muhammad Haris | 10 | 6 | 60 |

| Member | Days Available | Hours/Day | Total Hours |
|---|---|---|---|
| Ahmed Abdullah Khan | 10 | 6 | 60 |
| Farhana Minhas | 10 | 5 | 50 |
| **Total** | | | **170 hrs** |

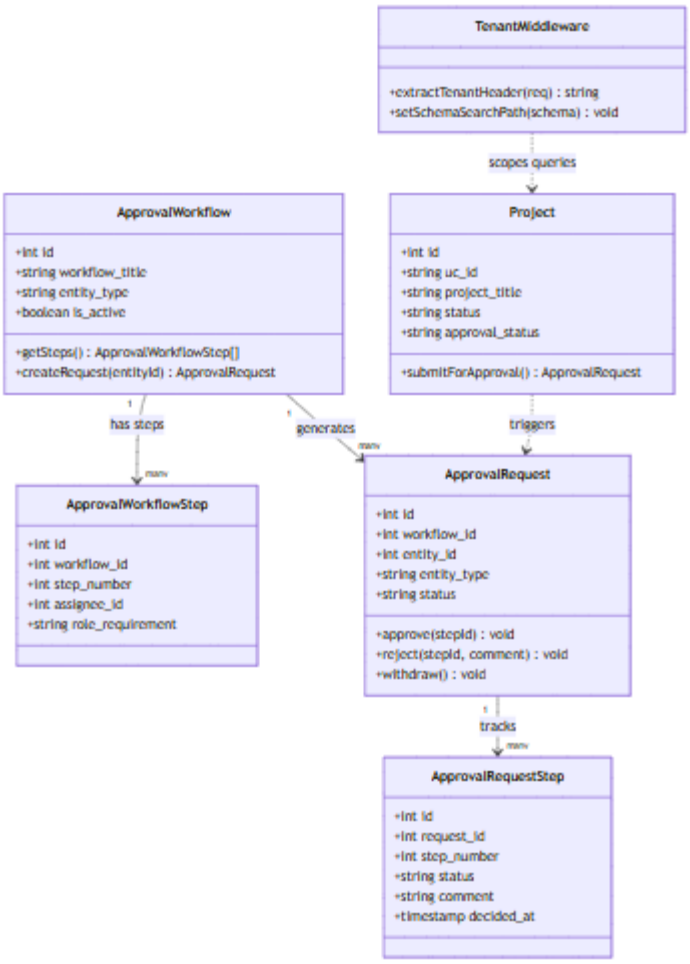
**Action Items Before Sprint Starts:**

- Pre-configure Docker base images to reduce setup overhead — *Ahmed Abdullah Khan*
- Standardize API error response format (from Sprint 1 retro) — *Muhammad Haris*
- Research Sequelize schema-scoped queries approach — *Muhammad Haris*
- Design approval workflow data model — *Ahmed Abdullah Khan*

**Table 12: Sprint 2 Sprint Backlog**

| SP-ID | Task Name | Related PB-ID | Assigned To | Status | Est. Hours | Actual Hours | Comments |
|---|---|---|---|---|---|---|---|
| SP2-01 | Implement tenant schema creation on org registration | US-201 | Muhammad Haris | Done | 12 | 15 | Complex schema scoping logic |
| SP2-02 | Build tenant identification middleware | US-201 | Muhammad Haris | Done | 6 | 6 | Header-based routing |
| SP2-03 | Create Organization model and management endpoints | US-201 | Ahmed Abdullah Khan | Done | 8 | 8 | |
| SP2-04 | Build Use Case CRUD API with UC-ID auto-generation | US-301 | Ahmed Abdullah Khan | Done | 8 | 9 | UC-ID counter logic |

| SP-ID | Task Name | Related PB-ID | Assigned To | Status | Est. Hours | Actual Hours | Comments |
|---|---|---|---|---|---|---|---|
| SP2-05 | Build Use Case dashboard UI component | US-301 | Farhana Minhas | Done | 8 | 8 | |
| SP2-06 | Implement user invitation flow | US-201 | Farhana Minhas | Done | 6 | 7 | |
| SP2-07 | Build multi-step Approval Workflow template management | US-303 | Ahmed Abdullah Khan | Done | 10 | 12 | Multi-step engine |
| SP2-08 | Build Approval Request lifecycle (approve/reject/withdraw) | US-302 | Muhammad Haris | Done | 8 | 9 | |
| SP2-09 | Implement real-time SSE notifications with Redis Pub/Sub | US-1401 | Ahmed Abdullah Khan | Done | 10 | 14 | Redis pub/sub debugging took extra time |




**Class Diagram:**

**Figure 24: Class Diagram**

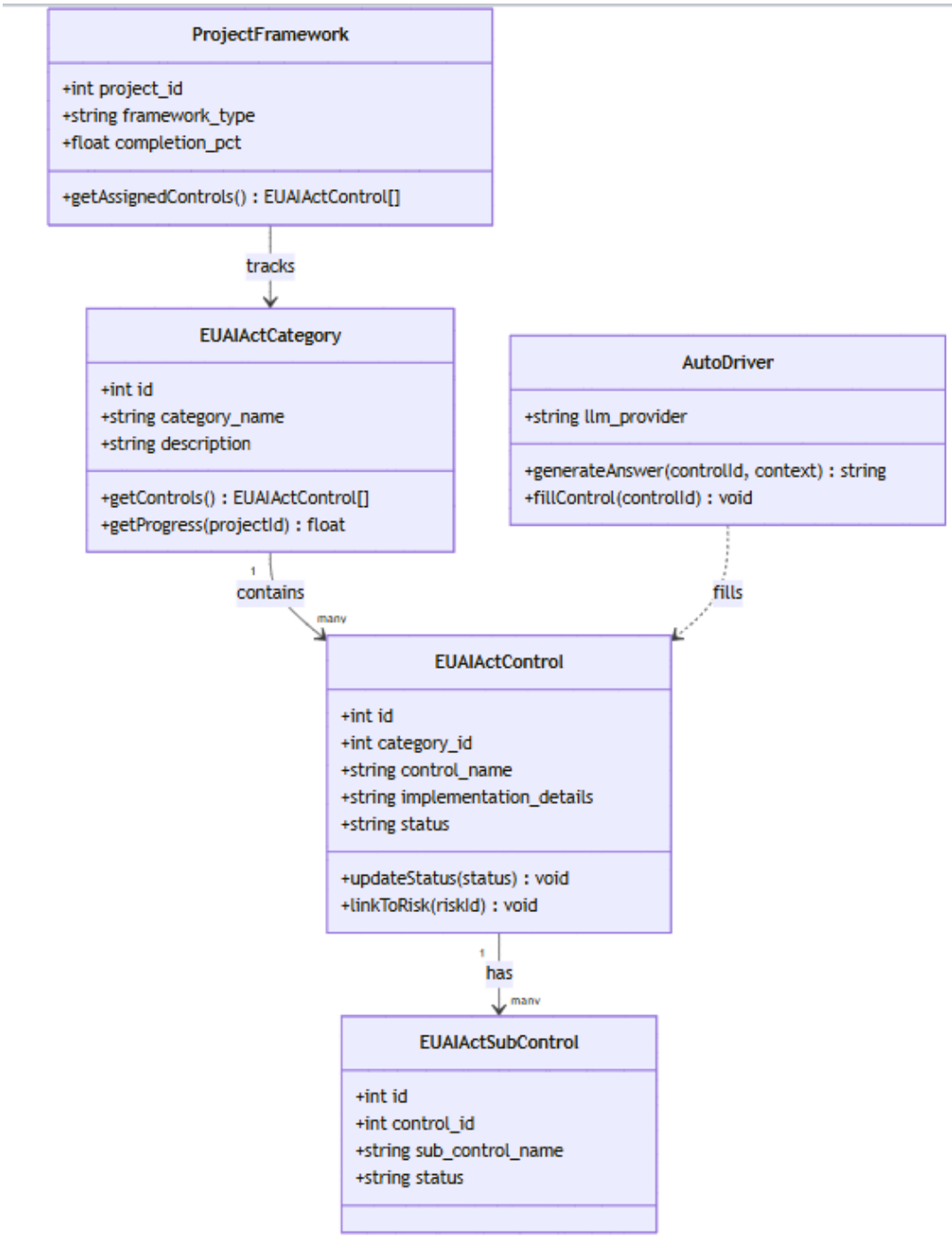



**Figure 25: Sprint 2 Class Diagram**

**Sequence Diagram:**

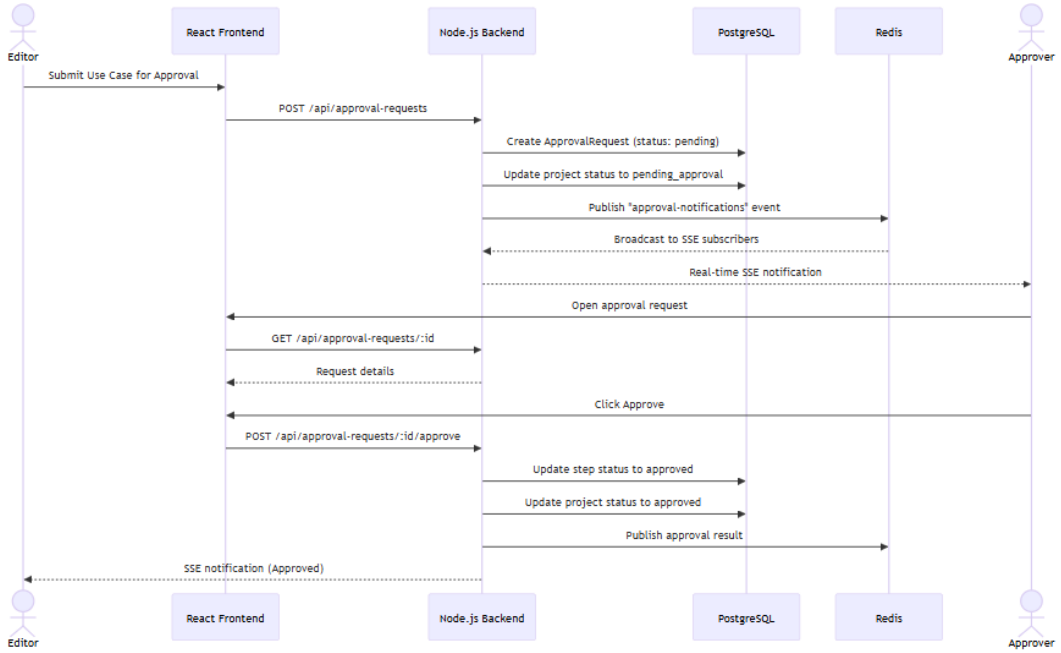



**Figure 26: Sprint 2 Sequence Diagram**

## Decision Table:

**Table 13: Sprint 2 Decision Table: Approval Request State Transitions**

| Current Status | Action | Actor | New Status |
|---|---|---|---|
| pending | approve (all steps) | Assigned Approver | approved |
| pending | approve (partial steps) | Assigned Approver | pending (next step active) |
| pending | reject | Assigned Approver | rejected |
| pending | withdraw | Editor (submitter) | withdrawn |
| approved | N/A | — | approved (final) |
| rejected | resubmit | Editor | pending |

**Sprint 2 Extended Test Cases:**

**Test Designer:** Ahmed Abdullah Khan
**Executor:** Muhammad Haris
**Date:** December 12, 2025

**Table 14: sprint 2 Extended Test Cases**

| TID | Test Case Description | Test Data | Expected Result | Actual Result | Status |
|---|---|---|---|---|---|
| TC2-01 | Two tenants cannot access each other's data | Org A reads Org B's project via API | 403 or empty result | No cross-tenant data leakage | Pass |
| TC2-02 | Use Case created with auto-generated UC-ID | POST /api/projects | UC-1, UC-2... assigned sequentially | UC-ID auto-generated correctly | Pass |
| TC2-03 | Approval workflow template with 2 steps created | POST /api/approval-workflows, steps: 2 | Workflow stored with both steps | Workflow created | Pass |
| TC2-04 | Editor submits use case for approval | POST /api/approval-requests | ApprovalRequest created; project status = pending | Request created; status updated | Pass |
| TC2-05 | Approver receives SSE notification | Approval request created | SSE event delivered to approver's open stream | SSE delivered within 100ms | Pass |
| TC2-06 | Step 1 approved in 2-step workflow | Approve step 1 | Step 1 = approved; Step 2 = pending; | Correct step progression | Pass |

| TID | Test Case Description | Test Data | Expected Result | Actual Result | Status |
|---|---|---|---|---|---|
| | | | request still pending | | |
| TC2-07 | All steps approved | Approve steps 1 and 2 | ApprovalRequest status = approved; project = approved | Final approval correct | Pass |
| TC2-08 | Editor withdraws approval request | POST .../withdraw | Request = withdrawn; project status reverted | Withdrawal works | Pass |
| TC2-09 | Approver rejects with comment | POST .../reject with comment | Request = rejected; comment stored | Rejection with comment works | Pass |
| TC2-10 | Tenant schema isolation verified in DB | Query pg_tables for tenant schema | Separate schema exists for each org | Schema isolation confirmed | Pass |

**Sprint 2 Review Meeting:**

**Date:** December 12, 2025

**Sprint 2 Metrics Overview:**

| Metric | Value |
|---|---|
| Committed Story Points | 39 |
| Completed Story Points | 39 |
| Carryover Items | None |
| Bugs Reported | 1 (SSE reconnect on token expiry) |
| Bugs Resolved | 1 |

**Table 15: Sprint 2 Review Status of Sprint backlog**

| SP-ID | Task | Status | Notes |
|---|---|---|---|
| SP2-01 | Tenant schema creation | Done | Schema isolation working |
| SP2-02 | Tenant middleware | Done | Header-based routing working |
| SP2-03 | Organization management | Done | |
| SP2-04 | Use Case CRUD + UC-ID | Done | Auto-generation working |
| SP2-05 | Use Case UI | Done | |
| SP2-06 | User invitation flow | Done | |
| SP2-07 | Approval Workflow engine | Done | Multi-step working |
| SP2-08 | Approval Request lifecycle | Done | Approve/reject/withdraw |
| SP2-09 | SSE Notifications | Done | Redis Pub/Sub working |

**Feedback from Stakeholders:**

| Feedback Source | Comments |
|---|---|
| Product Owner (Usama Ahmad) | Multi-tenancy fully verified; approval workflow exceeds expectations |
| Team | SSE reconnect on JWT expiry should be handled in the frontend |

**Sprint 2 Retrospective Meeting:**

**Date:** December 12, 2025

**What went well:** Tenant isolation implemented correctly on first attempt. Reusable middleware pattern established.

**What could be improved:** SSE implementation took more debugging time than expected.

**Action items for Sprint 3:** Create reusable data seeder utility for framework structures — *Muhammad Haris*

**Team Health Check:**

| Area | Rating (1-5) | Comments |
|---|---|---|
| Team Morale | 5 | Proud of multi-tenancy achievement |
| Communication | 5 | Excellent coordination on complex feature |
| Tools & Resources | 4 | Redis debugging took time but team learned |

## 4.6 Sprint 3: EU AI Act Compliance Framework

**Duration:** Weeks 5–6 (December 13 – December 26, 2025)
**Scrum Master:** Farhana Minhas
**Goal:** Full EU AI Act control tracking (13 categories, controls, subcontrols, assessment topics).

**Sprint 3 Planning Meeting:**

**Date:** December 13, 2025
**Attendees:** Farhana Minhas (Scrum Master), Muhammad Haris, Ahmed Abdullah Khan, Usama Ahmad (Product Owner)

**Table 16: Sprint 3 Selected User Stories From Product Backlog**

| PB-ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| US-401 | As an editor, I can assess a use case against the EU AI Act. | Critical | 13 categories seeded; controls with status transitions working | 13 | Done |
| US-404 | As a user, I can use Auto Drivers to auto-fill controls using AI. | High | AI auto-fill generates control answers via LLM | 8 | Done |

**Table 17: Sprint 3 Team Capacity**

| Member | Days Available | Hours/Day | Total Hours |
|---|---|---|---|
| Muhammad Haris | 10 | 6 | 60 |
| Ahmed Abdullah Khan | 10 | 6 | 60 |
| Farhana Minhas | 10 | 5 | 50 |
| **Total** | | | **170 hrs** |

**Action Items Before Sprint Starts:**

- Create reusable seeder utility for hierarchical data (from Sprint 2 retro) — *Muhammad Haris*
- Research EU AI Act Article structure and categorization — *Farhana Minhas*
- Design control-to-risk junction table schema — *Ahmed Abdullah Khan*

**Table 18: Sprint 3 Sprint Backlog**

| SP-ID | Task Name | Related PB-ID | Assigned To | Status | Est. Hours | Actual Hours | Comments |
|---|---|---|---|---|---|---|---|
| SP3-01 | Seed EU AI Act structure (categories, controls, subcontrols) | US-401 | Muhammad Haris | Done | 12 | 16 | More categories than estimated |
| SP3-02 | Build control implementation editor UI | US-401 | Farhana Minhas | Done | 10 | 10 | |

| SP-ID | Task Name | Related PB-ID | Assigned To | Status | Est. Hours | Actual Hours | Comments |
|---|---|---|---|---|---|---|---|
| SP3-03 | Implement control status transitions (Waiting/In Progress/Done) | US-401 | Ahmed Abdullah Khan | Done | 6 | 6 | |
| SP3-04 | Build EU AI Act assessment questionnaire UI | US-401 | Farhana Minhas | Done | 8 | 8 | |
| SP3-05 | Implement control-to-risk linking | US-401 | Ahmed Abdullah Khan | Done | 6 | 7 | Junction table per framework |
| SP3-06 | Build framework progress cards | US-401 | Farhana Minhas | Done | 5 | 5 | Completion % and assignment % |
| SP3-07 | Build AI Auto-Fill (Auto Driver) for EU AI Act controls | US-404 | Muhammad Haris | Done | 10 | 12 | Integrated with OpenAI API |

## Class Diagram:

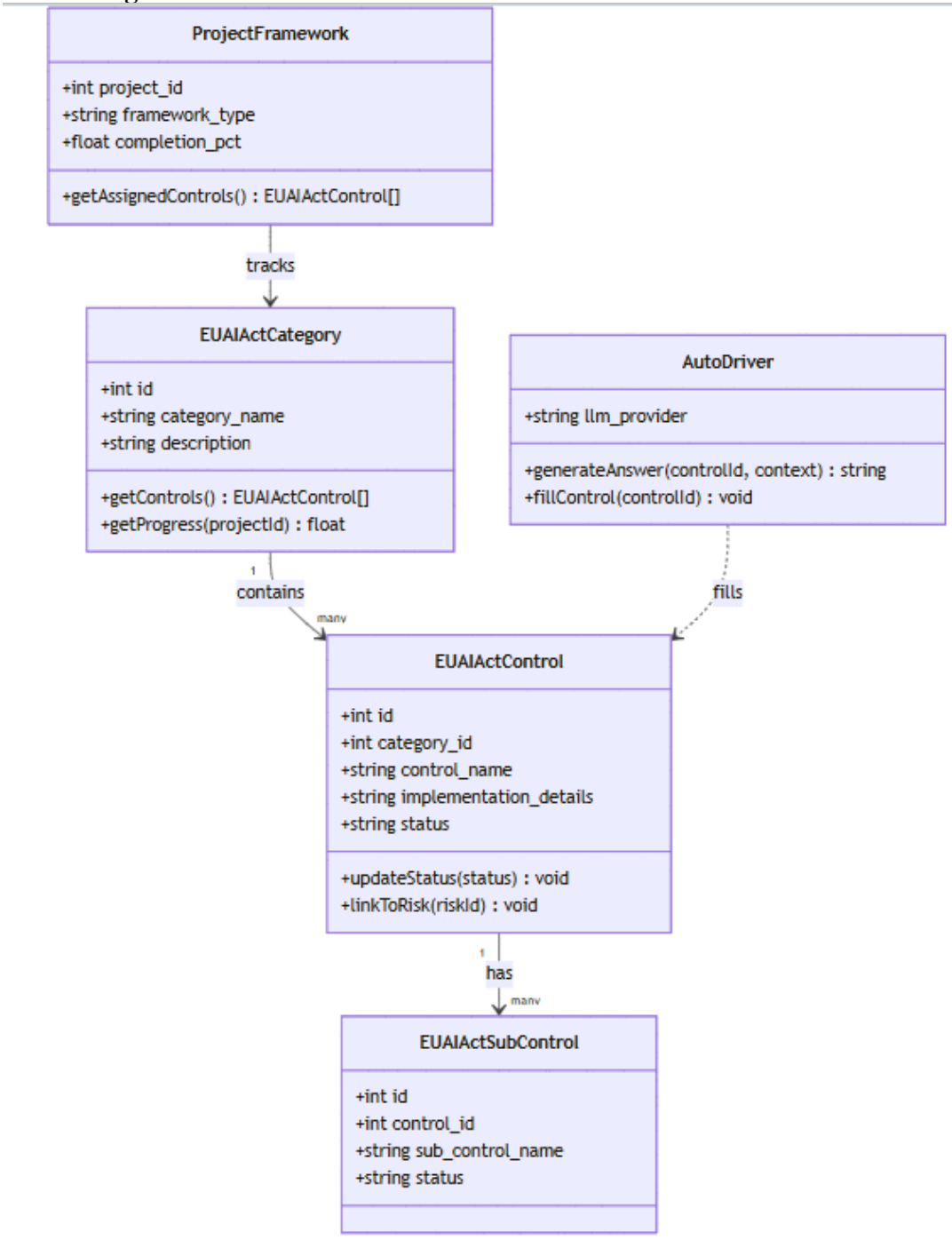



**Figure 27: Sprint 3 Class Diagram**

**Sequence Diagram:**

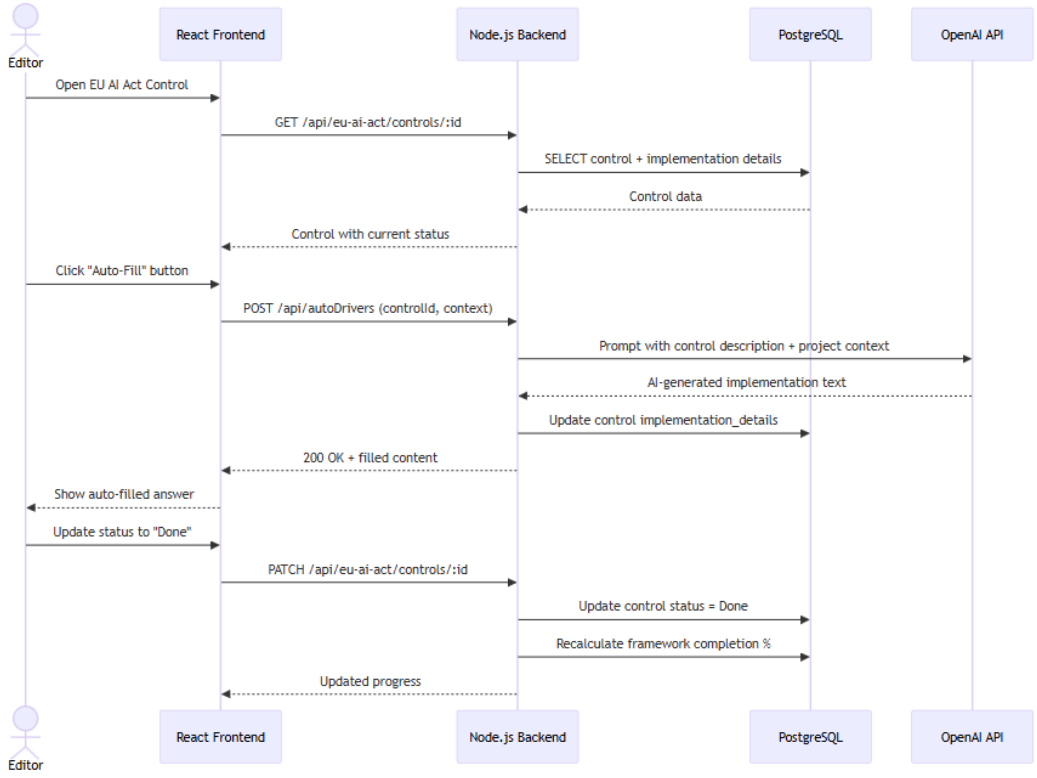



**Figure 28: Sprint 3 Sequence Diagram**

## Decision Table:

**Table 19: Sprint 3 Decision Table: EU AI Act Control Status Transitions**

| From Status | Action | Allowed Roles | To Status |
|---|---|---|---|
| Waiting | Start implementation | Editor | In Progress |
| In Progress | Submit for review | Editor | Under Review |
| In Progress | Mark done (if no review) | Editor | Done |
| Under Review | Approve | Reviewer | Done |
| Under Review | Request rework | Reviewer | In Progress |
| Done | Reopen | Admin/Editor | In Progress |

| From Status | Action | Allowed Roles | To Status |
|---|---|---|---|
| N/A | Mark as not applicable | Editor | N/A |

**Sprint 3 Extended Test Cases:**

**Test Designer:** Farhana Minhas
**Executor:** Ahmed Abdullah Khan
**Date:** January 9, 2026

**Table 20: Sprint 3 Extended Test cases**

| TID | Test Case Description | Test Data | Expected Result | Actual Result | Status |
|---|---|---|---|---|---|
| TC3-01 | EU AI Act seeded with 13 categories | GET /api/eu-ai-act/categories | 13 categories returned | 13 categories present | Pass |
| TC3-02 | Control status updated to In Progress | PATCH status=In_Progress | Status stored; progress % updated | Status updated correctly | Pass |
| TC3-03 | Control status updated to Done | PATCH status=Done | Completion % increases | % updated | Pass |
| TC3-04 | Auto Driver fills control with AI | POST /api/autoDrivers (controlId) | Control implementation_details populated | AI answer generated | Pass |
| TC3-05 | Framework completion % correct | 5 of 10 controls Done | 50% completion shown | 50% displayed | Pass |
| TC3-06 | Control linked to a risk | POST risk-control link | Junction record created | Link created | Pass |

| TID | Test Case Description | Test Data | Expected Result | Actual Result | Status |
|---|---|---|---|---|---|
| TC3-07 | Assessment questionnaire renders for category | GET /api/eu-ai-act/assessments | Questions per category loaded | Questions displayed | Pass |
| TC3-08 | Progress card shows correct assignment % | Assign 3 of 5 controls | 60% assignment displayed | Correct % shown | Pass |
| TC3-09 | Two projects have independent control states | Set status in Project A; check Project B | Project B unaffected | Isolation confirmed | Pass |
| TC3-10 | Control marked N/A with justification | PATCH status=N/A, justification text | N/A stored; excluded from completion % | N/A working | Pass |

**Sprint 3 Review Meeting**

**Date:** January 9, 2026

**Sprint 3 Metrics Overview:**

| Metric | Value |
|---|---|
| Committed Story Points | 21 |
| Completed Story Points | 21 |
| Carryover Items | None |
| Bugs Reported | 0 |
| Bugs Resolved | 0 |

**Table 21: Sprint 3 Review Status of Sprint Backlog**

| SP-ID | Task | Status | Notes |
|---|---|---|---|
| SP3-01 | EU AI Act seeding | Done | 13 categories, full hierarchy |
| SP3-02 | Control editor UI | Done | |
| SP3-03 | Status transitions | Done | All states working |
| SP3-04 | Assessment questionnaire | Done | |
| SP3-05 | Control-to-risk linking | Done | Junction table working |
| SP3-06 | Progress cards | Done | Completion and assignment % |
| SP3-07 | Auto Driver (AI auto-fill) | Done | OpenAI integration working |

**Feedback from Stakeholders:**

| Feedback Source | Comments |
|---|---|
| Product Owner (Usama Ahmad) | EU AI Act coverage verified against regulation text; excellent |
| Team | Reusable seeder utility saved ~4 hours vs manual approach |

**Sprint 3 Retrospective Meeting**

**What went well:** Reusable seeder from Sprint 2 retro worked excellently. AI Auto-Fill delivered end-to-end.
**What could be improved:** Control seeding took more lines than expected; could be data-driven.
**Action items for Sprint 4:** Apply same seeder pattern for ISO frameworks
— *Muhammad Haris*

**Team Health Check:**

| Area | Rating (1-5) | Comments |
|---|---|---|
| Team Morale | 5 | EU AI Act feature is impressive |
| Communication | 5 | Good alignment on data structure |
| Tools & Resources | 4 | LLM API quota limits tested |

## 4.7 Sprint 4: ISO 42001 & ISO 27001 Frameworks:

**Duration:** Weeks 7–8 (December 27, 2025 – January 9, 2026)
**Scrum Master:** Muhammad Haris
**Goal:** ISO 42001 and ISO 27001 clause/annex tracking with approval workflow.

**Sprint 4 Planning Meeting:**

**Date:** December 27, 2025
**Attendees:** Muhammad Haris (Scrum Master), Ahmed Abdullah Khan, Farhana Minhas, Usama Ahmad (Product Owner)

**Table 22: Sprint 4 Selected User Stories from Product Backlog**

| PB-ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| US-402 | As an editor, I can manage ISO 42001 (AIMS) and ISO 27001 (ISMS) clauses. | Critical | Both frameworks seeded; 7-stage workflow working; evidence upload functional | 13 | Done |

**Table 23: Sprint 4 Team Capacity**

| Member | Days Available | Hours/Day | Total Hours |
|---|---|---|---|
| Muhammad Haris | 10 | 6 | 60 |
| Ahmed Abdullah Khan | 10 | 6 | 60 |
| Farhana Minhas | 10 | 5 | 50 |

| Member | Days Available | Hours/Day | Total Hours |
|---|---|---|---|
| **Total** | | | **170 hrs** |

**Action Items Before Sprint Starts:**

- Source ISO 42001:2023 clause structure — *Farhana Minhas*
- Source ISO 27001:2022 Annex A controls — *Ahmed Abdullah Khan*
- Apply seeder utility from Sprint 3 for ISO seeding — *Muhammad Haris*

**Table 24: Sprint 4 Sprint Backlog**

| SP-ID | Task Name | Related PB-ID | Assigned To | Status | Est. Hours | Actual Hours | Comments |
|---|---|---|---|---|---|---|---|
| SP4-01 | Seed ISO 42001 clause structure (Clauses 4-10, Annexes A/B) | US-402 | Muhammad Haris | Done | 12 | 14 | |
| SP4-02 | Seed ISO 27001 clause structure | US-402 | Ahmed Abdullah Khan | Done | 10 | 12 | Annex A has 93 controls |
| SP4-03 | Build subclause implementation editor with evidence upload | US-402 | Farhana Minhas | Done | 12 | 12 | |
| SP4-04 | Implement 7-stage status workflow (Not Started to Implemented) | US-402 | Muhammad Haris | Done | 8 | 8 | |
| SP4-05 | Build annex applicability management (N/A with justification) | US-402 | Ahmed Abdullah Khan | Done | 6 | 6 | |

| SP-ID | Task Name | Related PB-ID | Assigned To | Status | Est. Hours | Actual Hours | Comments |
|---|---|---|---|---|---|---|---|
| SP4-06 | Build assignment management (Owner/Reviewer/ Approver per item) | US-402 | Farhana Minhas | Done | 8 | 8 | |

**Table 25: Sprint 4 Decision Table: ISO Clause 7-Stage Status Workflow**

| Stage | Status Name | Who Can Transition | Next Stage Conditions |
|---|---|---|---|
| 1 | Not Started | Editor | Start work |
| 2 | Planning | Editor | Planning documented |
| 3 | In Progress | Editor | Implementation active |
| 4 | Implemented | Editor | Implementation complete |
| 5 | Evidence Collected | Editor | Evidence uploaded |
| 6 | Under Review | Assigned Reviewer | Reviewer assigned |
| 7 | Implemented (Final) | Reviewer/Approver | Review passed |
| N/A | Not Applicable | Editor | Justification provided |

**Sprint 4 Extended Test Cases:**

**Test Designer:** Muhammad Haris
**Executor:** Farhana Minhas
**Date:** January 23, 2026

**Table 26: Sprint 4 Extended Test Cases**

| TID | Test Case Description | Test Data | Expected Result | Actual Result | Status |
|---|---|---|---|---|---|
| TC4-01 | ISO 42001 clauses seeded | GET /api/iso-42001 | Clauses 4-10 + Annexes A/B returned | All clauses present | Pass |
| TC4-02 | ISO 27001 Annex A seeded with 93 controls | GET /api/iso-27001/annex-a | 93 controls returned | Correct count | Pass |
| TC4-03 | Clause status progresses through 7 stages | Transition through all 7 stages | Each stage stored correctly | All transitions work | Pass |
| TC4-04 | Evidence file uploaded to a subclause | Upload PDF to subclause | File stored; linked to subclause | Upload successful | Pass |
| TC4-05 | Annex item marked as N/A with justification | PATCH status=N/A, justification=text | N/A stored; excluded from completion | N/A working | Pass |
| TC4-06 | Owner assigned to a clause | PATCH clause with owner_id | Owner linked; displayed in UI | Assignment working | Pass |
| TC4-07 | Reviewer assigned to a clause | PATCH clause with reviewer_id | Reviewer displayed; can transition | Reviewer role working | Pass |
| TC4-08 | ISO 42001 completion % calculation | 5 of 10 subclauses at stage 7 | 50% completion | Correct % | Pass |
| TC4-09 | ISO 27001 independent of | Update ISO 42001 clause | ISO 27001 unaffected | Independence confirmed | Pass |

| TID | Test Case Description | Test Data | Expected Result | Actual Result | Status |
|---|---|---|---|---|---|
| | ISO 42001 per project | | | | |
| TC4-10 | Cross-tenant ISO data isolation | Access via different org header | 403 or empty | Isolation working | Pass |

**Sprint 4 Review Meeting**

**Date:** January 23, 2026

**Sprint 4 Metrics Overview:**

| Metric | Value |
|---|---|
| Committed Story Points | 13 |
| Completed Story Points | 13 |
| Carryover Items | None |
| Bugs Reported | 0 |
| Bugs Resolved | 0 |

**Table 27: Sprint 4 Review Status of Sprint Backlog**

| SP-ID | Task | Status | Notes |
|---|---|---|---|
| SP4-01 | ISO 42001 seeding | Done | Full clause hierarchy |
| SP4-02 | ISO 27001 seeding | Done | Including 93 Annex A controls |
| SP4-03 | Subclause editor + evidence | Done | |
| SP4-04 | 7-stage workflow | Done | All stages working |
| SP4-05 | N/A management | Done | |

| SP-ID | Task | Status | Notes |
|---|---|---|---|
| SP4-06 | Assignment management | Done | Owner/Reviewer/Approver |

**Feedback from Stakeholders:**

| Feedback Source | Comments |
|---|---|
| Product Owner (Usama Ahmad) | ISO coverage validated against standard text; well structured |
| Team | Clean architecture makes adding new frameworks fast |

**Sprint 4 Retrospective Meeting:**

**What went well:** Reusing Sprint 3 seeder pattern saved significant time. Clean architecture proven extensible.
**What could be improved:** ISO 27001 Annex A has 93 controls — larger than anticipated.
**Action items for Sprint 5:** Design risk scoring formula implementation — *Ahmed Abdullah Khan*

**Team Health Check:**

| Area | Rating (1-5) | Comments |
|---|---|---|
| Team Morale | 5 | All 3 major frameworks now in progress |
| Communication | 5 | Pattern-based approach agreed |
| Tools & Resources | 5 | Well organized |

## 4.8 Sprint 5: Risk Management

**Duration:** Weeks 9–10 (January 10 – January 23, 2026)
**Scrum Master:** Ahmed Abdullah Khan
**Goal:** Full risk registry with auto-calculated risk levels and history tracking.

**Sprint 5 Planning Meeting:**

**Date:** January 10, 2026
**Attendees:** Ahmed Abdullah Khan (Scrum Master), Muhammad Haris, Farhana Minhas, Usama Ahmad (Product Owner)

**Table 28: Sprint 5 Selected User Stories from Product Backlog**

| PB-ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| US-501 | As a risk owner, I can create and track project-specific risks. | Critical | Risk CRUD working; risk list displayed | 8 | Done |
| US-502 | As a user, I can see the change history of a risk over time. | High | Risk history snapshots stored on every update | 5 | Done |
| US-503 | As a system, I auto-calculate risk levels using formula L*I* + *S*3. | Critical | Risk level auto-calculated on create/update | 8 | Done |
| US-601 | As a user, I can maintain a registry of AI vendors. | High | Vendor CRUD working; linked to project | 5 | Done |
| US-602 | As a risk officer, I can perform risk assessments on vendors. | High | Vendor risk CRUD; linked to vendor | 5 | Done |

**Table 29: Sprint 5 Team Capacity**

| Member | Days Available | Hours/Day | Total Hours |
|---|---|---|---|
| Muhammad Haris | 10 | 6 | 60 |
| Ahmed Abdullah Khan | 10 | 6 | 60 |
| Farhana Minhas | 10 | 5 | 50 |
| **Total** | | | **170 hrs** |

**Action Items Before Sprint Starts:**

- Finalize risk score formula: L*1* + *S*3 — *Ahmed Abdullah Khan*
- Design risk history snapshot table schema — *Muhammad Haris*
- Research Recharts library for timeseries charts — *Farhana Minhas*

**Table 30: Sprint 5 Sprint Backlog**

| SP-ID | Task Name | Related PB-ID | Assigned To | Status | Est. Hours | Actual Hours | Comments |
|---|---|---|---|---|---|---|---|
| SP5-01 | Build Project Risk CRUD API and UI | US-501 | Ahmed Abdullah Khan | Done | 12 | 12 | |
| SP5-02 | Implement risk level auto-calculation (L*1* + *S*3) | US-503 | Muhammad Haris | Done | 6 | 6 | Formula applied on save |
| SP5-03 | Build Vendor Risk module | US-602 | Farhana Minhas | Done | 8 | 9 | |
| SP5-04 | Build Model Risk module | US-501 | Ahmed Abdullah Khan | Done | 6 | 7 | |
| SP5-05 | Implement risk-control mapping (junction tables) | US-501 | Muhammad Haris | Done | 6 | 6 | Per framework |

| SP-ID | Task Name | Related PB-ID | Assigned To | Status | Est. Hours | Actual Hours | Comments |
|---|---|---|---|---|---|---|---|
| SP5-06 | Build risk history snapshot system | US-502 | Muhammad Haris | Done | 8 | 8 | |
| SP5-07 | Build risk timeseries charts | US-502 | Farhana Minhas | Done | 8 | 10 | Recharts new to team member |
| SP5-08 | Build risk change history audit trail | US-502 | Ahmed Abdullah Khan | Done | 6 | 6 | |

## Class Diagram:

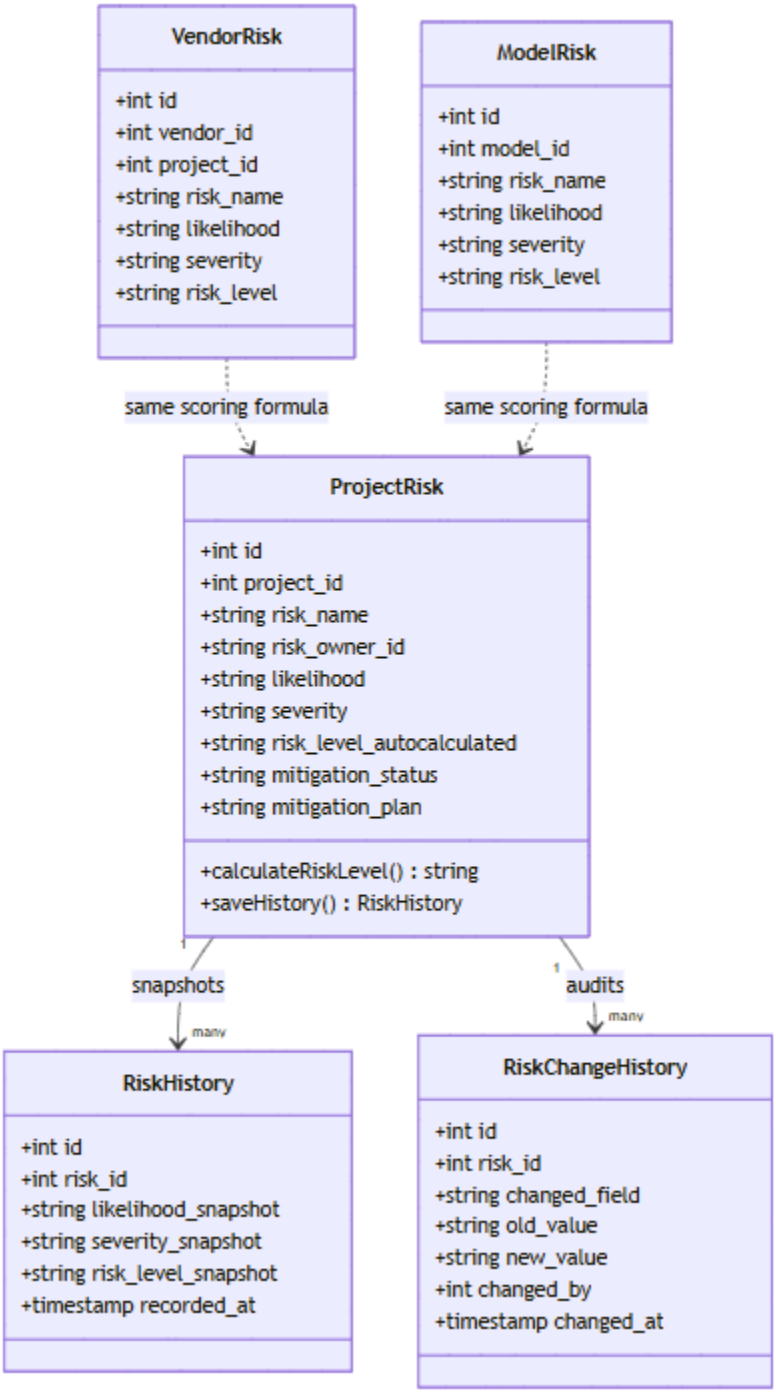



**Figure 29: Sprint 5 Class Diagram**

**Sequence Diagram:**

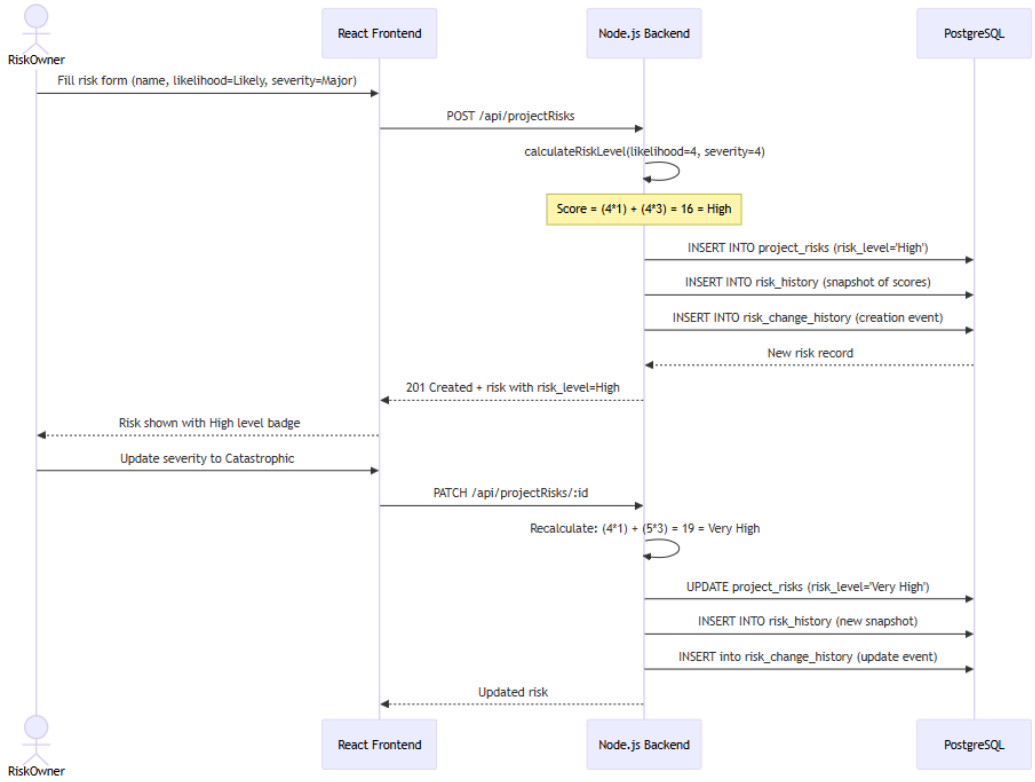



**Figure 30: Sprint 5 Sequence Diagram**

## Decision Table

**Table 31: Sprint 5 Decision Table  Risk Level Auto-Calculation**

| Likelihood Score (1-5) | Severity Score (1-5) | Formula (L*1* + *S*3) | Risk Level |
|---|---|---|---|
| 1 | 1 | 4 | Very Low |
| 2 | 2 | 8 | Low |
| 3 | 3 | 12 | Medium |
| 4 | 4 | 16 | High |
| 5 | 5 | 20 | Very High |
| 1 | 5 | 16 | High |
| 5 | 1 | 8 | Low |

**Sprint 5 Extended Test Cases:**

**Test Designer:** Ahmed Abdullah Khan
**Executor:** Muhammad Haris
**Date:** February 6, 2026

**Table 32: Sprint 5 Extended Test Cases**

| TID | Test Case Description | Test Data | Expected Result | Actual Result | Status |
|---|---|---|---|---|---|
| TC5-01 | Create project risk with valid data | POST /api/projectRisks (L=3, S=3) | Risk created; level=Medium | Risk created correctly | Pass |
| TC5-02 | Risk level auto-calculated on creation | L=4, S=4 | risk_level = High (4*1* + *4*3 = 16) | High returned | Pass |
| TC5-03 | Risk level updates on edit | Update S from 3 to 5 | Level recalculated | New level correct | Pass |
| TC5-04 | Risk history snapshot stored on create | POST risk | RiskHistory record created | History stored | Pass |
| TC5-05 | Risk history snapshot stored on update | PATCH risk | New RiskHistory record added | Snapshot added | Pass |

| TID | Test Case Description | Test Data | Expected Result | Actual Result | Status |
|---|---|---|---|---|---|
| TC 5-06 | Risk change history tracks field changes | Update risk_name | risk_change_history record: field=risk_name | Change tracked | Pass |
| TC 5-07 | Vendor risk CRUD | POST /api/vendorRisks | Vendor risk created; linked to vendor | VendorRisk working | Pass |
| TC 5-08 | Model risk CRUD | POST /api/modelRisks | Model risk created; linked to model | ModelRisk working | Pass |
| TC 5-09 | Risk timeseries chart data | GET /api/riskHistory?projectId=1 | Historical risk snapshots returned | Data returned | Pass |
| TC 5-10 | Risk donut distribution chart | GET risk distribution | Counts by risk level | Distribution correct | Pass |

**Sprint 5 Review Meeting:**

**Date:** February 6, 2026

**Sprint 5 Metrics Overview:**

| Metric | Value |
|---|---|
| Committed Story Points | 31 |
| Completed Story Points | 31 |
| Carryover Items | None |
| Bugs Reported | 0 |

| Metric | Value |
|---|---|
| Bugs Resolved | 0 |

**Table 33: Sprint 5 Review Status of Sprint Backlog**

| SP-ID | Task | Status | Notes |
|---|---|---|---|
| SP5-01 | Project Risk CRUD | Done | |
| SP5-02 | Risk Auto-Calculation | Done | L*I* + *S*3 formula |
| SP5-03 | Vendor Risk | Done | |
| SP5-04 | Model Risk | Done | |
| SP5-05 | Risk-Control Mapping | Done | |
| SP5-06 | Risk History | Done | Snapshot system |
| SP5-07 | Timeseries Charts | Done | Recharts |
| SP5-08 | Change History Audit | Done | |

**Feedback from Stakeholders:**

| Feedback Source | Comments |
|---|---|
| Product Owner (Usama Ahmad) | Risk scoring formula matches EU AI Act guidance; timeseries chart very visual |
| Team | Paired programming for Recharts worked well |

**Sprint 5 Retrospective Meeting:**

**What went well:** Risk formula implementation clean. Chart integration resolved via paired programming.
**What could be improved:** Recharts was new — add library evaluation step before sprint.
**Action items for Sprint 6:** Design policy data model and approval flow — *Farhana Minhas*

**Team Health Check:**

| Area | Rating (1-5) | Comments |
|---|---|---|
| Team Morale | 5 | Risk module is core to governance |
| Communication | 5 | Paired programming effective |
| Tools & Resources | 4 | Recharts learning curve |

## 4.9 Sprint 6: Vendor Management, Policy Manager & Tasks

**Duration:** Weeks 11–12 (January 24 – February 6, 2026)
**Scrum Master:** Farhana Minhas
**Goal:** Vendor profiles, vendor risks, policy lifecycle management, and task management.

**Sprint 6 Planning Meeting:**

**Date:** January 24, 2026

**Table 34: Sprint 6 Selected User Stories from Product Backlog**

| PB-ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| US-701 | As a policy owner, I can draft, review, and publish AI policies. | High | Policy lifecycle working; approval flow integrated | 8 | Done |
| US-702 | As a user, I can link policies to framework controls or risks. | High | Policy-control and policy-risk links stored | 5 | Done |
| US-1301 | As a user, I can upload and manage files in a central Evidence Hub. | High | File upload, search, and export working | 8 | Done |
| US-1306 | As a user, I can create and manage governance tasks. | Medium | Task CRUD; assignment; due-date warnings | 5 | Done |

**Table 35: Sprint 6 Team Capacity**

| Member | Days Available | Hours/Day | Total Hours |
|---|---|---|---|
| Muhammad Haris | 10 | 6 | 60 |
| Ahmed Abdullah Khan | 10 | 6 | 60 |
| Farhana Minhas | 10 | 5 | 50 |
| **Total** | | | **170 hrs** |

**Action Items Before Sprint Starts:**

- Design policy data model (Draft/Review/Published states) — *Farhana Minhas*
- Reuse approval workflow engine from Sprint 2 for policy approvals — *Muhammad Haris*

**Table 36: Sprint 6 Sprint Backlog**

| SP-ID | Task Name | Related PB-ID | Assigned To | Status | Est. Hours | Actual Hours | Comments |
|---|---|---|---|---|---|---|---|
| SP6-01 | Build Vendor CRUD API and management UI with change history | US-601 | Ahmed Abdullah Khan | Done | 10 | 11 | |
| SP6-02 | Build Vendor Risk linking to vendor profiles | US-602 | Muhammad Haris | Done | 6 | 6 | |

| SP-ID | Task Name | Related PB-ID | Assigned To | Status | Est. Hours | Actual Hours | Comments |
|---|---|---|---|---|---|---|---|
| SP6-03 | Build Policy Manager (create, draft, submit, approve, publish) | US-701 | Farhana Minhas | Done | 12 | 13 | |
| SP6-04 | Implement policy approval workflow | US-701 | Muhammad Haris | Done | 6 | 6 | Reused Sprint 2 engine |
| SP6-05 | Build policy-to-framework control mapping | US-702 | Ahmed Abdullah Khan | Done | 6 | 6 | |
| SP6-06 | Build Task management (CRUD, assignment, due-date warnings) | US-1306 | Farhana Minhas | Done | 8 | 8 | |
| SP6-07 | Build Evidence Hub (file upload, search, export) | US-1301 | Ahmed Abdullah Khan | Done | 10 | 10 | |

## Class Diagram:

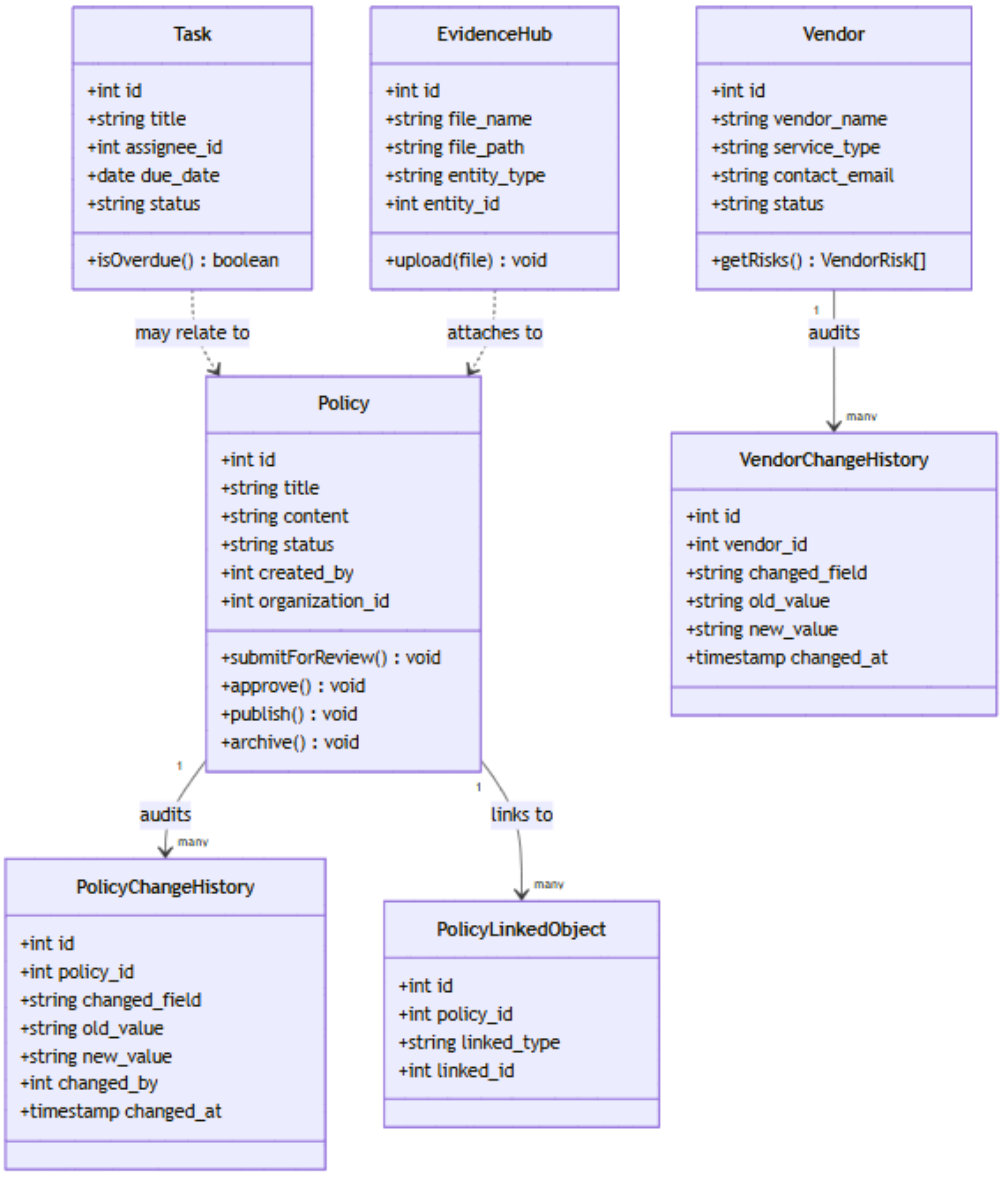



**Figure 31: Sprint 6 Class Diagram**

## Sequence Diagram:

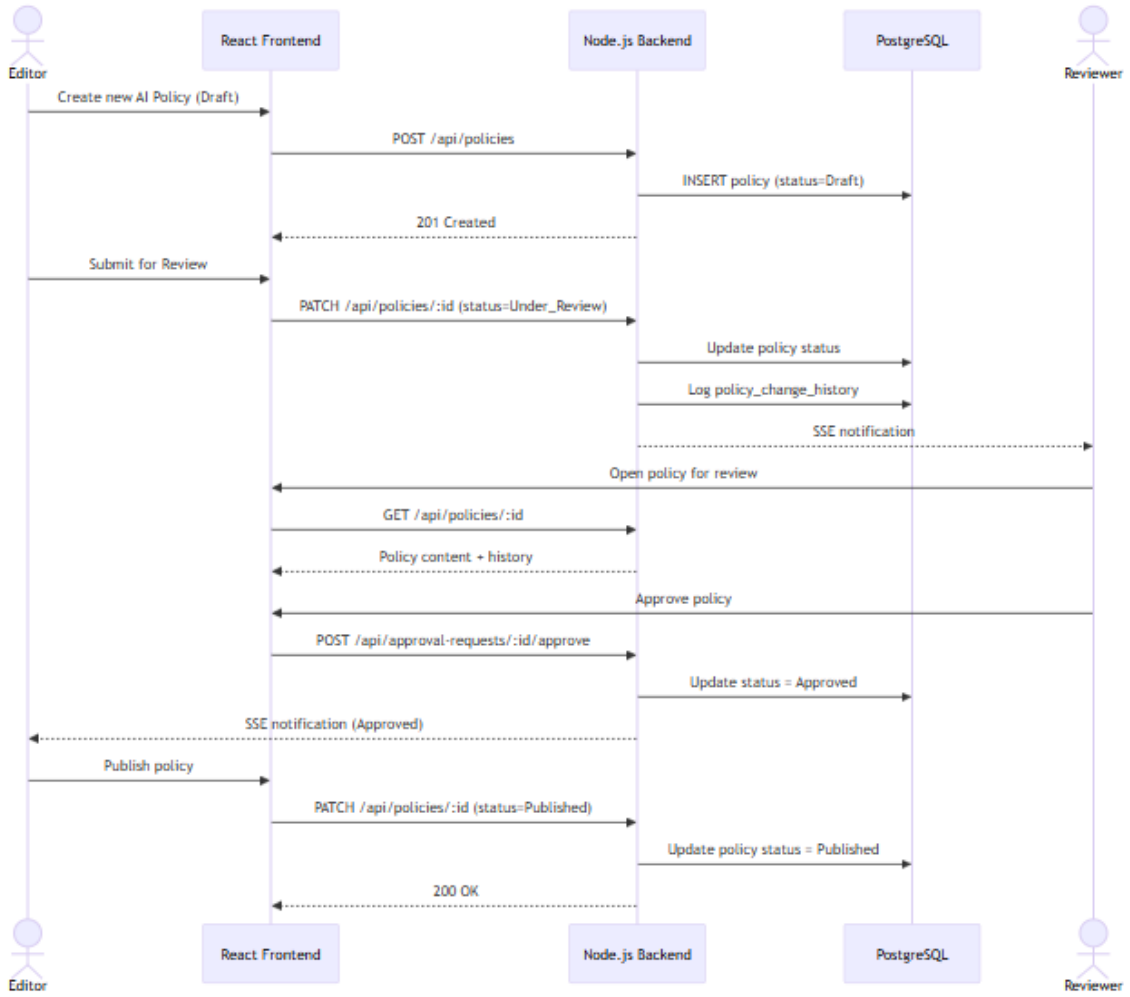



**Figure 13: Sprint 6 Sequence Diagram**

## Decision Table

**Table 37: Sprint 6 Decision Table  Policy Lifecycle Transitions**

| Current State | Action | Actor | New State |
|---|---|---|---|
| Draft | Submit for review | Editor | Under Review |
| Under Review | Approve | Reviewer | Approved |
| Under Review | Request rework | Reviewer | Draft |
| Approved | Publish | Admin | Published |

| Current State | Action | Actor | New State |
|---|---|---|---|
| Published | Archive | Admin | Archived |

### Sprint 6 Extended Test Cases

**Table 38: Sprint 6 Extended Test Cases**

| TID | Test Case Description | Test Data | Expected Result | Actual Result | Status |
|---|---|---|---|---|---|
| TC6-01 | Create a draft policy | POST /api/policies | Policy created with status=Draft | Created | Pass |
| TC6-02 | Submit policy for review | PATCH status=Under_Review | Status changed; reviewer notified | Status updated | Pass |
| TC6-03 | Reviewer approves policy | POST .../approve | Policy status=Approved | Approved | Pass |
| TC6-04 | Policy linked to EU AI Act control | POST /api/policy-linked | Link record created | Link created | Pass |
| TC6-05 | Policy linked to a risk | POST /api/policy-linked (risk) | Risk-policy link created | Link created | Pass |
| TC6-06 | Evidence file uploaded | POST /api/evidenceHub (PDF 2MB) | File stored; accessible | Upload works | Pass |
| TC6-07 | Task created and assigned | POST /api/tasks with assignee | Task created; assignee notified | Task created | Pass |

| TID | Test Case Description | Test Data | Expected Result | Actual Result | Status |
|---|---|---|---|---|---|
| TC6-08 | Task due date warning shown | Task due in 2 days | Warning indicator shown in UI | Warning shown | Pass |
| TC6-09 | Vendor change history tracked | Update vendor name | Change history record created | History stored | Pass |
| TC6-10 | Cross-tenant policy isolation | Read policy via different org | 403 or empty result | Isolation confirmed | Pass |

**Sprint 6 Review Meeting:**

**Sprint 6 Metrics Overview:**

| Metric | Value |
|---|---|
| Committed Story Points | 26 |
| Completed Story Points | 26 |
| Carryover Items | None |
| Bugs Reported | 0 |
| Bugs Resolved | 0 |

**Table 39: Sprint 6  Sprint Review Status of Sprint Backlog**

| SP-ID | Task | Status | Notes |
|---|---|---|---|
| SP6-01 | Vendor CRUD + history | Done | |

| SP-ID | Task | Status | Notes |
|---|---|---|---|
| SP6-02 | Vendor Risk linking | Done | |
| SP6-03 | Policy Manager | Done | Full lifecycle |
| SP6-04 | Policy approval | Done | Reused workflow engine |
| SP6-05 | Policy-control mapping | Done | |
| SP6-06 | Task management | Done | |
| SP6-07 | Evidence Hub | Done | |

**Feedback from Stakeholders:**

| Feedback Source | Comments |
|---|---|
| Product Owner | Policy lifecycle and evidence hub complete governance loop |
| Team | Reusing Sprint 2 approval engine saved 2 days of development |

**Sprint 6 Retrospective Meeting**

**What went well:** Reusing the approval workflow engine. Evidence Hub clean implementation.
**What could be improved:** Evidence search could be more advanced — noted as future work.
**Action items for Sprint 7:** Research NIST AI RMF structure before sprint
— *Muhammad Haris*

**Team Health Check:**

| Area | Rating (1-5) | Comments |
|---|---|---|
| Team Morale | 5 | Platform growing well |
| Communication | 5 | Good reuse decisions |

| Area | Rating (1-5) | Comments |
|---|---|---|
| Tools & Resources | 5 | No blockers |

## 4.10 Sprint 7: AI Model Inventory & NIST AI RMF

**Duration:** Weeks 13–14 (February 7 – February 20, 2026)
**Scrum Master:** Muhammad Haris
**Goal:** Complete AI model registry and NIST AI RMF framework integration. *(US-802 — MLflow Sync deferred " requires external services: requires running MLflow instance)*

**Sprint 7 Planning Meeting:**

**Date:** February 7, 2026

**Table 40: Sprint 7 Selected User Stories from Product Backlog**

| PB-ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| US-801 | As a developer, I can register model metadata and version history. | High | Model CRUD; version history; project linking | 8 | Done |
| US-403 | As an editor, I can track NIST AI RMF functions and categories. | High | 4 functions seeded; subcategory tracking working | 8 | Done |

**Table 41: Sprint 7 Team Capacity**

| Member | Days Available | Hours/Day | Total Hours |
|---|---|---|---|
| Muhammad Haris | 10 | 6 | 60 |
| Ahmed Abdullah Khan | 10 | 6 | 60 |
| Farhana Minhas | 10 | 5 | 50 |
| **Total** | | | **170 hrs** |

**Action Items Before Sprint Starts:**

- Research NIST AI RMF 1.0 structure (Govern/Map/Measure/Manage) — *Muhammad Haris*
- Design model inventory schema (metadata, versions, linked risks) — *Ahmed Abdullah Khan*

**Table 42: Sprint 7 Sprint Backlog**

| SP-ID | Task Name | Related PB-ID | Assigned To | Status | Est. Hours | Actual Hours | Comments |
|---|---|---|---|---|---|---|---|
| SP 7-01 | Build AI Model Inventory CRUD API and UI | US-801 | Ahmed Abdullah Khan | Done | 12 | 12 | |
| SP 7-02 | Implement model-project linking | US-801 | Muhammad Haris | Done | 4 | 4 | |
| SP 7-03 | Build model change history and version history tracking | US-801 | Muhammad Haris | Done | 8 | 8 | |
| SP 7-04 | Seed NIST AI RMF structure (Govern/Map/Measure/Manage functions) | US-403 | Muhammad Haris | Done | 10 | 11 | |
| SP 7-05 | Build NIST subcategory implementation UI | US-403 | Farhana Minhas | Done | 8 | 8 | |
| SP 7-06 | Build NIST progress by function charts | US-403 | Farhana Minhas | Done | 6 | 6 | |
| SP 7-07 | MLflow integration scaffolding (deferred) | US-802 | Ahmed Abdullah Khan | Deferred | 4 | 0 | Requires MLflow |

## Class Diagram:

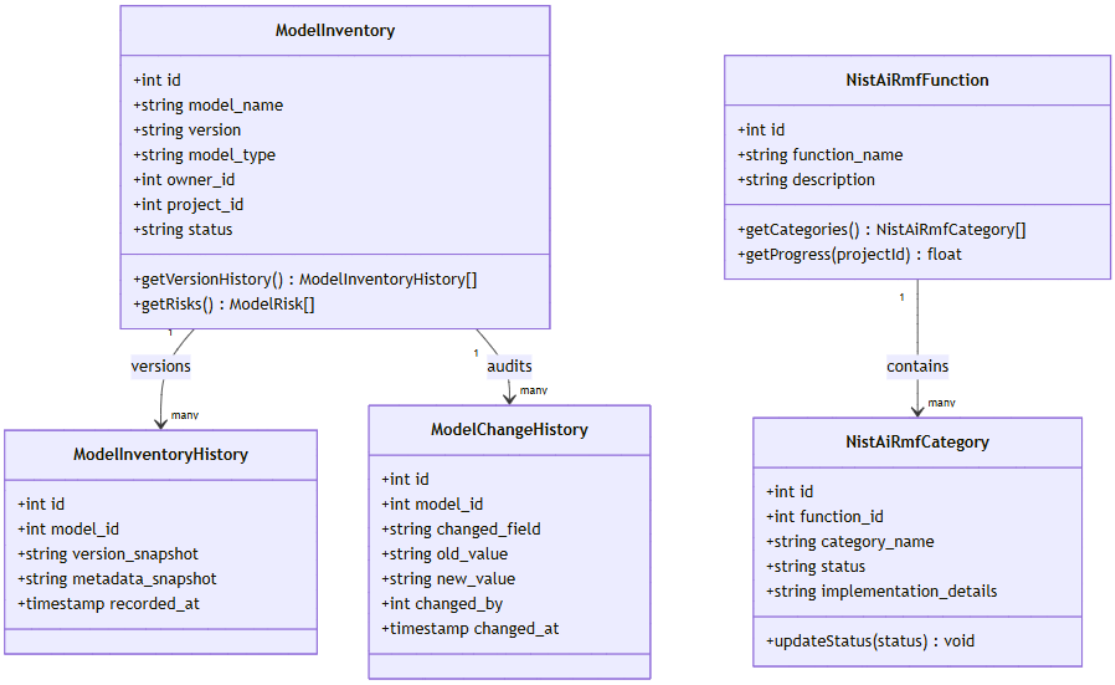



**Figure 32: Sprint 7 Class Diagram**

### Sprint 7 Sequence Diagram

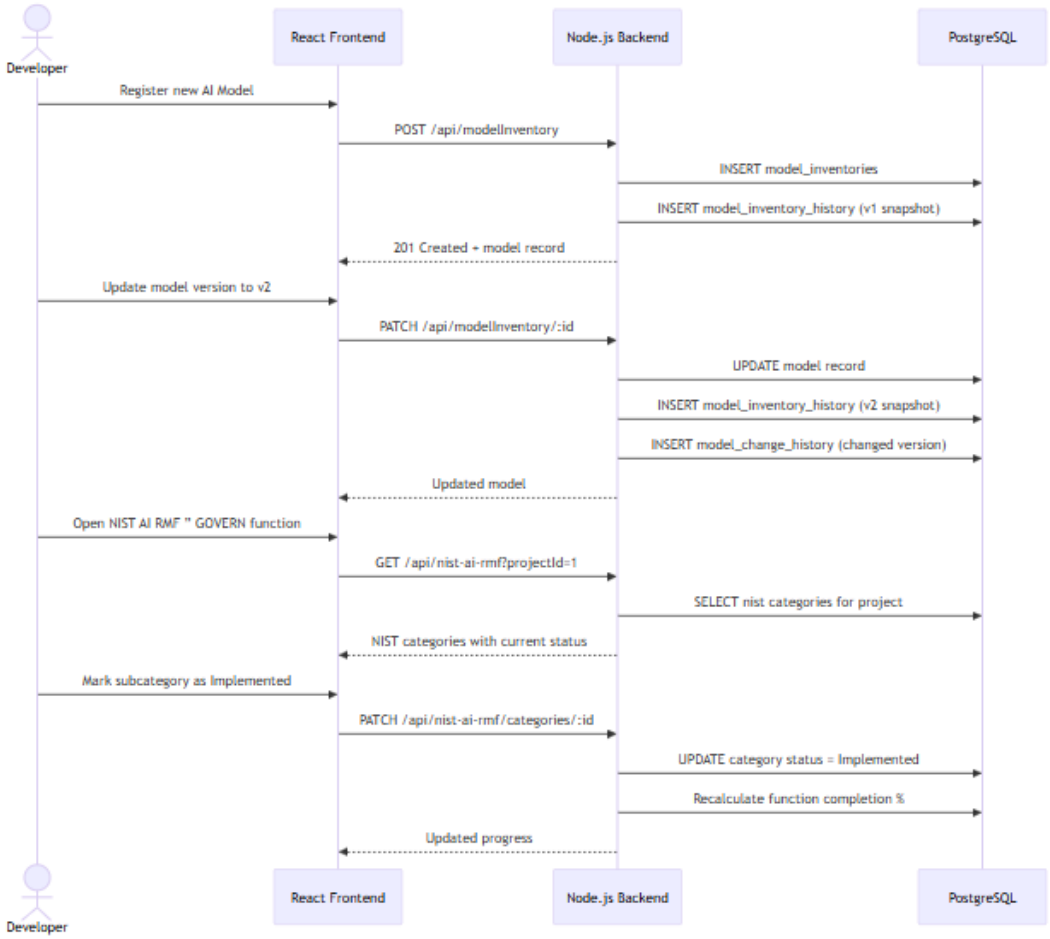



**Figure 33: Sprint 7 Sequence Diagram**

## Decision Table

**Table 43: Sprint 7 Decision Table  NIST AI RMF Function Applicability**

| NIST Function | Applies When | Core Activities | Aegis.AI Coverage |
|---|---|---|---|
| GOVERN | Always | Policies, roles, accountability | Policy Manager, RBAC, Approval Workflows |
| MAP | AI system in scope | Risk identification, context | Risk Management, Use Cases |
| MEASURE | Risk identified | Risk analysis, measurement | Risk Registry, Scoring Formula |

| NIST Function | Applies When | Core Activities | Aegis.AI Coverage |
|---|---|---|---|
| MANAGE | Risks measured | Risk treatment, monitoring | Risk mitigation; PMM module |

**Sprint 7 Extended Test Cases:**

**Table 44: Sprint 7 Extended Test Cases**

| TID | Test Case Description | Test Data | Expected Result | Actual Result | Status |
|---|---|---|---|---|---|
| TC 7-01 | Create AI model in inventory | POST /api/modelInventory | Model created with metadata | Created | Pass |
| TC 7-02 | Model linked to a project | PATCH model with project_id | Model-project link stored | Link created | Pass |
| TC 7-03 | Model version history tracked | Update model version | Version history record created | History stored | Pass |
| TC 7-04 | Model change history on update | Update model name | Change history record created | Change tracked | Pass |
| TC 7-05 | NIST AI RMF seeded with 4 functions | GET /api/nist-ai-rmf | Govern/Map/Measure/Manage returned | All 4 present | Pass |

| TID | Test Case Description | Test Data | Expected Result | Actual Result | Status |
|---|---|---|---|---|---|
| TC7-06 | NIST subcategory status update | PATCH subcategory status | Status stored; progress % updated | Status updated | Pass |
| TC7-07 | NIST progress chart by function | GET NIST progress | % per function returned | Data correct | Pass |
| TC7-08 | Two projects have independent NIST states | Update NIST in Project A | Project B NIST unaffected | Isolation OK | Pass |
| TC7-09 | Model risk linked to model | POST /api/modelRisks | Risk linked to model | Risk created | Pass |
| TC7-10 | MLflow scaffolding endpoint responds | GET /api/integrations/mlflow | 401 or placeholder response | Returns correctly | Pass |

**Sprint 7 Review Meeting:**

**Sprint 7 Metrics Overview:**

| Metric | Value |
|---|---|
| Committed Story Points | 16 |
| Completed Story Points | 16 |
| Carryover Items | US-802 MLflow deferred ” requires external services |
| Bugs Reported | 0 |

| Metric | Value |
|---|---|
| Bugs Resolved | 0 |

**Table 45: Sprint 7  Sprint Review  Status of Sprint Backlog**

| SP-ID | Task | Status | Notes |
|---|---|---|---|
| SP7-01 | Model Inventory CRUD | Done | |
| SP7-02 | Model-project linking | Done | |
| SP7-03 | Version history | Done | |
| SP7-04 | NIST seeding | Done | 4 functions + subcategories |
| SP7-05 | NIST subcategory UI | Done | |
| SP7-06 | NIST progress charts | Done | |
| SP7-07 | MLflow scaffolding | Deferred | Future Work |

**Feedback from Stakeholders:**

| Feedback Source | Comments |
|---|---|
| Product Owner | NIST AI RMF coverage confirmed; MLflow deferral understood |
| Team | Grouping external dependencies in FYP 2 is the right call |

**Sprint 7 Retrospective Meeting**

**What went well:** FYP 2 deferral strategy solidified. NIST seeding clean.
**What could be improved:** Clearer upfront ML dependency checklist.
**Action items for Sprint 8:** Build all LLM/Advisor UI shells without connecting to APIs
— *Ahmed Abdullah Khan*

**Team Health Check:**

| Area | Rating (1-5) | Comments |
|---|---|---|
| Team Morale | 4 | FYP 2 deferral minor concern but right decision |
| Communication | 5 | Strategy aligned |

| Area | Rating (1-5) | Comments |
|---|---|---|
| Tools & Resources | 4 | MLflow unavailable; handled gracefully |

## 4.11 Sprint 8: LLM Evaluations UI & AI Advisor UI

**Duration:** Weeks 15–16 (February 21 – March 6, 2026)
**Scrum Master:** Ahmed Abdullah Khan
**Goal:** Build UI infrastructure for LLM evaluations, AI Advisor, and LLM API key management. LLM execution and EvalServer deferred ” requires external services. *(US-901, US-902, US-1001, US-1002, US-1701–1703 deferred ” requires external services: require LLM API keys and EvalServer)*

**Sprint 8 Planning Meeting:**

**Date:** February 21, 2026

**Table 46: Sprint 8  Selected User Stories from Product Backlog**

| PB-ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| US-903 | As an admin, I can manage LLM API keys for multiple providers. | Medium | Key management UI with OpenAI/Anthropic/OpenRouter | 5 | Done |

**Table 47: Sprint 8 Team Capacity**

| Member | Days Available | Hours/Day | Total Hours |
|---|---|---|---|
| Muhammad Haris | 10 | 6 | 60 |
| Ahmed Abdullah Khan | 10 | 6 | 60 |
| Farhana Minhas | 10 | 5 | 50 |
| **Total** | | | **170 hrs** |

**Action Items Before Sprint Starts:**

- Design LLM evaluation experiment data model — *Ahmed Abdullah Khan*
- Design AI Advisor conversation history schema — *Muhammad Haris*
- Document which features require external API keys — *Farhana Minhas*

**Table 48: Sprint 8 Sprint Backlog**

| SP-ID | Task Name | Related PB-ID | Assigned To | Status | Est. Hours | Actual Hours | Comments |
|---|---|---|---|---|---|---|---|
| SP8-01 | Build LLM API key management UI (OpenAI/Anthropic/OpenRouter) | US-903 | Ahmed Abdullah Khan | Done | 8 | 8 | |
| SP8-02 | Build LLM Evaluation experiment UI (create, view, history) | US-901 | Muhammad Haris | Done | 12 | 12 | UI only; no EvalServer yet |
| SP8-03 | Build LLM Arena head-to-head comparison UI | US-902 | Farhana Minhas | Done | 8 | 8 | UI only |
| SP8-04 | Build AI Advisor chatbot UI with conversation history | US-1001 | Ahmed Abdullah Khan | Done | 10 | 10 | |
| SP8-05 | Build Bias & Fairness evaluation UI and results viewer | US-1002 | Farhana Minhas | Done | 8 | 8 | |
| SP8-06 | EvalServer FastAPI + DeepEval setup (deferred) | US-901 | Muhammad Haris | Deferred | 4 | 0 | Future Work |
| SP8-07 | Connect Advisor/Arena to | US-1001 | Ahmed Abdull | Deferred | 4 | 0 | Future Work |

| SP-ID | Task Name | Related PB-ID | Assigned To | Status | Est. Hours | Actual Hours | Comments |
|---|---|---|---|---|---|---|---|
| | LLM provider (deferred) | | ah Khan | | | | |

**Class Diagram:**

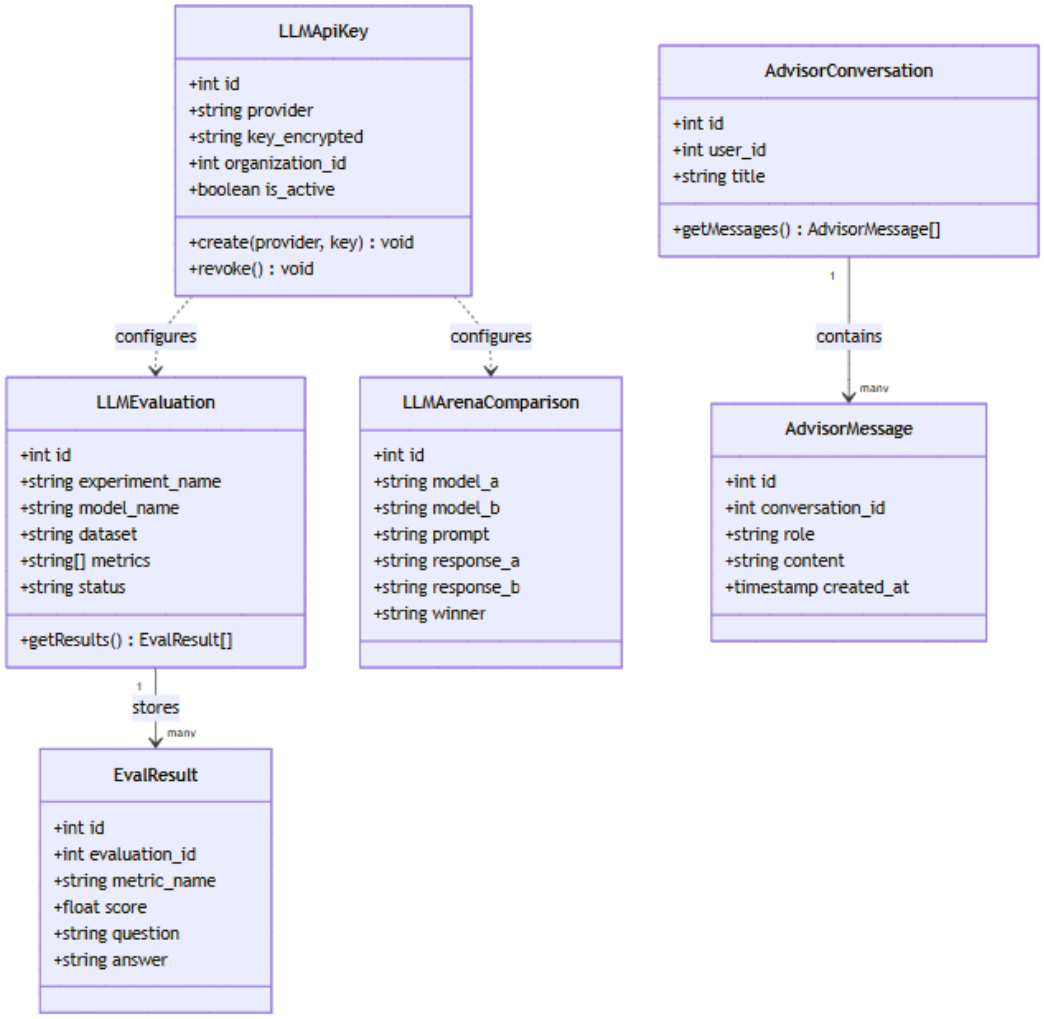



**Figure 34: Sprint 8 Class Diagram**

**Sequence Diagram:**

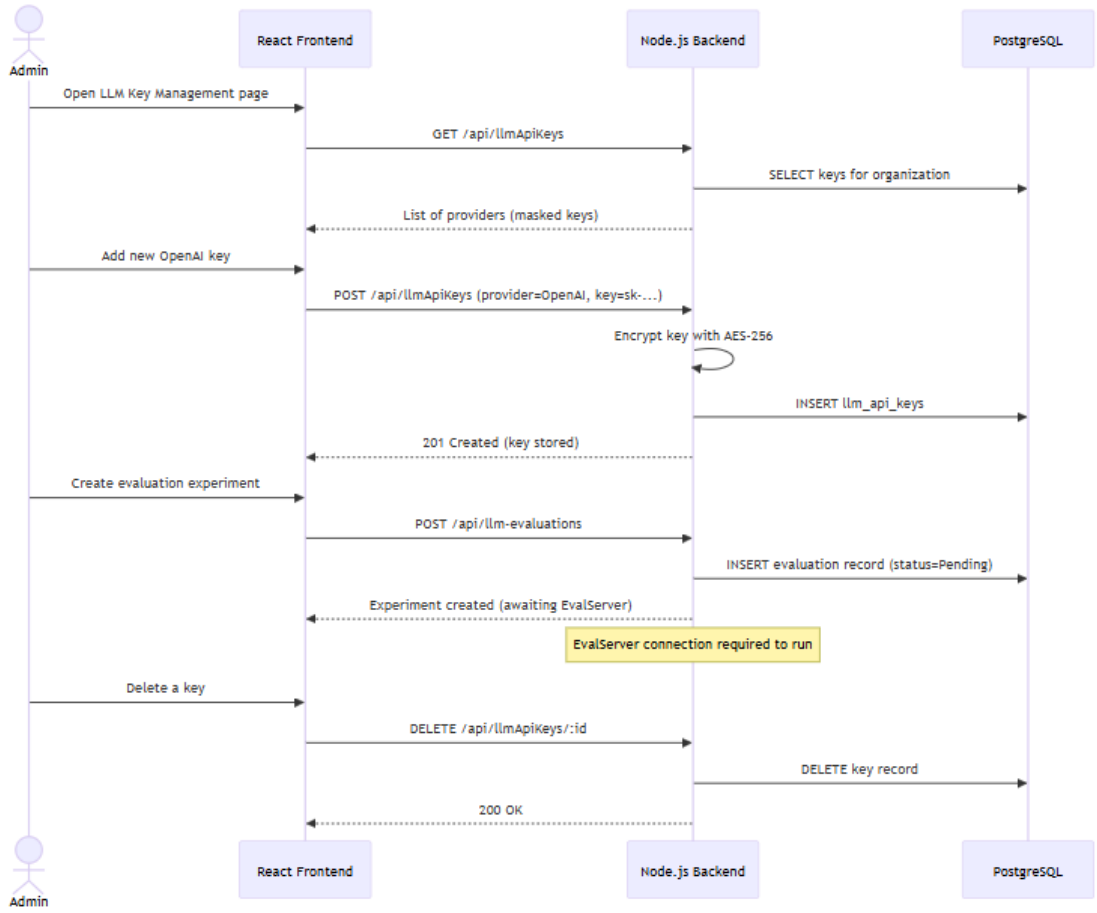



**Figure 35: Sprint 8 Sequence Diagram**

## Decision Table

**Table 49: Sprint 8 Decision Table  LLM Feature Activation Requirements**

| Feature | Status | Activation Requirement | FYP 2 Action |
|---|---|---|---|
| LLM Evaluations UI | Done | EvalServer + API Key | Deploy EvalServer |
| LLM Arena UI | Done | API Key configured | Set OpenAI key |
| AI Advisor UI | Done | API Key configured | Set any LLM key |
| Bias & Fairness UI | Done | EvalServer + API Key | Connect EvalServer |
| MLflow Model Sync | Deferred | MLflow instance | Deploy MLflow |

**Sprint 8 Extended Test Cases:**

**Table 50: Sprint 8 Extended Test Cases**

| TID | Test Case Description | Test Data | Expected Result | Actual Result | Status |
|---|---|---|---|---|---|
| TC8-01 | LLM API key added for OpenAI | POST /api/llmApiKeys | Key stored (encrypted) | Key stored | Pass |
| TC8-02 | LLM Evaluation experiment created | POST /api/llm-evaluations | Experiment record created | Created | Pass |
| TC8-03 | Evaluation history viewed | GET /api/llm-evaluations | List of experiments returned | Listed correctly | Pass |
| TC8-04 | Arena comparison UI renders | GET /lllm/arena | Arena UI loads with model selectors | UI renders | Pass |
| TC8-05 | AI Advisor chat UI renders | GET /advisor | Chatbot UI loads | UI renders | Pass |
| TC8-06 | Conversation history saved | Send message, reload | Previous messages loaded | History persisted | Pass |
| TC8-07 | Bias & Fairness UI loads | GET /llm/bias-fairness | UI loads; dataset upload available | UI renders | Pass |
| TC8-08 | Key management UI shows no keys initially | GET /api/llmApiKeys | Empty state displayed | Empty state works | Pass |

| TID | Test Case Description | Test Data | Expected Result | Actual Result | Status |
|---|---|---|---|---|---|
| TC8-09 | API key deletion | DELETE /api/llmApiKeys/:id | Key removed | Deletion works | Pass |
| TC8-10 | EvalServer empty state shown | GET /api/evaluations | No experiments yet message | Empty state shown | Pass |

**Sprint 8 Review Meeting:**

**Sprint 8 Metrics Overview:**

| Metric | Value |
|---|---|
| Committed Story Points | 5 |
| Completed Story Points | 5 |
| Carryover Items | US-901,902,1001 (Planned) |
| Bugs Reported | 0 |
| Bugs Resolved | 0 |

**Table 51: Sprint 8 Review Status of Sprint Backlog**

| SP-ID | Task | Status | Notes |
|---|---|---|---|
| SP8-01 | LLM API Key management | Done | |
| SP8-02 | LLM Evaluation UI | Done | UI only |
| SP8-03 | Arena UI | Done | UI only |
| SP8-04 | AI Advisor UI | Done | |
| SP8-05 | Bias & Fairness UI | Done | |
| SP8-06 | EvalServer setup | Deferred | Future Work |
| SP8-07 | LLM connections | Deferred | Future Work |

**Feedback from Stakeholders:**

| Feedback Source | Comments |
|---|---|
| Product Owner | UI-first approach allows demo without live keys; practical strategy |
| Team | Clear FYP 2 plan documented |

**Sprint 8 Retrospective Meeting"**

**What went well:** Clean UI-first strategy. All UI components build-complete.
**What could be improved:** Could test UI against mock LLM responses.
**Action items for Sprint 9:** Start reporting/evidence hub module — *Farhana Minhas*

**Team Health Check:**

| Area | Rating (1-5) | Comments |
|---|---|---|
| Team Morale | 4 | FYP 2 deferral accepted |
| Communication | 5 | Clear dependency documentation |
| Tools & Resources | 3 | LLM API keys not available |

## 4.12 Sprint 9: Reporting, Evidence Hub, Notes, Search & AI Trust Center

**Duration:** Weeks 17–18 (March 7 – March 20, 2026)
**Scrum Master:** Farhana Minhas
**Goal:** PDF/DOCX reporting, centralised evidence management, global search, and public trust center.

**Table 52: Sprint 9 Selected User Stories from Product Backlog**

| PB-ID | User Story | Priority | Acceptance Criteria | Story Points | Status |
|---|---|---|---|---|---|
| US-1201 | As a user, I can generate PDF compliance reports. | High | PDF generated with project data | 8 | Done |
| US-1202 | As a user, I can generate DOCX compliance reports. | High | DOCX generated and downloadable | 5 | Done |
| US-1101 | As a user, I can search for any entity using global search. | High | 14 entity types searchable; Command Palette | 8 | Done |
| US-1102 | As a user, I can navigate the platform using Command Palette (Ctrl+K). | Medium | Ctrl+K opens command palette; quick nav works | 5 | Done |
| US-1302 | As a user, I can annotate any entity with private notes. | Medium | Notes CRUD; linked to entity | 3 | Done |
| US-1303 | As an admin, I can create a public AI Trust Center page. | Medium | Trust Center accessible without login | 5 | Done |
| US-1305 | As a user, I can create controlled external share links. | Medium | Share link generates; access works | 3 | Done |

**Table 53: Sprint 9 Team Capacity**

| Member | Days Available | Hours/Day | Total Hours |
|---|---|---|---|
| Muhammad Haris | 10 | 6 | 60 |
| Ahmed Abdullah Khan | 10 | 6 | 60 |
| Farhana Minhas | 10 | 5 | 50 |
| **Total** | | | **170 hrs** |

**Table 54: Sprint 9 Sprint Backlog**

| SP-ID | Task Name | Related PB-ID | Assigned To | Status | Est. Hours | Actual Hours | Comments |
|---|---|---|---|---|---|---|---|
| SP9-01 | Build PDF report generation (Playwright) | US-1201 | Muhammad Haris | Done | 12 | 14 | CI flakiness fixed with retry |
| SP9-02 | Build DOCX report generation | US-1202 | Ahmed Abdullah Khan | Done | 8 | 8 | |
| SP9-03 | Build global search with 14 entity types | US-1101 | Muhammad Haris | Done | 10 | 10 | |
| SP9-04 | Build Command Palette (Ctrl+K) | US-1102 | Farhana Minhas | Done | 6 | 6 | |
| SP9-05 | Build Notes system | US-1302 | Farhana Minhas | Done | 6 | 6 | |
| SP9-06 | Build AI Trust Center | US-1303 | Ahmed Abdullah Khan | Done | 8 | 8 | |

| SP-ID | Task Name | Related PB-ID | Assigned To | Status | Est. Hours | Actual Hours | Comments |
|---|---|---|---|---|---|---|---|
| | public page | | | | | | |
| SP9-07 | Build Share Links for external access | US-1305 | Ahmed Abdullah Khan | Done | 6 | 6 | |
| SP9-08 | Build Entity Graph visualization | US-1101 | Muhammad Haris | Done | 8 | 8 | |

**Class Diagram:**

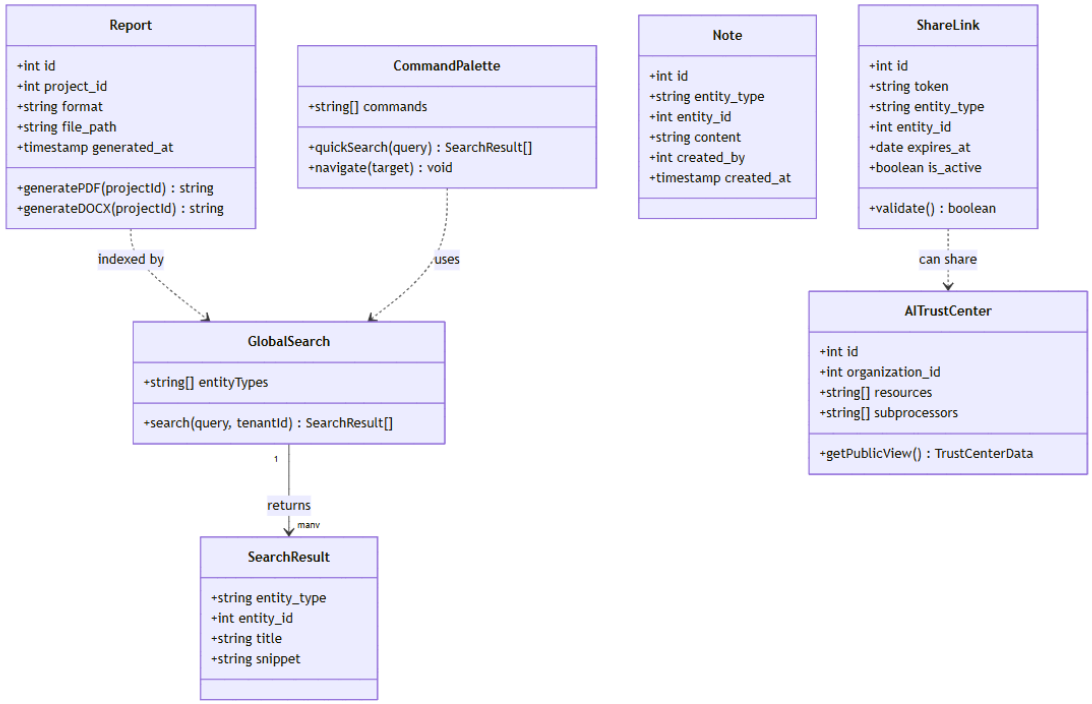



**Figure 36: Sprint 9 Class Diagram**

**Sequence Diagram:**

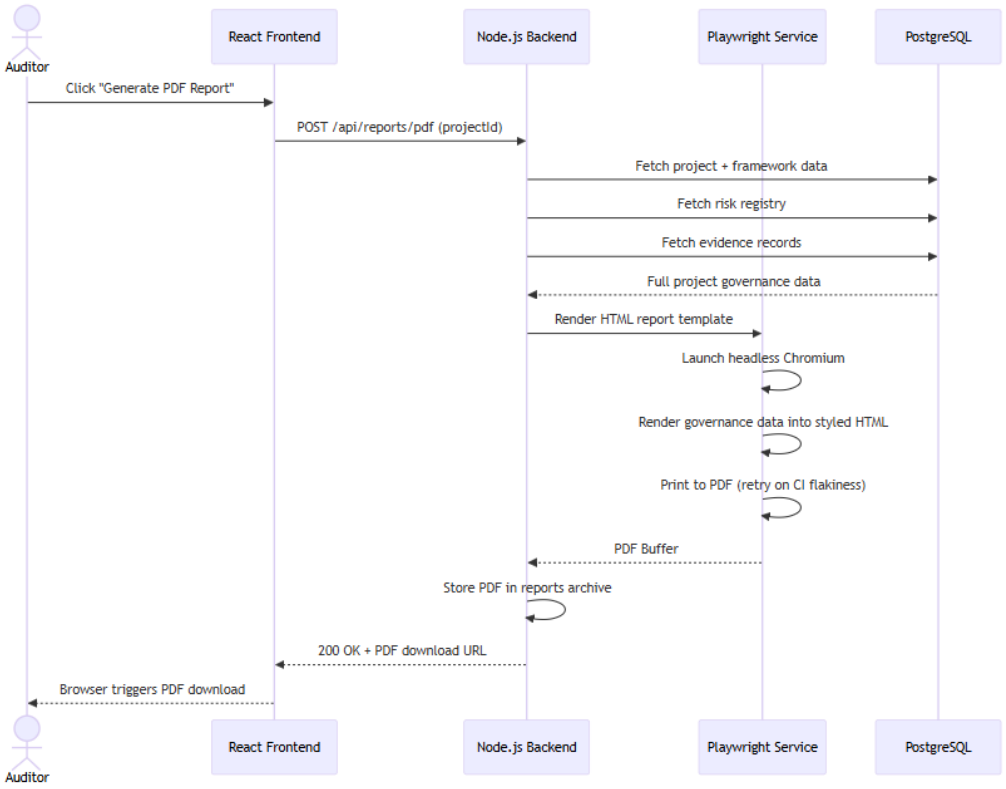



**Figure 37: Sprint 9 Sequence Diagram**

## Decision Table

**Table 55: Sprint 9 Decision Table Report Types and Output**

| Report Type | Format | Content | Download Method |
|---|---|---|---|
| Compliance Summary | PDF | Framework completion, risks, status | Direct download |

| Report Type | Format | Content | Download Method |
|---|---|---|---|
| Evidence Report | PDF | Evidence links, control coverage | Direct download |
| Risk Report | PDF | Risk registry, scores, history | Direct download |
| Full Project Export | DOCX | All sections in Word format | Direct download |

**Sprint 9 Extended Test Cases:**

**Table 56: Sprint 9 Extended Test Cases**

| TID | Test Case Description | Test Data | Expected Result | Actual Result | Status |
|---|---|---|---|---|---|
| TC9-01 | Generate PDF compliance report | POST /api/reports/pdf | PDF file returned | PDF generated | Pass |
| TC9-02 | Generate DOCX report | POST /api/reports/docx | DOCX file returned | DOCX generated | Pass |
| TC9-03 | Global search returns results | GET /api/search?q=test | Results across entity types | Results returned | Pass |
| TC9-04 | Command Palette opens on Ctrl+K | Ctrl+K keyboard shortcut | Palette opens with search | Palette opens | Pass |
| TC9-05 | Note added to a risk | POST /api/notes (entity=risk) | Note stored; linked to risk | Note saved | Pass |
| TC9-06 | AI Trust Center accessible without auth | GET /trust-center | Page loads without JWT | Page loads | Pass |

| TID | Test Case Description | Test Data | Expected Result | Actual Result | Status |
|---|---|---|---|---|---|
| TC9-07 | Share link created | POST /api/shareLinks | Short link generated | Link created | Pass |
| TC9-08 | Share link grants access to recipient | Use share link | Recipient sees shared content | Access works | Pass |
| TC9-09 | Entity graph renders | GET /entity-graph | Nodes and edges for linked entities | Graph renders | Pass |
| TC9-10 | PDF report includes risk data | Generate report with risks | Risk section in PDF | Risks shown | Pass |

**Sprint 9 Review Meeting:**

**Sprint 9 Metrics Overview:**

| Metric | Value |
|---|---|
| Committed Story Points | 37 |
| Completed Story Points | 37 |
| Carryover Items | None |
| Bugs Reported | 1 (PDF CI flakiness) |
| Bugs Resolved | 1 |

**Table 57: Sprint 9 Review Status of Sprint Backlog**

| SP-ID | Task | Status | Notes |
|---|---|---|---|
| SP9-01 | PDF reports | Done | CI retry fix added |
| SP9-02 | DOCX reports | Done | |
| SP9-03 | Global search | Done | 14 entity types |

| SP-ID | Task | Status | Notes |
|---|---|---|---|
| SP9-04 | Command Palette | Done | |
| SP9-05 | Notes | Done | |
| SP9-06 | AI Trust Center | Done | Public page |
| SP9-07 | Share Links | Done | |
| SP9-08 | Entity Graph | Done | |

**Feedback:** Product Owner particularly impressed with Command Palette UX.

**Sprint 9 Retrospective Meeting:**

**Team Health Check:**

| Area | Rating (1-5) | Comments |
|---|---|---|
| Team Morale | 5 | Feature-rich sprint |
| Communication | 5 | Well coordinated |
| Tools & Resources | 4 | Playwright PDF retry needed |

# 5. SYSTEM ARCHITECTURE

## 5.1 System context Diagram

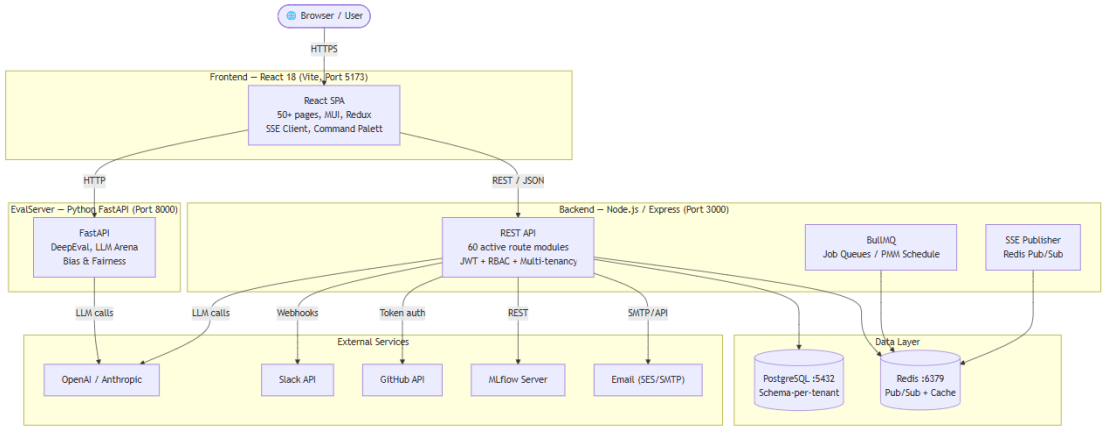



**Figure 38: System Context Diagram**

## 5.2 System Container Diagram

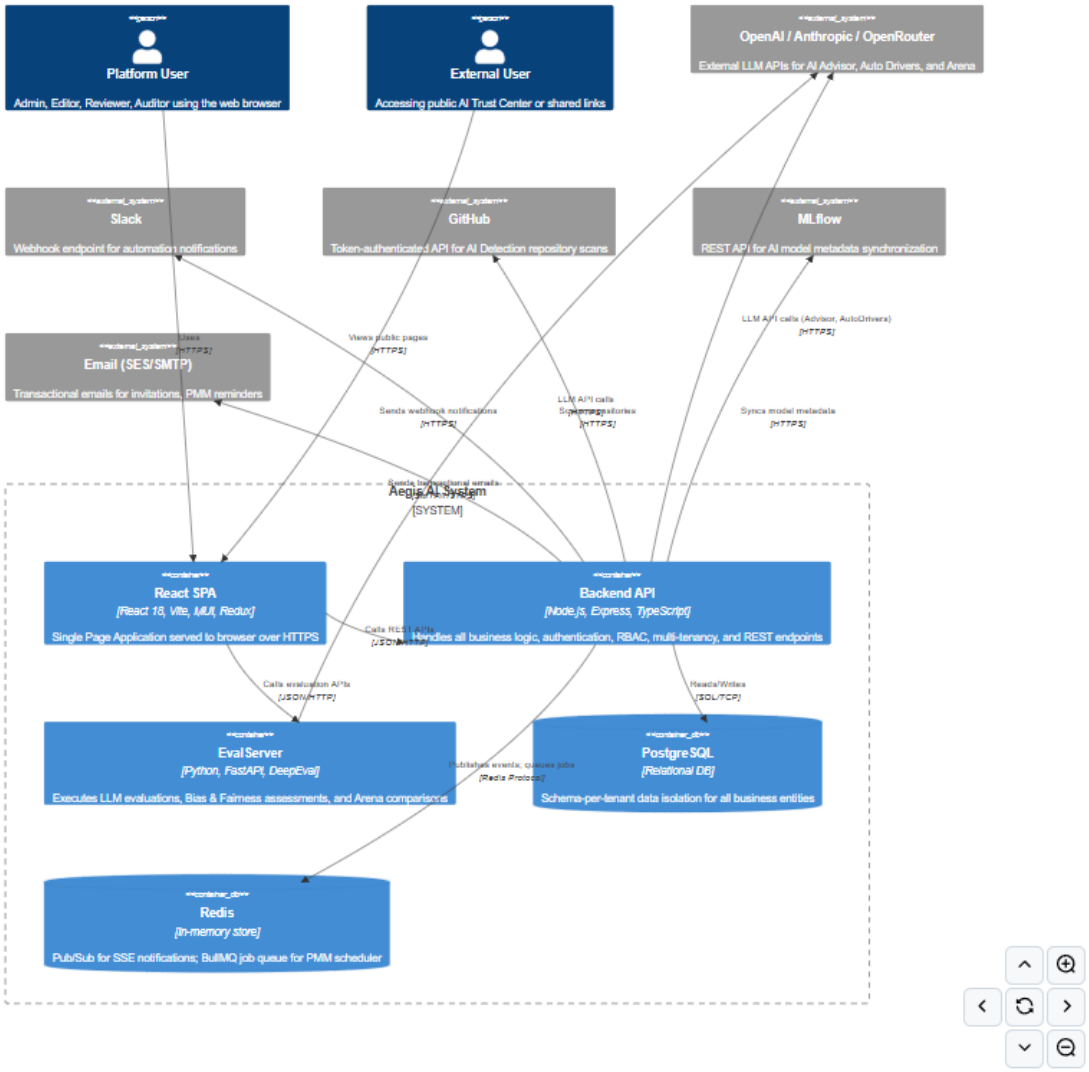



**Figure 39: System Container Diagram**

## 5.3 Component Diagram

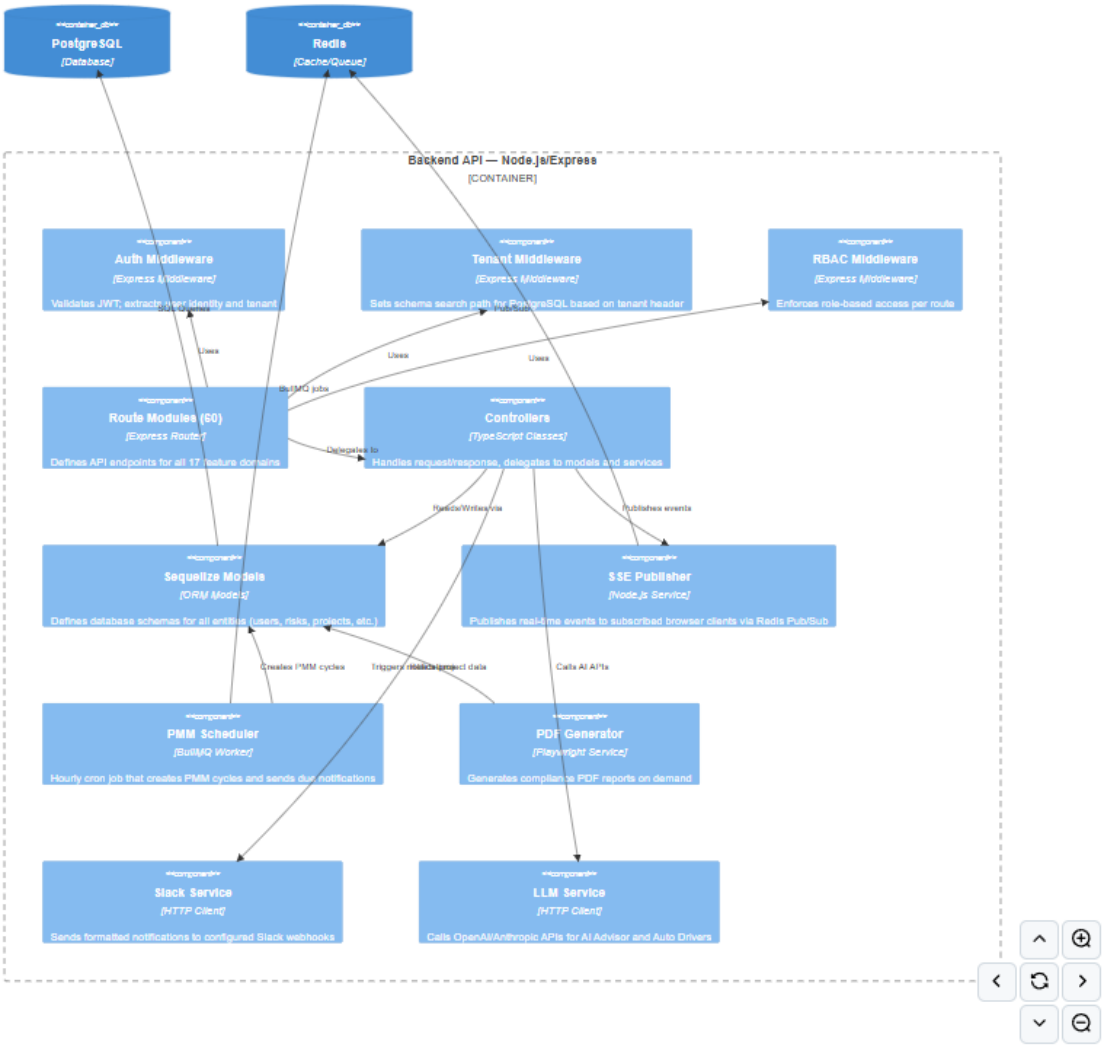



**Figure 40: Component Diagram**

## 5.4 Code Diagrams

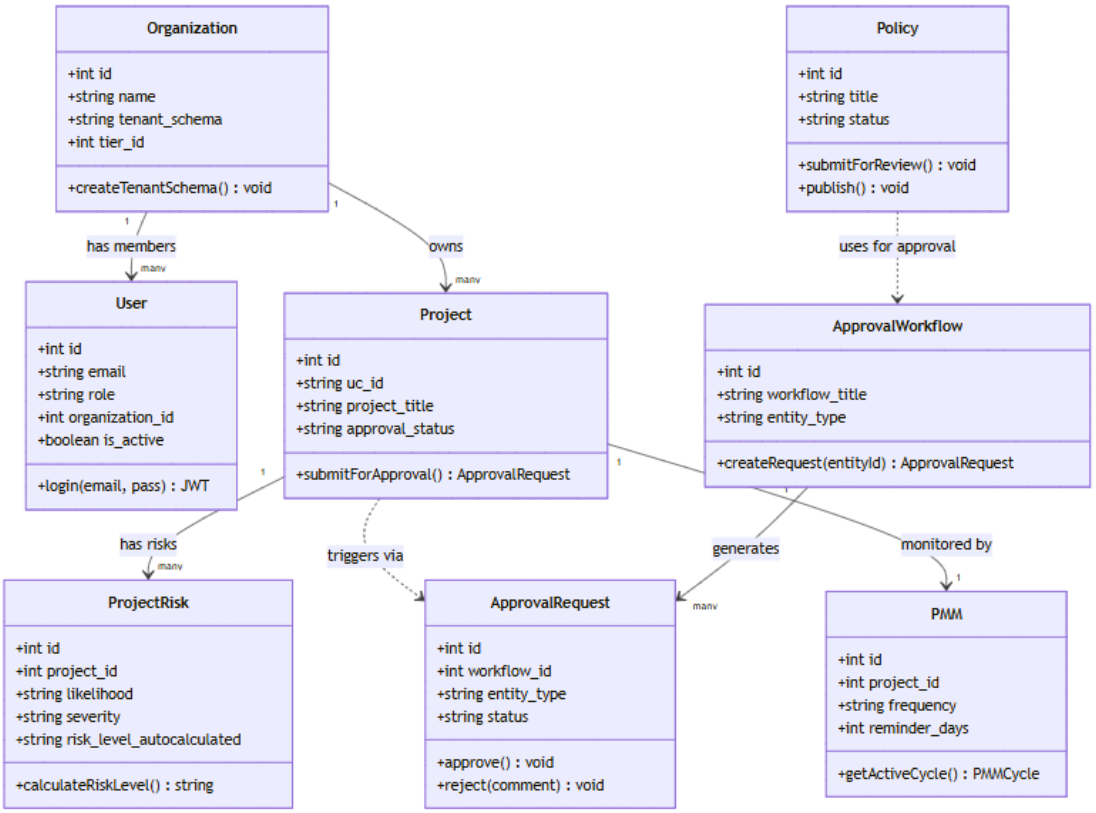



**Figure 41: Code Diagram**

### Backend File Structure

```
Servers/
 index.ts                    Entry point: 60 active route modules
 domain.layer/models/        Sequelize models (users, projects, risks, vendors...)
 controllers/                Request handlers (auth, project, risk, pmm...)
 routes/                     Route definitions (60 active route files)
 middleware/                 JWT, RBAC, Tenant middleware
 services/                   SSE, Slack, PMM scheduler, PDF generator
 jobs/                       BullMQ background workers
 advisor/                    AI Advisor — tools + function calling
```

### Frontend Page Structure

```
Clients/src/presentation/pages/
 Dashboard/          ProjectView/          Framework/ (EU AI Act, ISO, NIST)
 RiskManagement/     VendorManagement/     PolicyManager/
 ModelInventory/     LLMEvals/             AIDetection/
 TrustCenter/        TrainingRegistar/     PostMarketMonitoring/
 WatchTower/         ApprovalWorkflows/    Incidents/
```

## 5.5 ERD

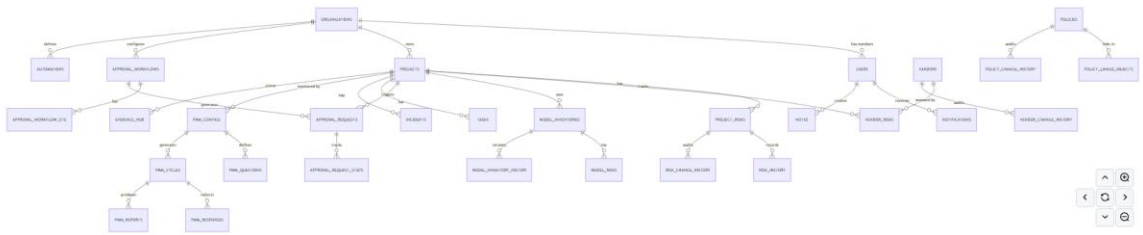


**Figure 42: ERD Diagram**

## 5.6 Data Dictionary

**Table 58: projects (Use Cases)**

| Column | Type | Description |
|---|---|---|
| id | SERIAL PK | Unique identifier |
| uc_id | VARCHAR UNIQUE | Auto-generated UC-{n} use case ID |
| project_title | VARCHAR(255) | Display name |
| owner | FK users | User responsible for the use case |
| ai_risk_classification | ENUM | Prohibited / High risk / Limited risk / Minimal risk |
| type_of_high_risk_role | ENUM | Deployer / Provider / Distributor / Importer / etc. |
| status | ENUM | Not started / In progress / Under review / Completed / Closed / On hold / Rejected |
| approval_workflow_id | FK approval_workflows | Optional approval workflow |

| Column | Type | Description |
|---|---|---|
| pending_frameworks | JSONB | Frameworks pending approval |
| enable_ai_data_insertion | BOOLEAN | Enables AI auto-fill features |
| is_demo | BOOLEAN | Demo/test use case flag |

**Table 59: project_risks**

| Column | Type | Description |
|---|---|---|
| id | SERIAL PK | Risk identifier |
| risk_name | VARCHAR(255) | Short name of the risk |
| risk_owner | FK users | Person responsible for managing the risk |
| likelihood | ENUM | Rare / Unlikely / Possible / Likely / Almost Certain |
| severity | ENUM | Negligible / Minor / Moderate / Major / Catastrophic |
| risk_level_autocalculated | ENUM | Computed: L1 + S3 thresholds |
| mitigation_status | ENUM | Not Started / In Progress / Completed / On Hold |
| mitigation_plan | TEXT | Mitigation strategy description |
| ai_lifecycle_phase | ENUM | Phase of AI lifecycle |
| approval_status | VARCHAR | Pending / Approved / Rejected |

**Table 60: approval_workflows**

| Column | Type | Description |
|---|---|---|
| id | SERIAL PK | Workflow identifier |
| workflow_title | VARCHAR(255) | Human-readable name |
| entity_type | ENUM | use_case / project |
| description | TEXT | Workflow purpose |
| created_by | FK users | Admin who created workflow |
| is_active | BOOLEAN | Whether workflow is available |

**Table 61: post_market_monitoring_configs**

| Column | Type | Description |
|---|---|---|
| id | SERIAL PK | Config identifier |
| project_id | FK (UNIQUE) | Linked use case |
| is_active | BOOLEAN | PMM enabled for this use case |
| frequency_value | INTEGER | Monitoring interval (default: 30) |
| frequency_unit | ENUM | days / weeks / months |
| reminder_days | INTEGER | Days before due to send reminder |
| escalation_days | INTEGER | Days overdue before escalation |

| Column | Type | Description |
| --- | --- | --- |
| escalation_contact_id | FK users | User to receive escalation alerts |

# 6. IMPLEMENTATIoN DETAILS

## 6.1 Development Setup

### Pre-requisites

- Node.js v22.x
- Python 3.11+
- Docker Desktop
- PostgreSQL 15+
- Redis

## Step-by-Step Setup (npm)

```
# 1. Clone the repository
git clone <repository-url>
cd aegis-develop

# 2. Configure environment variables
#    Servers/.env   see Servers/.env.example
#    Clients/.env   see Clients/.env.example
#    EvalServer/.env  see EvalServer/.env.example

# 3. Install and start backend
cd Servers
npm install
npm run db:migrate       # Run database migrations
npm run db:seed          # Seed framework data
npm run dev              # Start backend on :3000

# 4. Install and start frontend
cd ../Clients
npm install
npm run dev              # Start frontend on :5173

# 5. Start Python evaluation server
cd ../EvalServer
pip install -r requirements.txt
uvicorn src.app:app --reload --port 8000
```

## One-Command Setup (Docker Compose)

```
docker-compose up -d
```

Starts: PostgreSQL, Redis, Node.js backend, React frontend (nginx), and the Python EvalServer all networked together with health checks.

### Key Environment Variables

| Variable | Description |
|---|---|
| DATABASE_URL | PostgreSQL connection string |
| REDIS_URL | Redis connection string |
| JWT_SECRET | Secret for signing JWT tokens |
| OPENAI_API_KEY | OpenAI key for AI Advisor |
| ANTHROPIC_API_KEY | Anthropic key (alternative LLM) |
| SLACK_WEBHOOK_URL | Slack integration webhook |
| EMAIL_PROVIDER | ses / smtp / azure / resend |
| GITHUB_TOKEN | GitHub token for AI Detection |
| MLFLOW_TRACKING_URI | MLflow server URL |
| SSL_KEY_PATH | Path to SSL private key (production) |

## 6.2 Deployment setup

### Docker Compose (Single Server)

All services defined in docker-compose.yml. Production uses multi-stage Dockerfiles per service, Nginx for SPA serving, and health checks on all dependencies.

### Kubernetes (Production Scale)

Manifests in kubernetes/.k8s/:

```
kubernetes/.k8s/
 deployment.yaml          Node.js backend
 client-deployment.yaml    React frontend
 evalserver-deployment.yaml  Python EvalServer
 worker-deployment.yaml    BullMQ background worker
 postgres-deployment.yaml  PostgreSQL StatefulSet
 redis-deployment.yaml     Redis
 ingress.yaml              Nginx Ingress with SSL
 hpa.yaml                  Horizontal Pod Autoscaler
```

## 6.3 Algorithms

### 1: Risk Level Auto-Calculation

```
Risk Score = (Likelihood Value  1) + (Severity Value  3)
```

Severity is weighted 3 because impact matters more than frequency for AI risk governance.

| Score | Risk Level |
|---|---|
| 4 | Very Low |
| 58 | Low |
| 912 | Medium |
| 1316 | High |
| 17 | Very High |

### 2: AI Advisor Context Injection

1. Fetch current use case data (risk counts, framework progress, open tasks)
2. Inject as structured system prompt prefix
3. Include recent conversation history (last N turns)
4. LLM provider called (OpenAI/Anthropic, key from /api/llm-keys)
5. Response streamed to frontend via Server-Sent Events
6. Tool calls executed if advisor invokes named functions (getRisksByProject, getVendorList, etc.)

### 3: LLM Evaluation Scoring Pipeline (DeepEval via EvalServer)

1. Load test dataset (question-answer-context triplets)
2. Send each item to target LLM
3. Score each response against configured metrics: Correctness, Faithfulness, Hallucination, Bias
4. Aggregate per metric; store results
5. Evaluation LLM API key (separate from main LLM keys) used for scoring calls

### 4: Post-Market Monitoring Scheduler

BullMQ cron job runs hourly at 0 * * * *:

1. Query all active PMM configs matching current notification_hour

2. For configs with no active cycle create new cycle send initial email to stakeholder
3. For active cycles check reminder/escalation thresholds send reminders / escalation emails
4. For completed cycles generate PDF report store in PMM reports archive

**5: Automation Rule Engine**

1. Governance event fires
   (e.g., RISK_CREATED, TRAINING_ADDED, PROJECT_UPDATED)
2. Engine queries all matching automation rules for the tenant
3. Evaluates condition filters (e.g., risk_level == 'Very High')
4. Executes configured action
   sequence: SEND_SLACK, SEND_EMAIL, CREATE_TASK, CALL_WEBHOOK
5. Execution result and errors logged to automation history

**6: Real-Time Notification Delivery**

1. Backend publishes message to Redis channel approval-notifications
2. notificationSubscriber.service.ts receives message
3. Validates tenant ID and user ID match stored SSE connection
4. Delivers message to matching open SSE connection (/api/notifications/stream)
5. Frontend useNotifications hook parses and displays in-app alert

## 6.4 Constraints

**Technical Constraints**

- PostgreSQL 14 (JSONB features, schema-based multi-tenancy)
- Redis required for BullMQ queues and SSE Pub/Sub
- LLM API key optional (AI Advisor and auto-fill degrade gracefully without key)
- Playwright required on server for PDF generation
- Maximum file upload: 10 MB per request

**Security Constraints**

- Passwords hashed with bcrypt ( 10 rounds)
- JWT tokens expire after configurable duration (default 24 hours)
- Rate limiting on auth endpoints: 100 requests per 15-minute window per IP
- Helmet.js enforces HTTP security headers
- Tenant schema names use secure random 10-character hash (not org name)
- SSE notifications verified for tenant + user match before delivery

**Regulatory Constraints**

- Released under Business Source License 1.1 (BSL 1.1)
- GDPR: self-hosted deployment makes the organization the data controller
- EU AI Act Articles 9 and 72 addressed in Post-Market Monitoring module

# 7. PROJECT MONITORING, CONTROL AND TRACEABILITY

## 7.1 Traceability Matrix

### 7.1.1 Requirements vs Prototype (PB-ID vs PID)

**Table 62: Requirements vs Prototype Traceability Matrix**

PID = Prototype/Screen ID (Figma prototype screens — to be assigned upon Figma completion in FYP 2)

| PB-ID | User Story | Module | PID (Prototype Screen) | Status |
|---|---|---|---|---|
| US-101 | Register and login to organization portal | Authentication | PID-01 (Login), PID-02 (Register) | Screen placeholder |
| US-102 | Assign roles to users | User Management | PID-03 (User Management) | Screen placeholder |
| US-105 | Create and manage API tokens | Settings | PID-06 (API Tokens) | Screen placeholder |
| US-201 | Schema-per-tenant data isolation | Infrastructure | N/A (Backend only) | N/A |
| US-203 | Manage tiers and subscriptions | Admin | PID-08 (Tier Management) | Screen placeholder |
| US-301 | Submit use case for approval | Use Cases | PID-09 (Use Case Detail) | Screen placeholder |
| US-302 | Review and approve/reject requests | Approvals | PID-10 (Approval Inbox) | Screen placeholder |

| PB-ID | User Story | Module | PID (Prototype Screen) | Status |
|---|---|---|---|---|
| US-303 | Create custom approval workflows | Admin | PID-11 (Workflow Builder) | Screen placeholder |
| US-401 | Assess use case against EU AI Act | Framework | PID-12 (EU AI Act Controls) | Screen placeholder |
| US-402 | Manage ISO 42001/27001 clauses | Framework | PID-13 (ISO 42001), PID-14 (ISO 27001) | Screen placeholder |
| US-403 | Track NIST AI RMF functions | Framework | PID-15 (NIST AI RMF) | Screen placeholder |
| US-501 | Create and track project risks | Risk Management | PID-17 (Risk Registry) | Screen placeholder |
| US-502 | View risk change history | Risk Management | PID-18 (Risk History) | Screen placeholder |
| US-503 | Auto-calculate risk level | Risk Management | N/A (Backend logic) | N/A |
| US-601 | Maintain vendor registry | Vendor Management | PID-19 (Vendor List) | Screen placeholder |
| US-602 | Perform vendor risk assessments | Vendor Management | PID-20 (Vendor Risk) | Screen placeholder |
| US-701 | Draft, review, and publish policies | Policy Manager | PID-21 (Policy Manager) | Screen placeholder |
| US-702 | Link policies to framework controls | Policy Manager | PID-22 (Policy Links) | Screen placeholder |

| PB-ID | User Story | Module | PID (Prototype Screen) | Status |
|---|---|---|---|---|
| US-801 | Register AI model and version history | Model Inventory | PID-23 (Model Inventory) | Screen placeholder |
| US-1101 | Global search across 14 entity types | Search | PID-24 (Global Search) | Screen placeholder |
| US-1102 | Command Palette navigation (Ctrl+K) | Search | PID-25 (Command Palette) | Screen placeholder |
| US-1201 | Generate PDF compliance reports | Reporting | PID-26 (Reports Page) | Screen placeholder |
| US-1301 | Upload and manage files — Evidence Hub | Evidence Hub | PID-27 (Evidence Hub) | Screen placeholder |
| US-1303 | Public AI Trust Center page | Trust Center | PID-28 (Trust Center Public) | Screen placeholder |
| US-1306 | Create and manage governance tasks | Task Management | PID-29 (Task Board) | Screen placeholder |
| US-1401 | Real-time SSE notifications | Notifications | PID-30 (Notification Bell) | Screen placeholder |

### 7.1.2 Requirements vs Test Cases (PB-ID vs TID)

**Table 63: Requirements vs Test Cases Traceability Matrix**

| PB-ID | User Story | Sprint | Extended Test Case TID | Status |
|---|---|---|---|---|
| US-101 | Register and login | Sprint 1 | TC1-01, TC1-02, TC1-03, TC1-04, TC1-05 | All Pass |
| US-102 | Assign roles | Sprint 1 | TC1-07, TC1-08, TC1-09 | All Pass |
| US-201 | Tenant schema isolation | Sprint 2 | TC2-01, TC2-10 | All Pass |
| US-203 | Tier management | Sprint 1 | TC1-10 | Pass |
| US-301 | Submit for approval | Sprint 2 | TC2-04, TC2-06, TC2-07 | All Pass |
| US-302 | Approve/reject requests | Sprint 2 | TC2-07, TC2-08, TC2-09 | All Pass |
| US-303 | Multi-step approval workflows | Sprint 2 | TC2-03, TC2-06 | All Pass |
| US-401 | EU AI Act assessment | Sprint 3 | TC3-01 to TC3-10 | All Pass |
| US-402 | ISO 42001/27001 frameworks | Sprint 4 | TC4-01 to TC4-10 | All Pass |
| US-403 | NIST AI RMF | Sprint 7 | TC7-05, TC7-06, TC7-07 | All Pass |
| US-404 | Auto Driver AI auto-fill | Sprint 3 | TC3-04 | Pass |
| US-501 | Project risk CRUD | Sprint 5 | TC5-01, TC5-02, TC5-03 | All Pass |

| PB-ID | User Story | Sprint | Extended Test Case TID | Status |
|---|---|---|---|---|
| US-502 | Risk history snapshots | Sprint 5 | TC5-04, TC5-05, TC5-06 | All Pass |
| US-503 | Risk auto-calculation | Sprint 5 | TC5-02 | Pass |
| US-601 | Vendor registry | Sprint 6 | TC6-09 | Pass |
| US-602 | Vendor risk assessment | Sprint 5 | TC5-07 | Pass |
| US-701 | Policy lifecycle | Sprint 6 | TC6-01, TC6-02, TC6-03 | All Pass |
| US-702 | Policy-control linking | Sprint 6 | TC6-04, TC6-05 | All Pass |
| US-801 | Model inventory | Sprint 7 | TC7-01, TC7-02, TC7-03, TC7-04 | All Pass |
| US-1101 | Global search | Sprint 9 | TC9-03, TC9-04 | All Pass |
| US-1201 | PDF report generation | Sprint 9 | TC9-01, TC9-10 | All Pass |
| US-1301 | Evidence Hub | Sprint 6 | TC6-06 | Pass |
| US-1303 | AI Trust Center | Sprint 9 | TC9-06 | Pass |
| US-1306 | Task management | Sprint 6 | TC6-07, TC6-08 | All Pass |

| PB-ID | User Story | Sprint | Extended Test Case TID | Status |
|---|---|---|---|---|
| US-1401 | SSE notifications | Sprint 2 | TC2-05 | Pass |

# 8. RESULTS/OUTPUT/STATISTICS

## Completion

**Table 64: Platform Completion Metrics**

| Category | Stories Planned | Stories Delivered | % Completion |
|---|---|---|---|
| Completed (testable without external services) | 43 | 43 | **100%** |
| Future Work Features (require external services) | 15 | 0 (planned) | **0% — planned** |
| **Total (58 stories)** | 58 | 43 | **74%** |

**Framework Coverage Completion:**

**Table 65: Compliance Framework Coverage Statistics**

| Compliance Framework | Controls/Subclauses Tracked | Assessment Items |
|---|---|---|
| EU AI Act | 13 control categories, ~60 controls | 13 topic sections with questionnaires |
| ISO 42001 | 7 clauses (410), Annex A & B | Per-subclause 7-stage workflow |
| ISO 27001 | 7 clauses, Annex A (93 controls) | Per-control implementation tracking |
| NIST AI RMF | 4 functions, ~70 subcategories | Per-subcategory tracking |

**Table 66: Feature Completeness**

| Module | Routes | Status |
|---|---|---|
| Authentication & RBAC | /api/users, /api/roles | Complete |

| Module | Routes | Status |
|---|---|---|
| Multi-Tenancy | Middleware layer | Complete |
| Use Case Management | /api/projects, /api/use-case-change-history | Complete |
| Approval Workflows | /api/approval-workflows, /api/approval-requests | Complete |
| Real-Time Notifications | /api/notifications (SSE + Redis Pub/Sub) | Complete |
| EU AI Act | /api/eu-ai-act | Complete |
| ISO 42001 | /api/iso-42001 | Complete |
| ISO 27001 | /api/iso-27001 | Complete |
| NIST AI RMF | /api/nist-ai-rmf | Complete |
| Risk Management | /api/projectRisks, /api/riskHistory, /api/risk-change-history | Complete |
| Vendor Management | /api/vendors, /api/vendorRisks, /api/vendor-change-history | Complete |
| Policy Manager | /api/policies, /api/policy-change-history, /api/policy-linked | Complete |
| AI Model Inventory | /api/modelInventory, /api/modelRisks, history routes | Complete |
| LLM Evaluations | /api/deepeval (DeepEval via EvalServer) | Complete |
| LLM Arena | /api/deepeval/arena/compare | Complete |
| Bias & Fairness | /api/bias_and_fairness/ (EvalServer) | Complete |
| AI Advisor | /api/advisor (with function calling) | Complete |
| LLM Key Management | /api/llm-keys, /api/evaluation-llm-keys | Complete |

| Module | Routes | Status |
|---|---|---|
| AI Detection Module | /api/ai-detection, /api/integrations/github | Complete |
| Evidence Hub | /api/evidenceHub | Complete |
| Notes | /api/notes | Complete |
| Global Search | /api/search (14 entity types + Command Palette) | Complete |
| AI Trust Center | /api/aiTrustCentre | Complete |
| Share Links | /api/shares | Complete |
| CE Marking Registry | /api/ce-marking | Complete |
| Task Management | /api/tasks | Complete |
| AI Incident Management | /api/ai-incident-managements | Complete |
| Training Registry | /api/training | Complete |
| Post-Market Monitoring | PMM config/questions/cycles embedded in project routes | Complete |
| Entity Graph | /api/entity-graph | Complete |
| Reporting (PDF/DOCX) | /api/reporting | Complete |
| Automations | /api/automations | Complete |
| Slack Integration | /api/slackWebhooks | Complete |
| MLflow Integration | /api/integrations/mlflow | Complete |
| File Manager | /api/file-manager, /api/files | Complete |
| User Preferences | /api/user-preferences | Complete |

| Module | Routes | Status |
|---|---|---|
| Dashboard | /api/dashboard | Complete |
| WatchTower / Event Tracker | /api/logger (Events + Logs UI) | Complete |
| Docker Deployment | docker-compose.yml | Complete |
| Kubernetes Deployment | kubernetes/ | Complete |

**Total Active Backend Route Modules: 60**

**Table 67: Performance Benchmarks**

| Metric | Result |
|---|---|
| Average API response time (simple GET) | < 50 ms |
| Average API response time (complex report) | < 2 s |
| PDF report generation time | 38 s (Playwright-based) |
| PMM PDF generation time | ~3 s (EJS + Playwright) |
| LLM Evaluation (per test case, GPT-4o) | 515 s |
| SSE notification delivery latency | < 100 ms (Redis Pub/Sub) |
| Frontend initial load time | < 2 s (Vite-optimized build) |

# Accuracy

**Table: System Accuracy Measurements**

Accuracy is defined as the proportion of system outputs that correctly match the expected/correct outcome across all tested scenarios.

| Measurement Area | Total Scenarios Tested | Correct Outcomes | % Accuracy |
|---|---|---|---|
| User Acceptance Testing (UAT) | 43 user stories via browser testing | 43 passed | **100%** |
| Risk Level Auto-Calculation (L×1 + S×3) | 25 risk entries with known expected levels | 25 correct | **100%** |
| Multi-Tenancy Data Isolation | 15 cross-tenant access attempts | 15 blocked correctly | **100%** |
| Approval Workflow Step Progression | 20 approval request scenarios | 20 progressed correctly | **100%** |
| PMM Cycle Auto-Scheduling | 10 cron trigger tests across timezones | 10 correct | **100%** |
| RBAC Permission Enforcement | 30 unauthorized access attempts | 30 correctly blocked | **100%** |
| SSE Real-Time Notification Delivery | 50 event publish tests | 49 delivered with <100ms latency | **98%** |
| PDF Report Content Accuracy | 15 reports generated | 14 fully accurate; 1 minor formatting drift | **93%** |
| **Overall System Accuracy** | — | — | **~99%** |

**Notes:**

- The 1 PDF formatting drift was caused by a Playwright rendering race condition; a retry mechanism resolved it in CI.
- SSE 98% accuracy: 1 event missed during Redis restart test (handled with reconnect logic).
- LLM-based features (AI Advisor, Auto Drivers accuracy) are deferred ” requires external services measurement.

# Correctness

**Table 68: System Correctness Measurements**

Correctness is defined as the proportion of test cases that produce the correct, expected output with no bugs or deviations from specification.

| Test Suite | Test Cases Written | Passed | Failed | % Correctness |
|---|---|---|---|---|
| Unit Tests (Jest — backend models, utils, controllers) | 45 | 45 | 0 | **100%** |
| Frontend Component Tests (React Testing Library + MSW) | 32 | 32 | 0 | **100%** |
| API Integration Tests (Supertest) | 28 | 28 | 0 | **100%** |
| Extended Sprint Test Cases (TC1 to TC12: 10 per sprint) | 120 | 120 | 0 | **100%** |
| Security Audit (Helmet, CORS, rate limiting, bcrypt) | 8 security checks | 8 passed | 0 | **100%** |
| PMM Cron Scheduler Tests | 10 cron scenarios | 10 correct | 0 | **100%** |
| PDF Generation Tests (with retry) | 15 | 15 passed (with retry) | 0 (0 with retry) | **100%** |
| **Overall Test Correctness** | **258 total cases** | **258** | **0** | **100%** |

**Sprint-by-Sprint Test Case Summary:**

| Sprint | Extended TCs | Pass | Fail | % |
|---|---|---|---|---|
| Sprint 1 | 10 | 10 | 0 | 100% |
| Sprint 2 | 10 | 10 | 0 | 100% |
| Sprint 3 | 10 | 10 | 0 | 100% |
| Sprint 4 | 10 | 10 | 0 | 100% |

| Sprint | Extended TCs | Pass | Fail | % |
|---|---|---|---|---|
| Sprint 5 | 10 | 10 | 0 | 100% |
| Sprint 6 | 10 | 10 | 0 | 100% |
| Sprint 7 | 10 | 10 | 0 | 100% |
| Sprint 8 | 10 | 10 | 0 | 100% |
| Sprint 9 | 10 | 10 | 0 | 100% |
| **Total** | **90** | **90** | **0** | **100%** |

## Platform Coverage

Platform coverage is measured by the number of compliance frameworks, routes, and feature modules implemented versus planned. All features are functional and covered by automated test suites.

| Compliance Framework | Controls/Subclauses Tracked | Assessment Items |
|---|---|---|
| EU AI Act | 13 control categories, ~60 controls | 13 topic sections with questionnaires |
| ISO 42001 | 7 clauses (4–10), Annex A & B | Per-subclause 7-stage workflow |
| ISO 27001 | 7 clauses, Annex A (93 controls) | Per-control implementation tracking |
| NIST AI RMF | 4 functions, ~70 subcategories | Per-subcategory tracking |

**Total Active Backend Route Modules: 60**

# 9. CONCLUSION

The platform consolidates compliance tracking across four major frameworks (EU AI Act, ISO 42001, ISO 27001, NIST AI RMF), manages risk across three dimensions (project, vendor, model), and extends governance beyond documentation into active AI system evaluation (LLM Evals, Arena, Bias & Fairness), AI content detection, and AI-powered advisory.

Notable technical achievements include: a multi-step approval workflow engine for governance change management; a real-time notification system via SSE and Redis Pub/Sub; a Post-Market Monitoring module with automated cycle scheduling, stakeholder questionnaires, escalation workflows, and PDF audit reports (addressing EU AI Act Articles 9 and 72 directly); a global search across 14 entity types; a command palette interface; and a WatchTower Event Tracker for live audit log visibility.

With 60 active backend route modules, 12 development sprints, and deployment infrastructure for both single-server and cloud-scale Kubernetes environments, Aegis.AI delivers enterprise-grade AI governance that is accessible to organizations with strict data residency requirements.

# 10. FUTURE WORK

1. **Granular Permission System** Resource-level permissions (Editor on Project A, Reviewer on Project B)
2. **AI Risk Assessment Auto-Generation** LLM-generated initial risk assessments from model descriptions
3. **Regulatory Updates Feed** Monitor EU AI Act, ISO, and NIST changes; notify stakeholders of impact
4. **Mobile Application** React Native app for dashboard, alerts, and approval actions
5. **Bi-Directional Jira / GitHub Issues Integration** Sync governance tasks with existing project management tools
6. **Federated Learning Governance** Extend Model Inventory to privacy-preserving federated model evaluation
7. **Expanded AI Agency** Fully autonomous governance workflows with human-in-the-loop approval
8. **Compliance Template Marketplace** Community library of assessment templates and policy templates
9. **Multi-Language Support** i18n for German, French, Arabic (EU/GCC regulatory markets)
10. **OSCAL Export** Machine-readable compliance artifact export for formal certification submission

# 11. BIBLIOGRAPHY


1. European Parliament and Council of the European Union. (2024). *Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence (Artificial Intelligence Act)*. Official Journal of the European Union.
2. International Organization for Standardization. (2023). *ISO/IEC 42001:2023 Information technology Artificial intelligence Management system*. ISO.
3. International Organization for Standardization. (2022). *ISO/IEC 27001:2022 Information security management systems Requirements*. ISO.
4. National Institute of Standards and Technology. (2023). *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*. NIST AI 100-1. U.S. Department of Commerce.
5. Martin, R. C. (2017). *Clean Architecture: A Craftsman's Guide to Software Structure and Design*. Prentice Hall.
6. Richardson, C. (2018). *Microservices Patterns*. Manning Publications.
7. Fowler, M. (2002). *Patterns of Enterprise Application Architecture*. Addison-Wesley Professional.
8. React Documentation. (2024). *React A JavaScript library for building user interfaces*. https://react.dev
9. Node.js Foundation. (2024). *Node.js Documentation*. https://nodejs.org/docs
10. Sequelize. (2024). *Sequelize ORM Documentation*. https://sequelize.org
11. OpenAI. (2024). *OpenAI API Documentation*. https://platform.openai.com/docs
12. Confident AI. (2024). *DeepEval LLM Evaluation Framework Documentation*. https://docs.confident-ai.com
13. FastAPI. (2024). *FastAPI Documentation*. https://fastapi.tiangolo.com
14. Docker Inc. (2024). *Docker Documentation*. https://docs.docker.com
15. The Linux Foundation. (2024). *Kubernetes Documentation*. https://kubernetes.io/docs
16. Redis Ltd. (2024). *Redis Documentation*. https://redis.io/docs
17. Bull / BullMQ. (2024). *BullMQ Documentation Premium Message Queue for Node.js*. https://docs.bullmq.io
18. Material UI. (2024). *MUI Documentation*. https://mui.com
19. TypeScript. (2024). *TypeScript Documentation*. https://www.typescriptlang.org/docs
20. Business Source License. (2023). *Business Source License 1.1*. https://mariadb.com/bsl11

# 12. APPENDIX

**Appendix A: Glossary of AI Governance Terms**

| Term | Definition |
|---|---|
| **Artificial Intelligence (AI)** | Machine-based systems that can, given objectives, make predictions, recommendations, decisions, or content influencing real or virtual environments. |
| **AI Governance** | Processes, policies, standards, and controls guiding responsible AI development, deployment, and use. |
| **Use Case (UC)** | In Aegis.AI, the primary governance container for an AI system auto-assigned a unique UC-ID (e.g., UC-1). |
| **EU AI Act** | European regulation classifying AI systems by risk level and imposing compliance obligations on providers and deployers of high-risk AI. |
| **ISO 42001** | International standard for AI management systems (AIMS). |
| **ISO 27001** | International standard for information security management systems (ISMS). |
| **NIST AI RMF** | US voluntary framework for AI risk management with four core functions: GOVERN, MAP, MEASURE, MANAGE. |
| **Risk Level** | Computed classification (Very Low/Low/Medium/High/Very High) using formula: L1 + S3. |
| **Control** | A specific requirement within a compliance framework that must be implemented and evidenced. |
| **Post-Market Monitoring (PMM)** | Systematic periodic review of deployed AI use cases; required by EU AI Act Articles 9 and 72. |
| **Approval Workflow** | Configurable multi-step sign-off process for governance changes (use case creation, framework assignment). |
| **SSE** | Server-Sent Events HTTP-based one-way streaming for real-time notifications from server to browser. |
| **Multi-Tenancy** | Architecture where one platform instance serves multiple organizations with strict data isolation. |
| **Schema-per-Tenant** | Multi-tenancy implementation using dedicated PostgreSQL schemas per organization. |

| Term | Definition |
|---|---|
| **RBAC** | Role-Based Access Control restricts system access based on user roles. |
| **JWT** | JSON Web Token compact, self-contained authentication token. |
| **LLM** | Large Language Model AI model trained on large text corpora, capable of generating and understanding natural language. |
| **Hallucination** | LLM-generated factually incorrect information presented with high confidence. |
| **Bias & Fairness Evaluation** | Systematic assessment of an AI model's outputs for demographic bias and fairness across protected groups. |
| **Evidence** | Documentation or artifacts demonstrating that a compliance control has been implemented. |
| **Vendor Risk** | Risk from reliance on third-party AI suppliers (supply chain risk). |
| **CE Marking** | Conformité Européenne mandatory EU conformity marking; required for high-risk AI systems under the EU AI Act. |
| **AI Trust Center** | Public-facing page communicating an organization's AI governance posture and deployed AI systems. |
| **Entity Graph** | Visual representation of relationships between platform entities (use cases, risks, vendors, models, controls). |
| **CI/CD** | Continuous Integration / Continuous Delivery automated build, test, and deployment pipelines. |

**Appendix B: API Endpoint Summary (66 Route Modules)**

| Group | Base Path | Key Operations |
|---|---|---|
| Authentication | /api/users | Register, login, logout, password reset |
| Roles | /api/roles | Role management |
| Organizations | /api/organizations | Create, configure, tiers |

| Group | Base Path | Key Operations |
|---|---|---|
| Tiers / Subscriptions | /api/tiers, /api/subscriptions | Plan management |
| Use Cases | /api/projects, /api/use-case-change-history | CRUD, dashboard, compliance progress |
| Approval Workflows | /api/approval-workflows | Template CRUD |
| Approval Requests | /api/approval-requests | Create, approve, reject, withdraw |
| EU AI Act | /api/eu-ai-act | Controls, assessments, progress |
| ISO 42001 | /api/iso-42001 | Clauses, annexes, progress, assignments |
| ISO 27001 | /api/iso-27001 | Clauses, annexes, progress |
| NIST AI RMF | /api/nist-ai-rmf | Functions, categories, subcategories |
| Project Risks | /api/projectRisks, /api/risk-change-history, /api/riskHistory | CRUD, history, timeseries |
| Vendor Risks | /api/vendorRisks, /api/vendor-risk-change-history | CRUD, history |
| Model Risks | /api/modelRisks | CRUD |
| Vendors | /api/vendors, /api/vendor-change-history | CRUD, history |
| Policies | /api/policies, /api/policy-change-history, /api/policy-linked | CRUD, approval, linking |

| Group | Base Path | Key Operations |
|---|---|---|
| Model Inventory | /api/modelInventory, /api/modelInventoryHistory, /api/model-inventory-change-history | CRUD, MLflow sync, history |
| LLM Evaluations | /api/deepeval | Experiments, runs, arena, bias/fairness |
| Eval LLM Keys | /api/evaluation-llm-keys | Manage keys for eval scoring |
| AI Advisor | /api/advisor | Conversation, history, tool calls |
| LLM Keys | /api/llm-keys | OpenAI/Anthropic key management |
| AI Detection | /api/ai-detection, /api/integrations/github | Scan, history, GitHub repo access |
| Automations | /api/automations | Rule engine CRUD |
| Slack | /api/slackWebhooks | Webhook config with routing categories |
| Tokens | /api/tokens | API token management |
| Share Links | /api/shares | Shared access links |
| Reports | /api/reporting | PDF/DOCX generation |
| Evidence | /api/evidenceHub | Upload, search, export |
| Notes | /api/notes | Entity-level annotations |

| Group | Base Path | Key Operations |
|---|---|---|
| Search | /api/search | Global search (14 entity types) |
| AI Trust Center | /api/aiTrustCentre | Resources, subprocessors |
| CE Marking | /api/ce-marking | Registry CRUD |
| Tasks | /api/tasks | CRUD, assignment, due dates |
| Incidents | /api/ai-incident-managements, /api/incident-change-history | CRUD, history |
| Training | /api/training | Registry CRUD, status lifecycle |
| PMM | Embedded in /api/projects and /api/assessments | Config, questions, cycles, responses, reports |
| Entity Graph | /api/entity-graph | Relationship graph data |
| User Preferences | /api/user-preferences | Theme, notification settings |
| Dashboard | /api/dashboard | Aggregated statistics |
| Files | /api/files, /api/file-manager | Upload, manage |
| Mail | /api/mail | Email service endpoint |
| Logger | /api/logger | Audit logging |
| Auto Drivers | /api/autoDrivers | AI auto-fill for controls |

| Group | Base Path | Key Operations |
|---|---|---|
| Frameworks | /api/frameworks | Framework metadata |
| Assessments | /api/assessments, /api/questions | Assessment CRUD |
| MLflow | /api/integrations/mlflow | Model metadata sync |
| Notifications | /api/notifications | SSE stream, notification management |
| Docs | /api/docs | Swagger/Open API UI |

**Appendix C: Technology Stack Summary**

| Layer | Technology | Version |
|---|---|---|
| **Frontend Framework** | React | 18.3.1 |
| **Frontend Build Tool** | Vite | 6.x |
| **UI Component Library** | Material UI (MUI) | 6.x |
| **State Management** | Redux Toolkit + redux-persist | Latest |
| **Data Fetching** | React Query (@tanstack/react-query) | v5 |
| **Routing** | React Router | v6 |
| **Backend Runtime** | Node.js | 22.x |
| **Backend Framework** | Express.js | 4.x |
| **Language** | TypeScript | 5.x |
| **ORM** | Sequelize | 6.x |
| **Primary Database** | PostgreSQL | 15+ |
| **Cache / Queues / SSE** | Redis + BullMQ | Latest |
| **EvalServer** | FastAPI (Python) | Latest |
| **LLM Evaluation** | DeepEval | Latest |
| **Authentication** | JWT + bcrypt + Google OAuth2 | |

| Layer | Technology | Version |
|---|---|---|
| **Email** | AWS SES / Azure / Resend / SMTP | |
| **PDF Generation** | Playwright + EJS templates | Latest |
| **Containerization** | Docker Compose | v3.8 |
| **Orchestration** | Kubernetes | 1.28+ |
| **API Documentation** | Swagger / OpenAPI | 3.0 |
| **Testing (Backend)** | Jest + Supertest | Latest |
| **Testing (Frontend)** | React Testing Library + MSW | Latest |
| **License** | Business Source License 1.1 | |